



Chief Audit Officer

Istruzione Operativa n 20 v 02

del 29 maggio 2023

**“PROCEDURA METODOLOGICA INTERNAL AUDIT
(MANUALE IA)”**

INDICE

1	INTRODUZIONE	6
2	DEFINIZIONI E ABBREVIAZIONI	7
3	SINTESI DEI PRINCIPALI CONTENUTI DEL MANUALE DI INTERNAL AUDIT	10
4	GESTIONE DELLE RISORSE	18
4.1	Assegnazione risorse	18
4.2	Identificazione profili e competenze nella funzione Internal Audit.....	19
4.3	Formazione delle risorse.....	19
4.4	Budget del personale della funzione IA.....	20
4.5	Conflitto di interesse e riservatezza.....	21
5	LA PIANIFICAZIONE DEGLI INTERVENTI DI AUDIT.....	22
5.1	Definizione dell'Universo degli Oggetti di Audit	23
5.2	Determinazione dell'indice di rischio degli OA	24
5.3	Definizione del Piano di Audit.....	25
5.4	Pianificazione interventi di <i>follow-up</i> "sul campo"	26
5.5	Approvazione del Piano di Audit	27
6	PROGRAMMAZIONE OPERATIVA.....	28
7	GESTIONE DEGLI INTERVENTI DI AUDIT	29
7.1	Avvio dell'intervento.....	30
7.2	Attività preliminare.....	30
7.2.1	Relazione di pianificazione	31
7.2.2	Raccolta della documentazione e incontro preliminare con la struttura auditata	32
7.2.3	Analisi delle informazioni e definizione del piano dei test.....	34
7.2.4	Budget delle risorse e tempistiche di realizzazione dell'intervento.....	35
7.2.5	Definizione del Programma di Lavoro dell'intervento	36
7.3	Attività esecutiva.....	37
7.3.1	Focus su selezione del campione.....	38
7.3.2	Esecuzione delle verifiche (test).....	40

7.3.3	Identificazione dei rilievi e delle raccomandazioni di rafforzamento del SCIGR.....	42
7.4	Formalizzazione e <i>reporting</i> dei risultati	43
7.4.1	Valutazione di sintesi (<i>rating</i>) del SCIGR e dei rilievi.....	43
7.4.2	Predisposizione Piano di Azione dell'intervento	45
7.4.3	Discussione con il Management	46
7.4.4	Predisposizione Rapporto di audit	46
7.4.5	Trasmissione del Rapporto di audit	48
7.5	Monitoraggio delle azioni correttive.....	49
7.5.1	Follow-up “sul campo”	50
7.6	Gestione degli interventi con metodologia “ <i>agile</i> ”	52
7.7	Gestione dei <i>Joint Audit</i>	53
7.8	Aspetti specifici degli audit <i>spot</i>	54
7.9	Focus su specifiche tecniche di indagine e analisi.....	55
8	CONTINUOUS AUDITING.....	57
8.1	Verifiche specifiche sui KRI	58
8.2	Verifiche ricondotte nell'ambito degli interventi di audit.....	59
9	COMBINED ASSURANCE: VERIFICHE INTEGRATE AUDIT E TESTING 262.....	60
9.1	Pianificazione degli interventi.....	60
9.2	Esecuzione degli interventi	61
9.3	Reporting.....	63
9.4	Monitoraggio azioni correttive	64
10	ALTRE ATTIVITÀ DI SUPPORTO SPECIALISTICO.....	65
10.1	Monitoraggio indipendente.....	65
10.2	Istruttorie su segnalazioni	65
10.3	Attività di consulenza.....	66
11	FLUSSI INFORMATIVI (<i>REPORTING</i>) CON GLI <i>STAKEHOLDER</i>	67
11.1	Relazione periodica sulle attività della funzione IA.....	68
11.2	Report sullo stato di attuazione delle azioni correttive.....	69
11.3	Report specifici per il <i>Management/Process Owner</i>	69
12	RAPPORTI CON GLI ORGANI DI CONTROLLO E VIGILANZA E IL COMITATO ETICO	70



12.1	Rapporti con l'Organismo di Vigilanza e il Comitato Etico	71
12.2	Rapporti con il Comitato Controllo e Rischi e il Collegio Sindacale.....	72
13	<i>QUALITY ASSURANCE</i> E MIGLIORAMENTO CONTINUO	72
13.1	Valutazioni interne (<i>Internal Quality Review</i>)	72
13.2	Valutazioni esterne (<i>External Quality Review</i>)	75
14	GESTIONE E ARCHIVIAZIONE DELLA DOCUMENTAZIONE.....	76
14.1	Regole generali di riferimento	76
14.2	Documentazione di audit	77
14.3	Altra documentazione	78
14.4	Regole di accesso agli archivi.....	79
14.5	Regole operative di classificazione della documentazione gestita dall'Internal Audit.....	80
15	TEMPI DI CONSERVAZIONE DELLA DOCUMENTAZIONE	80
16	SISTEMI INFORMATIVI A SUPPORTO	80
17	INDICE DEGLI ALLEGATI.....	81

AMBITO DI APPLICAZIONE

- Ferrovie dello Stato Italiane S.p.A.
- Società del Gruppo FS Italiane

ATTO DI DIREZIONE E COORDINAMENTO ☒**MODALITA' DI RECEPIMENTO DI POLO E DI ADOZIONE SOCIETARIA**

Il presente documento è un atto di direzione e coordinamento a valenza di Gruppo¹.

Le Capogruppo di Settore e le altre Società soggette a direzione e coordinamento di FS SpA, adottano, nel rispetto delle proprie prerogative di autonomia e indipendenza, il presente documento (atto di adozione).

Inoltre, le Capogruppo di Settore con il medesimo atto provvedono al recepimento del documento nell'ambito del rispettivo Polo (atto di recepimento di Polo).

Successivamente, le Società del Polo adottano il presente documento (atto di adozione).

In relazione alle peculiarità organizzative del singolo contesto, l'atto di adozione delle Società del Polo, nel caso in cui siano Sub-Holding, può avere valenza anche sulle proprie controllate.

Le Società estere adottano i principi disciplinati in coerenza con l'ordinamento giuridico ove la Società ha la sede legale.

Ciascuna Società garantisce la corretta e costante applicazione di quanto definito e ne assicura la massima diffusione al proprio interno ed il relativo controllo attuativo anche presso le proprie controllate, nel rispetto degli obblighi di riservatezza e delle prerogative di autonomia ed indipendenza di ciascuna Società.

- ☒ Applicabilità diretta
- ☐ Applicabilità con caratterizzazione organizzativa
- ☐ Applicabilità con integrazione
- ☐ Applicabilità con definizione di processo

¹ Per Gruppo FS Italiane si intendono le Società, italiane o estere, controllate da FS SpA ai sensi dell'art. 2359 comma 1, numeri 1) e 2) del codice civile. Italcertifer SpA non è soggetta a direzione e coordinamento, a ulteriore garanzia della sua indipendenza in relazione all'attività svolta. Gli atti di direzione e coordinamento emanati dalla Holding sono inviati ad Italcertifer quali descrizione degli indirizzi adottati nell'ambito del Gruppo FS Italiane, che potranno essere valutati dal management di Italcertifer nell'ambito della propria discrezionalità gestionale.

1 INTRODUZIONE

Nel rispetto degli Standard internazionali² per la pratica professionale dell'Internal Audit, le finalità, i poteri e le responsabilità dell'Internal Audit sono stati formalmente definiti nel “Modello di Governance Internal Audit”, cosiddetto “*Audit Charter*”³.

Coerentemente con quanto previsto nell’*Audit Charter* e nella normativa che regola il monitoraggio delle azioni correttive derivanti dalle attività IA, la presente procedura metodologica ha la finalità di disciplinare le modalità operative di svolgimento delle attività dell'Internal Audit, in particolare:

- la gestione delle risorse;
- la definizione del Piano di Audit;
- la gestione degli interventi di audit;
- il monitoraggio delle azioni correttive;
- le attività di supporto specialistico (in materia di SCIGR);
- i flussi informativi (*Reporting*) con gli *stakeholder*;
- i rapporti con gli Organi di controllo e vigilanza;
- le attività di Quality Assurance;
- la gestione e archiviazione della documentazione.



La presente procedura metodologica (di seguito Manuale IA o solo Manuale) si applica a tutte le **funzioni internal auditing (funzioni IA)** del Gruppo FS Italiane.

Le attività di definizione e aggiornamento del Manuale rientrano nel ruolo di indirizzo, coordinamento e controllo attuativo, da un punto di vista metodologico, svolto dalla **funzione internal audit di FS SpA**.

² Gli Standard internazionali dell'Internal Audit hanno lo scopo di: 1. Promuovere l'aderenza agli elementi vincolanti dell'*International Professional Practices Framework*; 2. Fornire un quadro di riferimento per lo svolgimento e lo sviluppo di una vasta gamma di servizi di internal audit a valore aggiunto; 3. Definire i parametri per la valutazione della prestazione dell'internal audit; 4. Promuovere il miglioramento dei processi e delle attività dell'organizzazione.

³ La cui adozione è deliberata dal CdA di FS e dai CdA delle Capogruppo di Settore e delle altre Società controllate di cui all'elenco in allegato 1 al Regolamento di Gruppo. I CdA delle Società del Polo deliberano l'adozione dell'*Audit Charter* a valle dell'atto di recepimento della rispettiva Capogruppo di settore.

Il Responsabile della **funzione metodologie IA** della **funzione internal audit** di FS SpA è responsabile dell'aggiornamento del presente Manuale e dei relativi allegati⁴ al fine di assicurarne l'adeguatezza nel tempo.

A tal fine, le **funzioni IA del Gruppo FS Italiane** sono tenute a segnalare gli accadimenti aziendali di carattere operativo e strutturale che comportano la necessità di aggiornamento del presente Manuale e dei relativi allegati. Tali rilevazioni sono segnalate alla suddetta funzione che assicura il coordinamento delle attività di aggiornamento del documento.

Il presente documento è aggiornato su base almeno triennale, ovvero in occasione di eventi di natura interna e/o esterna al Gruppo FS Italiane, la cui rilevanza sul contenuto del documento stesso è considerata significativa (ad es. riorganizzazioni aziendali, operazioni di natura straordinaria, strutturali, modifiche agli Standard internazionali per la pratica professionale che incidono significativamente sulle modalità operative dello svolgimento dell'attività di internal audit).

2 DEFINIZIONI E ABBREVIAZIONI

Acronimo / Terminologia	Significato
ABC system	<i>Anti-Bribery & Corruption management system.</i>
AD	Amministratore Delegato.
Audit Charter	Modello di Governance Internal Audit.
Audit Manager	Primo riporto del RIA, responsabile di assicurare lo svolgimento degli interventi di audit/ <i>follow-up</i> di competenza, indirizzando, coordinando e supervisionando le attività dei Team di audit assegnati.
Holding	Ferrovie dello Stato Italiane SpA o FS SpA.
CCR	Comitato Controllo e Rischi (ove esistente) inteso come comitato endoconsiliare con compiti di supporto al CdA in materia di sistema di controllo interno e gestione dei rischi.
CdA	Consiglio di Amministrazione.
CS	Collegio Sindacale.
DP	Dirigente Preposto.
Funzione IA	Funzione internal audit di società.

⁴ L'allegato 1 "Linee guida per l'utilizzo degli standard operativi" e l'allegato 2 "Key Performance Indicator (KPI) della funzione IA" costituiscono parte integrante del presente documento e, in caso di successive modifiche organizzative e/o normative e/o per esigenze operative, saranno conseguentemente aggiornati e resi disponibili sulla intranet aziendale, nella sezione contenente i documenti organizzativi, da parte della **funzione organizzazione** di FS SpA su indicazione della funzione IA di FS SpA, senza necessità di rimettere il presente documento.

Acronimo / Terminologia	Significato
IA	Internal Audit.
Lead Auditor	Ruolo ricoperto dalla funzione IA di FS SpA nella conduzione di “Joint Audit” attivati con una o più funzioni IA societarie.
Modello 231	Modello di organizzazione e di gestione ai sensi del D.lgs. n.231/2001.
OdV	Organismo di Vigilanza, istituito ai sensi del D.lgs. n. 231/2001.
Organi di controllo e vigilanza	Collegio Sindacale, Comitato Controllo e Rischi, Organismo di Vigilanza.
Owner (dell’azione correttiva)	Responsabile di struttura organizzativa macro che dispone delle competenze, esperienze e leve gestionali per la completa realizzazione dell’azione correttiva, avvalendosi, ove necessario, anche del supporto di altre funzioni aziendali. Per le Società più piccole l’ <i>Owner</i> può anche essere figura non dirigenziale, Responsabile di struttura micro. Possono essere individuati come <i>Owner</i> anche ruoli aziendali che <i>ex lege</i> dispongono di autonomia decisionale e/o di spesa (ad es. Responsabile dei Lavori ex D. lgs. 81/2008 e s.m.i.).
Responsabile apicale di struttura	Per gli interventi di audit svolti dalla funzione IA di FS SpA, coincide con il primo riporto dell’AD di FS SpA o con l’AD di Società controllata. Per gli interventi di audit svolti dalla funzione IA di Società controllata coincide con il Responsabile di direzione/struttura di primo riporto dell’AD della Società o con l’AD di eventuali Società controllate da quest’ultima.
Responsabile dell’intervento di audit o Responsabile dell’audit	Audit Manager oppure, per le funzioni IA di minori dimensioni, il Responsabile della funzione internal audit (RIA).
RIA	Responsabile della funzione internal audit.
SCIGR	Sistema di Controllo Interno e Gestione dei Rischi.
Struttura auditata	Struttura oggetto dell’intervento di audit.
Team di audit o Team	<i>Team</i> composto da uno o più auditor.



Acronimo / Terminologia	Significato
<i>Team Leader</i>	Auditor del <i>Team</i> di audit avente anche il ruolo di coordinatore operativo del <i>Team</i> stesso.

3 SINTESI DEI PRINCIPALI CONTENUTI DEL MANUALE DI INTERNAL AUDIT

Si riporta di seguito un quadro di sintesi dei principali contenuti descritti nel presente Manuale, con indicazione

Argomento	Sintesi principali contenuti	Rif. Paragrafo
Gestione delle risorse	Il Responsabile internal audit di FS SpA, in qualità di <i>Process Owner</i> di Gruppo, assicura, in coerenza con il Modello di Governance del Gruppo FS Italiane, il presidio centralizzato della Famiglia Professionale IA attraverso leve di gestione unitaria e l'individuazione ed implementazione di modalità di integrazione; come definite dalla Policy "Strumenti Gestionali delle Famiglie Professionali".	§ 4 (pag. 18)
	Le risorse della funzione IA possono essere gestite in logica di pool oppure assegnate alle singole strutture organizzative della Funzione stessa.	§ 4.1 (pag. 18)
	Ciascuna funzione IA in coordinamento con la funzione in ambito risorse umane e organizzazione: • identifica i profili e le competenze necessarie, con particolare riferimento a: i) <i>know how</i> necessario all'efficace svolgimento delle attività di competenza; ii) fabbisogni quali/quantitativi nei diversi ruoli e livelli di <i>seniority</i>; • elabora il piano formativo annuale delle proprie risorse; • definisce il budget delle risorse.	§ 4.2 (pag. 19) § 4.3 (pag. 19) § 4.4 (pag. 20)
	Ciascuna funzione IA verifica l'assenza di conflitti d'interesse da parte delle proprie risorse (incluso il RIA) attraverso la sottoscrizione di un'apposita dichiarazione.	§ 4.5 (pag. 21)
Pianificazione interventi di Audit	Il Piano di Audit è elaborato almeno annualmente sulla base di una metodologia c.d. " top down - risk based ". Il processo di pianificazione si compone almeno delle seguenti fasi: • definizione dell'universo degli Oggetti di Audit (OA); • determinazione dell'indice di rischio per ciascun OA;	§ 5.1 (pag. 23) § 5.2 (pag. 24) § 5.3 (pag. 25)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
	elaborazione della proposta di Piano di Audit, sulla base dell'indice di rischio degli OA e tenendo anche conto di: <i>i)</i> eventuali indicazioni del Vertice e/o degli Organi di controllo e vigilanza e/o del <i>Top Management</i>; <i>ii)</i> equilibrio generale degli interventi tra le diverse funzioni/strutture interessate; <i>iii)</i> valutazioni professionali dell'Internal Audit; <i>iv)</i> interventi già svolti nell'ultimo biennio/triennio.	
	Il Piano di Audit prevede anche interventi di follow-up “sul campo” , pianificati per gli audit con <i>Rating</i> SCIGR “Non soddisfacente” o “Necessari miglioramenti significativi”.	§ 5.4 (pag. 26)
	Prima dell'approvazione, il RIA societario illustra la proposta di Piano di Audit alla struttura competente della pianificazione della funzione internal audit di FS SpA al fine di condividere: <i>i)</i> le metodologie utilizzate, <i>ii)</i> eventuali sinergie operative e possibili interventi congiunti, <i>iii)</i> allineamento su tematiche trasversali. La proposta di Piano di Audit, elaborata dal Responsabile della funzione internal audit della Società, è approvata – almeno annualmente - dal CdA, previo parere del Comitato Controllo e Rischi di Società (ove istituito) e sentiti il Presidente della Società, l'Amministratore Delegato della Società e il Collegio Sindacale della Società (CS). La proposta di Piano di Vigilanza ex D.lgs. 231/01 della Società (ove previsto) si compone dei soli interventi di rilievo 231 ed è parte integrante del Piano di Audit ed è approvata dall'Organismo di Vigilanza della Società.	§ 5.5 (pag. 27)
Programmazione operativa	La programmazione operativa , elaborata a inizio d'anno e aggiornata periodicamente, prevede che a ciascuna attività della funzione IA, con particolare riferimento agli interventi di audit/ <i>follow-up</i> “sul campo”, siano associati: <i>i)</i> i Responsabili e le risorse disponibili; <i>ii)</i> lo <i>scheduling</i> ; <i>iii)</i> le principali date <i>milestone</i> ; <i>iv)</i> l'eventuale impiego di <i>outsourcer</i> .	§ 6 (pag. 28)
	Il RIA comunica al Responsabile apicale della struttura / Società interessata l' avvio dell'intervento di audit, dandone contestuale informativa al Presidente del CdA e all'AD.	§ 7.1 (pag. 30)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
Gestione degli interventi di audit	A supporto dell'attività preliminare sono svolte le seguenti attività: <i>i)</i> definire natura e obiettivi specifici dell'intervento; <i>ii)</i> eseguire una valutazione preliminare dei rischi; <i>iii)</i> individuare le aspettative degli <i>stakeholders</i>; <i>iv)</i> individuare opportunità di miglioramento del SCIGR; <i>v)</i> definire le informazioni preliminari sulla composizione del <i>Team</i>. Tali esiti sono formalizzati nella relazione di pianificazione, elaborata nel periodo intercorrente tra l'avvio del singolo intervento e la redazione del Programma di Lavoro, recependo – tra l'altro - eventuali osservazioni e informazioni pervenute dagli <i>stakeholder</i> dell'IA, ulteriori a quelle recepite in sede di pianificazione annuale. L'attività preliminare ha, quindi, lo scopo di: <i>i)</i> definire obiettivi specifici dell'intervento; <i>ii)</i> individuare gli ambiti che saranno oggetto dell'audit, valutandone la significatività, i potenziali rischi e le possibili aree critiche; <i>iii)</i> focalizzare il Programma di Lavoro dell'audit, contenente: • raccolta e analisi della documentazione/informazioni necessarie e incontro preliminare con la struttura auditata; • definizione del piano dei test; • budget delle risorse e tempistiche di realizzazione dell'intervento.	§ 7.2 (pag. 30)
	Sulla base del Programma di Lavoro definito, il <i>Team</i> di audit procede alla selezione del campione, quando necessario, ed esegue le verifiche ivi previste (c.d. attività esecutiva) con l'obiettivo di valutare l'adeguatezza e l'efficacia dei controlli a presidio dei rischi rientranti nell'oggetto di audit. Sulla base delle differenze emerse tra la situazione attesa e la situazione in essere, così come emersa dalle attività di verifica, il <i>Team</i> identifica i possibili rilievi e le correlate raccomandazioni di rafforzamento del SCIGR⁵.	§ 7.3 (pag. 37)
	L'intervento di audit si conclude con la fase di formalizzazione e reporting dei risultati, che si compone delle seguenti attività:	§ 7.4 (pag. 43)

⁵ Sistema di Controllo Interno e Gestione dei Rischi.

Argomento	Sintesi principali contenuti	Rif. Paragrafo
	• valutazione di sintesi (Rating) sullo stato del disegno e dell'operatività del SCIGR dell'oggetto di audit e dei singoli rilievi emersi; • discussione con il Management dei rilievi emersi, delle raccomandazioni proposte per la loro rimozione e delle azioni correttive da implementare; • supporto al <i>Management</i> per la definizione del Piano di Azione, contenente le azioni correttive idonee a risolvere i rilievi riscontrati, le relative tempistiche e gli <i>Owner</i> (responsabili della loro attuazione); • predisposizione e trasmissione del Rapporto di audit.	
	Successivamente alla trasmissione del Rapporto di audit alle strutture auditate, la funzione IA monitora l'implementazione dei suddetti Piani di Azione, mediante Follow-up "documentale" e, ove previsto, Follow-up "sul campo". In particolare, quest'ultimo consiste in una verifica operativa e non solo documentale dell'attuazione delle relative azioni correttive da parte della funzione IA e, di norma, è attivato successivamente al completamento di tutto o di gran parte del Piano di Azione così come emerso dalle attività di <i>Follow-up</i> "documentale".	§ 7.5 (pag. 49)
	Al fine di implementare e adottare sistematicamente metodologie e strumenti innovativi, la funzione IA può identificare uno o più interventi di audit su cui adottare la metodologia "agile", con l'obiettivo di estenderne l'ampiezza di applicazione nel medio termine. Tale approccio consente al <i>Team</i> di Audit di: <i>i)</i> rivisitare le modalità operative, garantendo attività e verifiche a valore anche in scenari in cambiamento; <i>ii)</i> essere reattivi sulle priorità di rischi che cambiano in contesti in continua evoluzione; <i>iii)</i> essere sempre più propositivi e proattivi nell'agire in coerenza con la strategia, gli obiettivi e i rischi dell'organizzazione e di tenere in considerazione gli impatti futuri; <i>iv)</i> supportare le attività con una maggiore tempestività della condivisione dei rilievi e dell'avvio delle relative azioni correttive.	§ 7.6 (pag. 49)
	In presenza di specifiche circostanze, concordate dai RIA interessati, sarà possibile effettuare i c.d. Joint Audit, cioè interventi di audit che	§ 7.7 (pag. 53)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
	vedono il coinvolgimento della funzione IA di FS SpA – con il ruolo di <i>Lead Auditor</i> - con una o più funzioni IA .	
	La funzione IA può svolgere interventi che, in virtù della loro natura, possono comportare l'adozione di specifiche modalità di esecuzione delle attività .	§ 7.8 (pag. 54) § 7.9 (pag. 55)
Continuous auditing	Il <i>continuous auditing</i> si basa sul monitoraggio continuativo di un set strutturato di indicatori (KRI) che individuano la “dimensione” di uno scenario di rischio/possibili anomalie. A seguito dell'analisi dei KRI estratti, la funzione IA approfondisce gli eventuali red flag (anomalie) emersi attraverso due modalità operative: 1) verifiche specifiche sui KRI con valori e/o trend “anomali”; 2) verifiche ricondotte nell'ambito di interventi di audit (pianificati e spot) sui processi/attività/transazioni oggetto di <i>continuous auditing</i>.	§ 8 (pag. 57)
Combined assurance: verifiche integrate audit e testing 262	L'integrazione delle attività di testing 262 nell'ambito degli interventi di audit e di <i>follow-up</i> abilita i seguenti obiettivi: <i>i)</i> efficienza operativa (es. minor impatto sulle strutture aziendali oggetto di verifica, ottimizzazione dei Programmi di lavoro); <i>ii)</i> reportistica integrata; <i>iii)</i> monitoraggio coordinato (con le strutture del Dirigente Preposto) dei piani di azione. L'integrazione può avvenire attraverso due modalità differenti: 1) Test 262 rientranti nel perimetro/scope dell'intervento di audit/follow-up; in questo caso si ottiene la piena integrazione delle verifiche di audit e 262, cogliendo tutti gli obiettivi citati. Inoltre, i <i>test</i> 262 effettuati in logica integrata concorrono al giudizio (<i>rating</i>) espresso dall'IA sul SCIGR del processo esaminato; 2) Test 262 NON rientranti nel perimetro/scope dell'intervento di audit/follow-up; eventuali altri controlli 262 da testare durante l'intervento di audit/<i>follow-up</i>, sono svolti in ottica di efficienza con	§ 9 (pag. 60)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
	metodologia “ <i>agreed upon procedures</i> ” ma i relativi esiti non concorrono al giudizio (<i>rating</i>) espresso dall’IA sul SCIGR del processo esaminato.	
Altre Attività di Supporto Specialistico	La funzione IA può svolgere ulteriori attività di supporto specialistico in materia di SCIGR quali: • attività di monitoraggio indipendente previste dal sistema di controllo sull’informativa finanziaria e/o analoghi incarichi con riferimento ad altri modelli di controllo societari che li prevedano; • istruttorie sulle segnalazioni trasmesse alla funzione IA dagli Organi/Comitati che ne presidiano il processo di ricezione, analisi e trattamento; • attività di consulenza volte a fornire supporto specialistico al vertice aziendale e al <i>Management</i> nella creazione di valore aggiunto e nel miglioramento dei processi di <i>governance</i> e del SCIGR aziendale.	§ 10 (pag. 65)
Flussi Informativi (Reporting) con gli Stakeholder	La funzione IA redige relazioni periodiche aventi l’obiettivo di fornire informazioni sulla propria attività nonché sugli esiti e i correlati suggerimenti che ne derivano e sui relativi piani di azione. Le relazioni sono riconducibili principalmente alle seguenti tipologie: • relazione periodica sui principali risultati delle attività svolte dalla funzione IA; • report sullo stato di attuazione delle azioni correttive; • report specifici per il <i>Management/Process Owner</i>.	§ 11 (pag. 67)
Rapporti con gli Organi di controllo e vigilanza e il Comitato Etico	La funzione IA , al fine di adempiere alle responsabilità attribuitele in materia di SCIGR, assicura un costante rapporto con tutti gli Organi di controllo e di vigilanza societari, nonché con il Comitato Etico e la gestione dei correlati flussi informativi.	§ 12 (pag. 70)
	Nell’ambito dei rapporti con l’OdV e con il Comitato Etico , la funzione IA – qualora svolga attività di supporto secondo quanto previsto dallo Statuto OdV, dal Modello 231 e dal Regolamento del Comitato - assicura le funzioni di segreteria degli Organismi. Il RIA , inoltre, può essere componente interno dell’Organismo di Vigilanza e, di norma, del Comitato Etico.	§ 12.1 (pag. 71)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
	La funzione IA gestisce i flussi informativi nei confronti del CCR (ove istituito) e del CS al fine della tempestiva messa a disposizione delle informazioni rilevanti per l'espletamento dei rispettivi compiti e del coordinamento delle attività nelle aree di comune competenza.	§ 12.2 (pag. 72)
Quality Assurance e miglioramento continuo	Il programma di <i>Quality Assurance</i> costituisce un processo strutturato di revisione delle attività svolte dalla funzione IA, in conformità agli Standard internazionali per la pratica professionale, e include valutazioni interne (<i>Internal Quality Review-IQR</i>) ed esterne (<i>External Quality Review-EQR</i>). Le <i>IQR</i> sono svolte di norma mediante l'attivazione di un Gruppo di Lavoro composto da risorse interne a ciascuna funzione IA o composto da risorse di diverse funzioni IA, appositamente definito e coordinato dalla struttura responsabile delle metodologie della funzione IA di FS. Le <i>EQR</i> sono effettuate da un "valutatore" qualificato e indipendente, esterno all'organizzazione, individuato tramite gara. Il RIA comunica al proprio Vertice e agli Organi di controllo e vigilanza l'ambito e gli esiti delle <i>IQR</i> e <i>EQR</i> svolte, comprensivi dell'eventuale piano delle iniziative di miglioramento e dell'aggiornamento periodico del relativo stato di attuazione.	§ 13 (pag. 72)
Gestione e archiviazione della documentazione	Tutti i dati, le informazioni e la documentazione acquisita e prodotta dalla funzione IA, durante lo svolgimento e a conclusione delle attività, costituisce "informazione" aziendale riservata, di cui va garantita e tutelata la confidenzialità (anche ai sensi del GDPR). Al riguardo, tutti i documenti gestiti devono essere classificati ai sensi della normativa interna in materia. La gestione e l'archiviazione deve essere tale da consentire che i dati, le informazioni e i documenti analizzati e prodotti supportino le conclusioni e i risultati del lavoro svolto e consentano la ricostruzione e la ripercorribilità di questi ultimi. È opportuno privilegiare l'archiviazione della documentazione in formato elettronico.	§ 14 (pag. 76)

Argomento	Sintesi principali contenuti	Rif. Paragrafo
Tempi di conservazione	I documenti prodotti dalla funzione IA sono conservati per 10 anni, salvo casistiche specifiche.	§ 15 (pag. 80)
Sistemi informativi a supporto	La gestione informatizzata delle attività operative: <i>i)</i> garantisce una maggiore protezione delle informazioni/documenti, <i>ii)</i> prevede la preventiva autorizzazione dell'utente (profilazione) all'accesso a tali informazioni/documenti, <i>iii)</i> consente di ottimizzare la gestione della documentazione pertinente, evitando di archiviare lo stesso documento / informazione su sistemi differenti. A tal proposito, si raccomanda la progressiva digitalizzazione delle attività attraverso l'utilizzo dei sistemi informativi disponibili nell'ambito del Gruppo FS Italiane.	§ 16 (pag. 80)

4 GESTIONE DELLE RISORSE

Il **Responsabile internal audit di FS SpA**, in qualità di *Process Owner* di Gruppo, assicura, in coerenza con il Modello di *Governance* del Gruppo FS Italiane, il presidio centralizzato della Famiglia Professionale IA attraverso leve di gestione unitaria e l'individuazione ed implementazione di modalità di integrazione; come definite dalla *Policy* “Strumenti Gestionali delle Famiglie Professionali”.

L'*Audit Charter* stabilisce che la **funzione IA**, a garanzia del suo buon funzionamento:

- utilizzi metodologie di organizzazione, pianificazione, svolgimento e formalizzazione delle attività in conformità agli standard internazionali professionali;
- disponga di professionalità e skill adeguati a far fronte alle attività, ivi comprese quelle di natura specialistica, previa valutazione della loro indipendenza, professionalità ed esperienza;
- preveda il continuo aggiornamento professionale per conseguire il più efficace utilizzo delle risorse; il fabbisogno formativo è parte integrante del budget della **funzione IA**; il fabbisogno formativo professionale specialistico del personale sarà soddisfatto in raccordo con il Piano Formativo Internal Audit, definito dalla **funzione internal audit di FS SpA**, in collaborazione con la **funzione formazione**, sulla base del fabbisogno comunicato dalle **funzioni IA societarie**;
- disponga di una organizzazione interna adeguata all'evoluzione delle attività di competenza e in base alle migliori prassi professionali, con particolare riferimento, tra l'altro, alla costituzione – ove opportuno - di unità professionali specialistiche, in accordo con la **funzione internal audit di FS SpA**;
- abbia accesso a tutte le informazioni, ai dati, sia documentali sia informatici (ivi inclusi quelli eventualmente classificati come “confidenziali” / “strettamente confidenziali”), agli archivi e ai beni della Società e delle Società controllate nell'ambito degli accertamenti, analisi e delle valutazioni svolte;
- ottenga l'assistenza necessaria dai Vertici aziendali e dal personale aziendale direttivo e subordinato delle unità sottoposte a verifiche⁶.

4.1 Assegnazione risorse

Le risorse della **funzione IA** possono essere gestite in logica di “*pool*” oppure assegnate alle singole strutture organizzative della funzione stessa.

La gestione in pool prevede che la struttura competente della **funzione IA** per la gestione delle risorse definisca, in coordinamento con gli altri Responsabili della **funzione IA**, l'assegnazione delle risorse a ciascuna attività della funzione stessa.

⁶ Per ulteriori dettagli si rimanda all'*Audit Charter* “Garanzie per il buon funzionamento dell'Internal Audit”.

Nel caso di gestione che prevede la stabile assegnazione delle risorse alle diverse strutture della **funzione IA**, il Responsabile di ciascuna struttura definisce l'assegnazione delle risorse alle attività di competenza, aggiornando periodicamente la competente struttura della funzione IA (ove istituita) / il referente della pianificazione annuale.

In entrambe le modalità operative di gestione delle risorse, è necessario valorizzare le competenze delle persone, stimolare la flessibilità nello svolgimento di diverse attività e favorire l'attuazione di criteri di *job rotation* interni alla funzione/Famiglia Professionale IA e di *learning on the job*.

I responsabili con cui hanno lavorato le risorse, in coerenza con le politiche, i modelli e gli strumenti definiti dalla funzione risorse umane e ai fini della successiva condivisione con il **Responsabile Internal Audit (RIA)**:

- definiscono gli obiettivi annuali che la risorsa deve perseguire⁷;
- valutano le performance della risorsa;
- propongono gli eventuali passaggi di categoria e gli interventi di politica retributiva;
- definiscono il piano di formazione, al fine di assicurare azioni di sviluppo delle professionalità coerenti con gli obiettivi della funzione IA.

4.2 Identificazione profili e competenze nella funzione Internal Audit

Al fine di dotarsi di risorse in possesso di approfondite e specifiche competenze professionali e di conoscenze trasversali ai differenti business aziendali, ciascuna **funzione IA**, ove possibile e in coordinamento con la funzione risorse umane:

- identifica il *know how* necessario all'efficace svolgimento delle attività di competenza, in attuazione delle strategie aziendali;
- definisce i fabbisogni quali/quantitativi delle persone nei diversi ruoli e livelli di *seniority*;
- ottimizza la leva formativa e alimenta i sistemi di *knowledge management* (ove disponibili).

4.3 Formazione delle risorse

Annualmente ciascuna **funzione IA**⁸ elabora, in coordinamento con la funzione risorse umane, il fabbisogno formativo delle proprie risorse, coerentemente con la quota di *budget* formazione resa disponibile dalla funzione risorse umane, al fine di assicurare azioni di sviluppo delle competenze/professionalità, coerenti con gli obiettivi della stessa **funzione IA**.

Il fabbisogno formativo è approvato dal **RIA** e successivamente trasmesso alla **funzione formazione**.

⁷ Con riferimento alle risorse individuate sulla base delle regole definite dalla funzione risorse umane.

⁸ Eventualmente per il tramite di una specifica struttura responsabile della gestione del *pool* di risorse, ove presente.

La formazione si suddivide principalmente in tre tipologie:

- formazione aziendale istituzionale;
- formazione volta allo sviluppo delle competenze manageriali e comportamentali;
- formazione professionale specialistica⁹.

Il fabbisogno formativo professionale specialistico è comunicato alla **funzione internal audit di FS SpA** che, in collaborazione con la **funzione formazione**, definisce annualmente il Piano Formativo Internal Audit. I fabbisogni non rientranti nel Piano Formativo di Famiglia Professionale potranno essere soddisfatti in ambito societario.

Nel corso dell'anno, ciascuna **funzione IA** monitora¹⁰ periodicamente la partecipazione ai corsi di formazione previsti nel piano formativo, congiuntamente con la competente struttura della **funzione formazione**.

Per le nuove risorse in ingresso nella funzione IA, in aggiunta a quanto già previsto in termini di formazione aziendale “standard”, è inoltre previsto un periodo di *training on the job* in affiancamento a risorse di elevata *seniority*, al fine di acquisire le tecniche e le metodologie di audit in uso.

Con riferimento alla formazione caratterizzante la figura dell'internal auditor, le funzioni IA promuovono¹¹:

- iniziative¹² di formazione e comunicazione interne a ciascuna funzione IA e/o alla famiglia professionale Internal Audit di Gruppo;
- il conseguimento e il mantenimento, da parte delle proprie risorse, di certificazioni professionali¹³, che contribuiscono a rafforzare il livello qualitativo delle risorse richiesto per l'esercizio della professione.

4.4 Budget del personale della funzione IA

L'attività di definizione del *budget* del personale della **funzione IA** viene svolta annualmente in coordinamento con la funzione risorse umane, di norma nel quarto trimestre dell'anno precedente a quello di riferimento, e prevede l'analisi dei seguenti principali fattori:

- numero di risorse disponibili nella **funzione IA**;

⁹ Anche per l'abilitazione e il mantenimento di certificazioni professionali, sia quelle in materia di internal auditing (ad esempio CIA-Certified Internal Auditor, CCSA-Certified in Control Self-Assessment, CFE-Certified Fraud Examiner, CFSA-Certified Financial Services Auditor, CRMA-Certified in Risk Management Assurance), sia quelle in altre discipline (es. Qualità, HSE, albo dei dottori commercialisti e dei revisori).

¹⁰ Con riferimento alle risorse individuate sulla base delle regole definite dalla funzione risorse umane.

¹¹ Compatibilmente con le politiche definite dalla funzione risorse umane e con il *budget* disponibile.

¹² Quali ad esempio: *convention*, *workshop* su specifiche tematiche in materia di SCIGR, condivisione periodica delle *lesson learnt*.

¹³ Sia quelle in materia di internal auditing (ad esempio CIA-Certified Internal Auditor, CCSA-Certified in Control Self-Assessment, CFE-Certified Fraud Examiner, CFSA-Certified Financial Services Auditor, CRMA-Certified in Risk Management Assurance), sia quelle in altre discipline (es. Qualità, HSE, albo dei dottori commercialisti e dei revisori).

- Piano di Internal Audit¹⁴, ivi inclusa una stima di potenziali interventi spot e attività svolte in *service* a favore di società controllate;
- altre attività operative previste nell'anno di riferimento (ad es. attività di monitoraggio indipendente "262", attività di *continuous auditing*, attività afferenti alla gestione delle segnalazioni, attività progettuali, etc.);
- attività di staff (metodologie, *quality assurance*, *reporting*, *knowledge management*, gestione dei Rapporti con gli Organi di controllo e vigilanza, gestione delle risorse, gestione dei sistemi informativi, monitoraggio *budget* costi esterni e adempimenti di funzione/direzione, etc.);
- attività di formazione delle risorse;
- *trend* storici delle attività operative;
- alcuni indicatori di *performance*, quali ad esempio la durata (in giorni di calendario) e l'*effort* (in ore/giorni uomo) medi degli interventi di audit e di *Follow-up*, il tempo medio per lo svolgimento dei controlli nell'ambito del monitoraggio indipendente "262", il numero di segnalazioni pervenute, etc.;
- l'eventuale ricorso a risorse esterne (per esempio per far fronte a eventuali picchi di attività e/o per conflitti di interesse e/o per particolari competenze di natura tecnica).

La proposta di *budget* delle risorse è elaborata dal RIA, con l'eventuale supporto degli altri Responsabili della funzione IA e/o della specifica struttura competente per la pianificazione ed è sottoposta al processo di approvazione descritto nel paragrafo 5.5 congiuntamente al Piano di Audit.

4.5 Conflitto di interesse e riservatezza

Sussiste conflitto di interessi ogniqualvolta un soggetto, in occasione o a causa dell'espletamento di una specifica funzione, si venga a trovare in una situazione in cui un interesse secondario, anche per conto di terzi, interferisce con la sua capacità di agire in conformità ai suoi doveri e responsabilità che sintetizzano l'interesse primario della società. A titolo esemplificativo e non esaustivo, genera conflitto di interessi la presenza di relazioni familiari o personali con soggetti che abbiano avuto, durante le specifiche attività di audit e/o negli anni coperti dalle relative analisi, responsabilità operative nell'ambito dei processi/attività esaminati.

Con riferimento a quanto previsto dagli Standard internazionali per la pratica professionale¹⁵ e dal Codice Etico di Gruppo, ciascuna funzione IA verifica l'assenza di conflitti d'interesse da parte delle risorse appartenenti alla

¹⁴ Ove già disponibile.

¹⁵ Lo standard 1100 – Indipendenza e obiettività.

funzione, e in corso d'anno per tutti i nuovi ingressi, attraverso un'apposita dichiarazione¹⁶ sottoscritta da tutto il personale della **funzione IA** coinvolto nelle attività operative. In particolare, nella citata dichiarazione ciascuna risorsa:

- si impegna a segnalare tempestivamente al **RIA**¹⁷ eventuali situazioni di conflitto d'interesse che si dovessero manifestare prima dell'inizio delle singole attività in cui è previsto il suo coinvolgimento e, in ogni caso, appena ne venisse a conoscenza, per le conseguenti valutazioni di opportunità di svolgimento delle attività a cui la risorsa è assegnata;
- attesta che, nell'ambito delle attività di audit svolte, organizzate, dirette o supervisionate nel corso dell'anno, non si sono verificate situazioni di conflitto d'interesse.

Tutte le notizie/informazioni/documenti acquisite dalle persone a vario titolo coinvolte da attività della **funzione IA** dovranno essere mantenute strettamente confidenziali e riservate, protette contro il furto, accessi abusivi o divulgazione non autorizzata, nel rispetto delle normative di legge e aziendali in materia, al fine di impedire a soggetti terzi non autorizzati di venirne a conoscenza. In particolare, non potranno essere cedute, registrate, pubblicate o rivelate in qualunque modo a qualsiasi persona o entità, con qualsiasi mezzo (anche attraverso fotocopia o riproduzione), senza il preventivo consenso scritto del Vertice aziendale e dovranno essere utilizzate unicamente ai fini dell'esercizio delle attività di competenza¹⁸.

5 LA PIANIFICAZIONE DEGLI INTERVENTI DI AUDIT

Il Piano di Internal Audit (in seguito Piano di Audit) è elaborato almeno annualmente, in coerenza con le *best practice* internazionali e gli standard professionali, sulla base di una metodologia c.d. “*top down - risk based*”, finalizzata a determinare le priorità di intervento in linea con gli obiettivi strategici aziendali e perseguire obiettivi di “*risk coverage*”, basati cioè su criteri di rilevanza e di copertura dei principali rischi aziendali, per la società e per le eventuali società controllate.

Il processo di predisposizione del Piano di Audit è articolato almeno nelle seguenti fasi:

- definizione dell'universo degli Oggetti di Audit (OA);
- determinazione dell'indice di rischio per ciascun OA;

¹⁶ Sulla base dello standard operativo “*ST Conflitto di interessi Internal Auditor*” (incluso il RIA sulla base dello standard operativo “*ST Dichiarazione Conflitto di Interessi Resp_LA*”). Gli standard operativi richiamati nel presente Manuale sono predisposti dalla competente funzione di internal audit di FS SpA, in coordinamento con le altre funzioni IA. Per l'utilizzo degli standard si rimanda all'Allegato 1 “Linee guida per l'utilizzo degli standard operativi”.

¹⁷ Nel caso di conflitto di interessi del **RIA**, quest'ultimo s'impegna ad attivare tempestivamente opportune iniziative gestionali (ad es. affidamento dell'intervento di audit in *outsourcing* con “responsabilità in capo all'Appaltatore”). Inoltre, il **Responsabile internal audit di FS SpA** è coinvolto nella valutazione e definizione di eventuali situazioni di conflitto di interessi di **Responsabili della funzione internal audit delle controllate**. I summenzionati casi sono oggetto di informativa al Presidente.

¹⁸ Fatte salve le richieste da parte dell'Autorità Giudiziaria.

- elaborazione della proposta del Piano di Audit, ivi inclusi gli interventi di *follow-up* “sul campo”.

Il perimetro di riferimento di ciascuna **funzione IA** per la definizione del Piano di Audit deriva dall’ambito operativo di quest’ultima descritto nell’*Audit Charter*.

I principi e gli obiettivi contenuti nel presente capitolo troveranno opportuna e adeguata declinazione operativa in ciascuna **funzione IA**, che li armonizzerà con le proprie specificità organizzative (soprattutto per le **funzioni IA** di minori dimensioni¹⁹) e/o societarie e in funzione delle informazioni disponibili (di seguito descritte), condividendole con la **funzione internal audit di FS SpA**.

5.1 Definizione dell’Universo degli Oggetti di Audit

L’Oggetto di Audit (OA) è una parte della complessità organizzativa aziendale che, per dimensioni e caratteristiche, si presta a divenire oggetto di un intervento di verifica da parte dell’Internal Audit. Un OA può essere quindi rappresentato, per esempio, da: *i)* processi/sottoprocessi/attività, *ii)* specifici progetti, *iii)* singole strutture organizzative, *iv)* società, *v)* specifici argomenti/tematiche/rischi, *vi)* sistemi informativi.

Ciascuna **funzione IA**, sulla base dell’ambito operativo di competenza, definisce il c.d. universo degli OA.

Il processo di individuazione degli OA è principalmente basato sulle seguenti attività:

- analisi del modello di business e mappa dei processi (di società e/o di Gruppo, ove disponibile);
- analisi del quadro normativo e dell’assetto organizzativo societario;
- acquisizione e analisi di informazioni quantitative e qualitative relative ai processi/sottoprocessi/strutture organizzative, necessarie a valutarne la complessità operativa e organizzativa, quali, a titolo esemplificativo e non esaustivo: *i)* nr. risorse coinvolte, *ii)* nr. strutture coinvolte nel processo, *iii)* nr. di eventi gestiti dal processo, *iv)* grandezze/KPI economico finanziari, *v)* distribuzione sul territorio, *vi)* sistemi informativi a supporto;
- individuazione degli OA sulla base della complessità organizzativa e operativa dei processi/sottoprocessi/strutture organizzative/.. oggetto di analisi. In particolare, in caso di:
 - elevata complessità organizzativa e/o operativa si procede, di norma, all’individuazione di uno o più OA, al fine di consentire adeguati livelli di approfondimento nelle verifiche;
 - bassa complessità sia organizzativa che operativa si procede, di norma, con l’individuazione di un unico OA.

Le suddette valutazioni considerano inoltre i seguenti aspetti, ove disponibili:

¹⁹ E di norma prive di un’articolazione organizzativa in diverse strutture.

- rilevanza strategica del processo/sottoprocesso/struttura/.... analizzato;
- esiti delle attività di *risk assessment* svolte dalla competente funzione aziendale;
- valutazioni/analisi svolte da altri *assurance provider* aziendali;
- rilevanza del processo/sottoprocesso/struttura/.... ai sensi di modelli di controllo societari (ad es. Modello 231, *ABC system* e *Policy* Anticorruzione, “Modello 262”);
- eventuali indicazioni degli Organi di controllo e vigilanza, del Vertice e del *Top Management* societari;
- analisi delle segnalazioni e di specifiche tematiche di *compliance* e *governance*.

L'universo degli OA è oggetto di revisione e aggiornamento periodico, in considerazione di eventuali evoluzioni/cambiamenti intervenuti, con particolare riferimento a:

- evoluzione delle strategie societarie;
- evoluzioni dell'assetto societario, organizzativo e normativo;
- esiti delle attività di *risk management*;
- esiti di audit e di *continuous auditing*, segnalazioni e indicazioni ricevute dagli Organi di controllo e vigilanza e dal Vertice aziendale.

5.2 Determinazione dell'indice di rischio degli OA

Ad ogni OA è associata una valutazione di “rischiosità” che tiene conto, di norma, dei seguenti aspetti (ove disponibili):

- rilevanza strategica, cioè quanto l'OA concorre al raggiungimento degli obiettivi definiti nel piano industriale/strategico di Gruppo e della società;
- esiti delle attività di *risk assessment* svolte dalle competenti funzioni aziendali²⁰;
- rilevanza dell'OA ai fini di modelli di controllo societario, quali, ad esempio, il Modello 231, l'*ABC system* e *Policy* Anticorruzione e il “Modello 262”;
- fattore quali-quantitativo, che valorizza sia aspetti qualitativi, come ad es. la conoscenza e l'esperienza del *Management* della **funzione IA**, la ricorrenza delle segnalazioni su ciascun OA, altre attività di controllo svolte da strutture aziendali diverse dall'IA, sia aspetti quantitativi valorizzati sulla base di indicatori individuati per

²⁰ Ad esempio dal *Risk Management*.

il processo principale di riferimento dell'OA (ad es. *CAPEX*, *OPEX*, costi, volumi di acquisto, volumi di vendita, etc.), anche derivanti dalle analisi di *continuous auditing* (ove attivato sull'OA di interesse).

A ciascuno dei suddetti fattori deve essere associato un valore numerico di sintesi e un peso, la cui combinazione determina l'indice di rischio (*Risk Scoring Index*) di ciascun OA²¹. Sulla base del valore del *Risk Scoring Index* (*RSI*), gli OA sono raggruppati per fasce di rischio.

5.3 Definizione del Piano di Audit

Al fine di individuare gli interventi da inserire nel Piano di Audit, viene definito l'“*auditable audit universe*”, ovvero un sotto insieme dell'universo degli OA costituito dagli OA effettivamente pianificabili, in quanto non interessati da circostanze e/o eventi che non consentirebbero uno svolgimento efficace ed efficiente delle verifiche²².

Inoltre, sono di norma esclusi²³ gli OA su cui sono già stati svolti interventi nell'ultimo biennio/triennio al fine di garantire continuità, alternanza e ciclicità nella copertura degli stessi.

Una volta associati gli OA alle diverse fasce di rischio e individuato l'“*auditable audit universe*”, gli interventi di audit da inserire nella proposta di Piano di Audit sono individuati sulla base dei seguenti *step*:

- 1) selezionando un numero di interventi per ciascuna fascia di rischio. Tale selezione è effettuata applicando la percentuale di riferimento definita²⁴ per ogni fascia di rischio al numero totale di OA contenuti nella fascia stessa; prevedendo di coprire gli OA appartenenti alle fasce di rischio più elevato entro un periodo di massimo tre anni²⁵;
- 2) ordinando gli OA in funzione del *RSI* decrescente e dando priorità agli OA a rilevanza 231²⁶.

Nella selezione degli interventi da inserire nella proposta di Piano di Audit, si deve tenere conto anche di:

- eventuali indicazioni del Vertice e/o degli Organi di controllo e vigilanza e/o del *Top Management*;
- equilibrio generale degli interventi tra le diverse aree aziendali/funzioni/strutture interessate dagli interventi di audit;

²¹ Si riporta di seguito un esempio di formula per la determinazione del *Risk Scoring Index* (*RSI*):

$$RSI = 25\% \cdot (R1\text{-Rilevanza Strategica}) + 25\% \cdot (R2\text{-Risk Assessment}) + 30\% \cdot (R3\text{-Rilevanza 231/ABC/262}) + 20\% \cdot (R4\text{-Quali/Quantitativo}).$$

²² Quali, ad esempio, iniziative progettuali rilevanti che comportano una modifica strutturale del SCIGR e che potrebbero, di conseguenza, rendere opportuno un rinvio delle verifiche (successivamente al completamento del progetto).

²³ Salvo il caso di verifiche previste da normative su tematiche specifiche che prevedono una periodicità degli interventi maggiore (per es. annuale) ed escluso il processo di pianificazione dei *Follow-up* “sul campo”.

²⁴ Per esempio: Fascia A (*RSI* Alto)=60%; Fascia B (*RSI* Medio-Alto)=45%; Fascia C (*RSI* Medio)=30%; Fascia D (*RSI* Medio-Basso)=15%; Fascia E (*RSI* Basso)=5%.

²⁵ Salvo diverse indicazioni del CdA e/o in funzione della capacità produttiva e/o del *budget* di spesa della funzione IA, soprattutto per quelle di minori dimensioni.

²⁶ Ove il Piano di Vigilanza costituisca parte integrante del Piano di Audit.

- inserimento di *Entity Audit*²⁷, con priorità per le società di recente acquisizione/costituzione²⁸;
- valutazioni professionali di altre informazioni in possesso dell'Internal Audit e funzionali al raggiungimento degli obiettivi di rilevanza e di copertura dei principali rischi aziendali.

La proposta di Piano di Audit, derivante dal processo sopra descritto, mira a condurre verifiche integrate nell'ottica di cogliere ogni possibile sinergia, evitando sovrapposizioni e inefficienze, nonché integrando nell'ambito degli interventi di audit le verifiche di natura *Operational*, *Compliance* e *Financial*.

Il Piano di Audit annuale può contenere anche una previsione degli ulteriori interventi realizzabili nei due anni successivi, con particolare riferimento agli oggetti di audit appartenenti alle fasce di rischio più alte. Tale previsione è comunque oggetto di revisione annualmente.

Il Piano di Audit include anche ulteriori attività svolte dalla *funzione IA*, quali ad esempio: *i*) interventi di consulenza / supporto in materia di SCIGR (richiesti dagli *stakeholder* dell'IA e/o proposti dal *RIA*); *ii*) attività di monitoraggio indipendente "262" per il Dirigente Preposto (DP); *iv*) *continuous auditing*; *iii*) attività di supporto agli Organi di controllo e vigilanza e ai Comitati Aziendali²⁹.

5.4 Pianificazione interventi di *follow-up* "sul campo"

Gli interventi di *follow-up* "sul campo" sono pianificati su tutte le azioni correttive relative a Rapporti di audit con *Rating* SCIGR più critico³⁰. In particolare, sono previsti *follow-up* "sul campo" per i rapporti di audit emessi con *Rating* SCIGR "Non soddisfacente" o "Necessari miglioramenti significativi"; per i Rapporti di audit con *Rating* "Necessari alcuni miglioramenti" la pianificazione di un eventuale *Follow-up* "sul campo" va valutata caso per caso.

A supporto di tale valutazione si può tenere conto dei seguenti aspetti:

- particolare criticità/rilevanza della tematica oggetto di audit, la quale necessita di un ulteriore monitoraggio tramite un *Follow-up* "sul campo";
- presenza di rilievi particolarmente importanti (di norma con *rating* r1), anche se in numero ridotto rispetto al numero totale dei rilievi emersi nell'intervento di audit;
- maggior numerosità dei rilievi di disegno.

²⁷ Focalizzati su controlli di sistema e di *governance*.

²⁸ Ove applicabile, sulla base degli ambiti operativi delle funzioni internal audit disciplinati dall'*Audit Charter*.

²⁹ Per esempio il Comitato Etico.

³⁰ Nel caso di *Follow-up* "sul campo" relativi ad audit con *Rating* espresso con la precedente metodologia/scala di valutazione, deve essere effettuata una riclassificazione del *Rating* sulla base dell'attuale metodologia/scala di valutazione.

Inoltre, può essere pianificato un unico intervento di *follow-up* “sul campo” (c.d. *Follow-up* trasversale) sulle azioni correttive relative ai rilievi più critici inclusi in Rapporti di audit diversi da quelli suddetti, laddove gli interventi di audit abbiano interessato la stessa funzione/direzione aziendale.

Il *Follow-up* “sul campo” è previsto anche a seguito di specifiche richieste del Vertice e degli Organi di controllo e vigilanza societari.

5.5 Approvazione del Piano di Audit

La proposta di Piano di Audit è elaborata dal RIA, con il supporto della competente struttura della **funzione IA** (ove istituita) e degli altri Responsabili all'interno della **funzione IA**.

Prima dell'approvazione, il RIA **societario** illustra la proposta di Piano di Audit alla struttura competente della pianificazione della **funzione internal audit di FS SpA** al fine di condividere: *i*) le metodologie utilizzate, *ii*) eventuali sinergie operative e possibili interventi congiunti, *iii*) allineamento su tematiche trasversali³¹.

La proposta di Piano è approvata, almeno annualmente, dal CdA della Società, previo parere del Comitato Controllo e Rischi (ove istituito) e sentiti il Presidente, l'AD e il CS di Società.

La proposta di Piano di Vigilanza della società (ove previsto), relativamente agli interventi di vigilanza svolti ai sensi del D.lgs. 231/2001 dalla **funzione IA**³², è parte integrante del Piano di Audit ed è approvata dall'Organismo di Vigilanza preventivamente alla presentazione del Piano di Audit al Comitato Controllo e Rischi (ove istituito) e al CS.

Una volta che il Piano è approvato, il RIA informa i Responsabili apicali di struttura circa il loro futuro coinvolgimento nell'esecuzione degli interventi di audit riguardanti i loro ambiti di responsabilità.

Il RIA, nell'ambito del *reporting* periodico verso il CdA, informa il Vertice e gli Organi di controllo e vigilanza in merito allo stato di avanzamento del Piano di Audit approvato e/o alla necessità di sottoporre (sulla base dello stesso iter approvativo sopra descritto) eventuali modifiche/integrazioni del Piano stesso, derivanti per esempio dalle evoluzioni del Piano Strategico di Gruppo, del business e dei relativi profili di rischio, dell'assetto societario e di ulteriori tematiche emergenti di particolare rilevanza.

NB³³: Il Piano di audit approvato dal CdA è inserito nel sistema informativo gestionale.

³¹ Nel rispetto degli ambiti operativi della **funzione IA di FS SpA** e delle **funzioni IA societarie** definiti nell'*Audit Charter*.

³² A seconda dei modelli di funzionamento degli OdV societari (per esempio laddove l'OdV gestisca autonomamente, cioè senza il coinvolgimento della **funzione IA**, alcuni interventi di vigilanza) e di quanto previsto dall'*Audit Charter*.

³³ Per le **funzioni IA** che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

6 PROGRAMMAZIONE OPERATIVA

Sulla base del Piano di Audit approvato, del *budget* risorse disponibile e delle altre attività della **funzione IA**, viene elaborata la programmazione operativa di tutte le attività previste nell'anno di riferimento³⁴.

La programmazione operativa prevede l'assegnazione delle singole attività ai Responsabili di struttura, la loro calendarizzazione nel corso dell'anno e l'assegnazione delle relative risorse³⁵, tenendo conto della disponibilità di quest'ultime per lo svolgimento delle attività e bilanciando i volumi complessivi di tutte le attività della funzione IA.

Con particolare riferimento alle attività di verifica (es. Audit, *Follow-up*, monitoraggio indipendente "262"), la programmazione operativa prevede:

- l'assegnazione dei singoli interventi ai Responsabili dell'audit, ove presenti;
- lo *scheduling* degli interventi nel corso dell'anno;
- l'assegnazione dei *Team* di risorse³⁶ a ciascun intervento;
- l'analisi dei seguenti fattori:
 - disponibilità delle risorse, in termini quali/quantitativi³⁷;
 - tempi medi previsti per ciascuna tipologia di intervento, espressi sia in termini di *effort* (ore uomo) che di durata (giorni di calendario) e definiti sulla base di dati storici e delle informazioni³⁸ relative all'intervento da svolgere;
 - numero di interventi assegnati a ciascun Responsabile dell'audit;
 - eventuali esigenze operative³⁹ legate ai processi/funzioni/attività che saranno oggetto degli interventi di audit/*follow-up* "sul campo" (pianificati e/o spot);
 - equilibrio nel calendarizzare in periodi diversi/in contemporanea più interventi che interessano la medesima società controllata e/o funzione/direzione aziendale.

³⁴ La programmazione operativa è elaborata, in funzione dell'organizzazione interna della **funzione IA**, dai Responsabili di ciascuna struttura (ogni singola programmazione deve poi essere consolidata in un unico documento) oppure, dal Responsabile della struttura competente per la gestione del *pool* risorse in coordinamento con gli altri Responsabili oppure direttamente dai **RIA**.

³⁵ Allocazione di risorse sufficienti con il mix di conoscenze, capacità e altre competenze necessarie per svolgere l'incarico.

³⁶ Il *Team* di audit è di norma composto da un coordinatore operativo (c.d. *Team Leader*) e da uno o più auditor.

³⁷ Tenendo presente in particolare: il livello di *seniority*; le conoscenze/competenze specialistiche; la dislocazione territoriale; i periodi di indisponibilità (per es. per attività di formazione, ferie, permessi, ecc.).

³⁸ Quali ad esempio: *i*) obiettivi e prima ipotesi di *scope* dell'intervento, *ii*) nr. strutture coinvolte, *iii*) tipologia intervento (audit pianificato o audit spot), ecc.

³⁹ Quali per esempio attività progettuali in corso.

Inoltre, nella programmazione operativa è prevista l'indicazione degli interventi svolti con il supporto di un *outsourcer*⁴⁰.

Lo *scheduling* di ciascun intervento di audit/*follow-up* “sul campo” tiene conto almeno dei seguenti elementi:

- data prevista di avvio dell'attività;
- data prevista di consegna della bozza di Rapporto di audit al RIA;
- ore uomo previsti per ciascuna risorsa del *Team* di audit.

La programmazione operativa è monitorata e aggiornata periodicamente⁴¹, sulla base dello stato di avanzamento (consuntivo) delle singole attività ed è resa disponibile al RIA e a tutti i responsabili delle strutture della funzione IA.

I principi e gli obiettivi contenuti nel presente capitolo troveranno opportuna e adeguata declinazione operativa in ciascuna funzione IA, che li armonizzerà con le proprie specificità organizzative (soprattutto per le *funzioni IA* di minori dimensioni⁴²) e/o societarie e in funzione delle informazioni disponibili. Tali specificità saranno preventivamente condivise con la competente struttura in ambito metodologie della *funzione internal audit* di FS SpA per la relativa validazione.

NB⁴³: Le informazioni relative alla programmazione operativa sono inserite nel sistema informativo gestionale.

7 GESTIONE DEGLI INTERVENTI DI AUDIT

Il processo di gestione degli interventi di audit prevede le seguenti attività:

1. Avvio dell'intervento;
2. Attività preliminare;
3. Attività esecutiva;
4. Formalizzazione e *reporting* dei risultati;
5. Monitoraggio azioni correttive.

⁴⁰ Per esempio, attraverso l'attivazione di specifici accordi quadro di *outsourcing* dei servizi di internal auditing.

⁴¹ In funzione dell'organizzazione interna della *funzione IA*, è definita la periodicità di aggiornamento, curato dai Responsabili di ciascuna struttura/responsabili degli audit oppure dal Responsabile della struttura competente per la gestione del *pool* risorse (in coordinamento con gli altri responsabili) oppure direttamente dal RIA. In ogni caso, l'aggiornamento della programmazione operativa deve poi confluire in un unico documento di consolidamento delle attività della *funzione IA*.

⁴² E di norma prive di un'articolazione organizzativa in diverse strutture.

⁴³ Per le *funzioni IA* che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

A supporto di tali attività sono stati definiti specifici standard operativi. Per l'utilizzo degli standard si rimanda all'Allegato 1 "Linee guida per l'utilizzo degli standard operativi".

7.1 Avvio dell'intervento

Obiettivo della presente attività è informare i Responsabili apicali delle strutture/società interessate dell'avvio degli interventi di audit o di *follow-up* "sul campo".

Il RIA comunica al Responsabile apicale della struttura/Società interessata l'avvio dell'intervento di audit/*follow-up* sul campo, dandone contestuale informativa al Presidente del CdA e all'AD della propria Società. La comunicazione avviene tramite "lettera di avvio" predisposta⁴⁴ dal Responsabile dell'audit, firmata dal RIA e trasmessa da quest'ultimo ai destinatari⁴⁵.

Prima della comunicazione dell'avvio dell'intervento di audit o di *follow-up* sul campo, il RIA valuta con il Vertice aziendale e, ove necessario, con gli Organi di controllo e vigilanza, l'opportunità di affidare l'esecuzione dell'intervento in outsourcing.

L'eventuale effettuazione di interventi di audit previsti dal Piano di Audit, di interventi c.d. "Audit spot" e/o di altre attività di verifica su aree/processi su cui sono in corso di svolgimento indagini da parte dell'Autorità Giudiziaria e/o altre Autorità, è sottoposta⁴⁶ alla preliminare valutazione della funzione legale al fine di verificarne la compatibilità con le attività di indagine. Il RIA riferisce al Presidente del CdA e all'AD societario in merito agli esiti degli orientamenti assunti dalla funzione.

7.2 Attività preliminare

Obiettivo della presente fase è consentire al *Team* di audit di individuare i processi/sottoprocessi/attività (di seguito ambiti) in cui è articolato l'oggetto di audit e di formulare valutazioni preventive circa la significatività degli stessi, dei potenziali rischi e delle possibili aree critiche per focalizzare il Programma di Lavoro dell'audit. Tale obiettivo è conseguito dal *Team* di audit, con la supervisione del Responsabile dell'audit, attraverso la raccolta e l'analisi delle informazioni, le interviste preliminari con il personale delle aree interessate dall'attività di audit e l'eventuale osservazione diretta dello svolgimento delle diverse attività che compongono i processi esaminati (*walkthrough*).

⁴⁴ Sulla base dello standard operativo "ST Lettera di avvio audit (o *follow-up*)".

⁴⁵ Le tipologie di destinatari sono indicate nello standard operativo "ST Lettera di avvio audit (o *follow-up*)".

⁴⁶ Sulla base dello standard operativo "ST Richiesta valutazione legale".

7.2.1 Relazione di pianificazione

A supporto dello svolgimento dell'intervento e in particolare dell'attività preliminare, la competente struttura della **funzione IA** (ove istituita)/il referente della pianificazione annuale e l'Audit Manager forniscono⁴⁷ al *Team* di audit alcune informazioni in merito all'intervento stesso, quali:

- natura e obiettivi specifici dell'intervento: *i)* origine (spot o pianificato), *ii)* eventuali suggerimenti/considerazioni provenienti dagli *stakeholders* dell'IA, *iii)* innesto di eventuali segnalazioni, *iv)* principali aspetti in merito agli esiti degli orientamenti assunti dalla funzione legale (ove disponibili), *v)* modalità particolari di svolgimento dell'intervento (es. in modalità "tradizionale", "*combined assurance*" o "*agile*", in *joint* con altra **funzione IA**, con *interim report*, senza interviste al *Management*, etc.);
- valutazione preliminare dei rischi: descrizione dei principali rischi da approfondire nell'intervento, individuati sulla base del *risk assessment* derivante dal processo di Risk Management, delle previsioni del Modello 231 e del Modello ABC *System* e della *Policy* Anticorruzione ed eventuali altri modelli di controllo aziendali (es. Antitrust, *Tax Compliance Framework*, Modello 262);
- aspettative *stakeholders* interni: descrizione di eventuali aspettative e/o richieste degli *stakeholders* dell'IA emerse in sede di predisposizione del Piano di Audit o di richiesta di Audit Spot;
- opportunità di miglioramento del SCIGR: descrizione di eventuali aree di miglioramento sulla base delle informazioni preliminari assunte e/o di fatti / eventi già noti, quali ad esempio le informazioni provenienti: *i)* da attività di *continuous auditing*, *ii)* dall'andamento di eventuali indicatori di processo, *iii)* dalla Relazione annuale del DP, *iv)* dalla struttura che gestisce le segnalazioni⁴⁸ (compresa indicazione se all'OdV e/o al Comitato Etico sono pervenute segnalazioni), *v)* da altre attività di verifica / monitoraggio svolte da altre strutture aziendali con cui sono formalizzati flussi informativi, *vi)* da eventuali indagini dell'autorità giudiziaria, *vii)* da analisi svolte sui flussi informativi "231", etc.;
- informazioni preliminari sulla composizione del *Team* di audit, il relativo *effort* e le tempistiche dell'intervento.

La relazione di pianificazione va elaborata nel periodo intercorrente tra l'avvio del singolo intervento e la redazione del Programma di Lavoro, recependo – tra l'altro - eventuali osservazioni e informazioni pervenute dagli *stakeholder* dell'IA, ulteriori a quelle recepite in sede di pianificazione annuale.

Alla relazione di pianificazione vanno allegati tutti i documenti analizzati al fine di supportare e velocizzare la successiva fase di raccolta della documentazione.

⁴⁷ Sulla base dello standard operativo "*ST Relazione di pianificazione*".

⁴⁸ Tali informazioni sono richieste dal Team di audit in fase di avvio dell'attività e/o di reporting.

7.2.2 Raccolta della documentazione e incontro preliminare con la struttura auditata

La documentazione funzionale alle analisi può essere reperita sia autonomamente dal *Team* di audit sia tramite specifica richiesta alle strutture aziendali competenti⁴⁹.

In particolare, sono reperiti direttamente dal *Team* di audit tutti i documenti pubblicati sul portale intranet aziendale⁵⁰ (quali, per esempio, documenti organizzativi, normative e modelli di riferimento, procedure dei Sistemi di gestione della qualità) nonché altre informazioni disponibili presso la **funzione IA**, quali, in particolare:

- gli esiti delle attività di *risk assessment*, disponibili dal processo di *Risk Management* (ove presente) e correlati agli obiettivi del processo/attività oggetto dell'audit;
- gli esiti di eventuali *risk assessment* finalizzati all'aggiornamento dei Modelli 231 e *Anti Bribery&Corruption*, forniti dalle competenti funzioni/strutture aziendali;
- la relazione annuale del Dirigente Preposto⁵¹ (con evidenza degli esiti delle attività di monitoraggio indipendente "262");
- le informazioni sulle eventuali segnalazioni⁵² afferenti al perimetro dell'intervento di audit;
- le informazioni su eventuali interventi di audit/*follow-up* svolti su aree/processi correlati allo *scope* dell'intervento avviati nel triennio precedente alla data di avvio dell'audit in corso, nonché lo stato delle relative carenze;
- esiti derivanti dagli approfondimenti di *continuous auditing* (ove attivato sul perimetro – totale o parziale - dell'intervento di audit);
- gli esiti di attività di analisi dei flussi informativi "231" ed esiti di altri flussi informativi provenienti da strutture di secondo livello di controllo (ove disponibili);
- le informazioni desumibili attraverso gli strumenti specialistici a disposizione (es. banche dati esterne, sistema aziendale di gestione delle procure, *data base* aziendali sulla composizione degli Organi di governo, di controllo e di vigilanza delle società del Gruppo). In particolare, va promosso l'utilizzo di banche dati interne alla **funzione IA** (ove disponibili) che permettano di valorizzare esperienze di audit precedenti e che abbiano attinenza con l'incarico da svolgere.

Esternamente alla **funzione IA**, il Responsabile dell'audit richiede, in particolare:

⁴⁹ Che può essere effettuata anche prima dell'incontro preliminare con le strutture auditate (c.d. *Opening Meeting*).

⁵⁰ Di Gruppo e/o di società.

⁵¹ Oppure, ove non fosse presente il DP, la relazione redatta dal Responsabile Amministrativo sull'attività svolta a supporto delle attestazioni ex lege 262/2005.

⁵² Che risultano alla funzione IA dai flussi informativi con gli Organi preposti (es. OdV e Comitato Etico).

- ai Responsabili delle strutture aziendali / processi interessati, la documentazione in ambito necessaria allo svolgimento delle verifiche, nonché, qualora confermato dal Responsabile stesso, le risultanze di eventuali interventi svolti da parte di altri *assurance provider*;
- alle eventuali strutture aziendali che svolgono un monitoraggio interno di processo (controllo di “secondo livello”) sulle attività della competente direzione/funzione, le risultanze dell’eventuale monitoraggio svolto.

La documentazione raccolta deve essere pertinente con l’obiettivo dell’intervento di audit e inerente all’attività oggetto di verifica.

La richiesta di documentazione può essere formulata secondo le modalità ritenute più opportune dal Responsabile dell’audit; tramite e-mail, includendola nella presentazione di apertura dell’intervento (c.d. *Opening Meeting*) oppure nel corso delle interviste effettuate. In linea generale, l’attività di acquisizione della documentazione richiesta alle strutture auditate deve garantire la tracciabilità della fonte (“chi” l’ha fornita all’Internal Audit) e del momento (data) in cui è stata acquisita.

Gli elementi informativi necessari allo svolgimento dell’intervento sono acquisiti anche attraverso estrazione diretta dai sistemi informativi di processo a cura del *Team* di audit e/o tramite questionari diffusi ad un numero elevato di interlocutori.

L’attività presso le strutture auditate è avviata dal Responsabile dell’audit di norma mediante una riunione di apertura (*Opening Meeting*) con il *Management* al fine di:

- illustrare gli obiettivi e il perimetro dell’audit;
- presentare gli approcci operativi che saranno adottati (ad es. approccio “tradizionale”, “*combined assurance*” o “*agile*”, svolgimento di interviste, rilevazione del processo aziendale tramite *walkthrough*, esecuzione di *test* dei controlli, discussione evidenze emerse dalle attività di *testing*, etc.);
- ottenere le prime indicazioni utili alle analisi (includendo, come detto, l’eventuale richiesta di documentazione);
- concordare con la/e struttura/e auditata/e un primo *Gantt* delle attività;
- presentare il *Team* di audit.

I contenuti dell’*Opening Meeting* possono variare a seconda delle specificità dell’intervento e sono inseriti nella presentazione⁵³ (di “*Opening Meeting*”) a supporto dell’incontro.

⁵³ Elaborata sulla base dello standard operativo “*ST Opening meeting*”. La presentazione di *Opening Meeting* potrebbe non essere necessaria, per esempio, nel caso in cui gli aspetti da affrontare nell’intervento di audit siano stati già trattati, nella loro interezza o parzialmente, nel corso di riunioni e/o di azioni di sensibilizzazione e/o di incontri diversamente finalizzati ma che comunque hanno consentito alla struttura auditata di essere già a conoscenza degli aspetti da affrontare nell’audit.

Alla riunione partecipano, oltre al *Management* operativo, il Responsabile dell'audit e il *Team* di audit e, ove necessario in ragione delle peculiarità dell'intervento, il RIA.

7.2.3 Analisi delle informazioni e definizione del piano dei test

Il *Team Leader*, con il supporto del *Team*, procede – anche contestualmente alla fase precedente – all'identificazione delle principali aree di rischio al fine di definire il piano dei *test* dell'intervento.

L'identificazione delle principali aree di rischio avviene attraverso:

- l'analisi preliminare delle risultanze, ove disponibili e ove applicabili, delle attività di *risk assessment* svolte nell'ambito del processo di *Risk Management*, nonché altre informazioni sui rischi prodotte da altre strutture aziendali sui processi oggetto di audit⁵⁴;
- gli eventuali ulteriori indicatori di rischio, tra cui, a titolo esemplificativo e non esaustivo, quelli rivenienti da Rapporti di audit, da specifici modelli di controllo (es. Modello 231, *ABC system*), da attività di monitoraggio svolte da altre strutture aziendali sulle attività oggetto di audit, da indicazioni degli Organi di controllo e vigilanza e/o da informazioni relative a segnalazioni pervenute;
- lo svolgimento di interviste di approfondimento, ove necessarie, con il/i Responsabile/i della/e struttura/e auditata/e, partendo, ove disponibili e ove applicabili, dalle risultanze del *risk assessment* svolto nell'ambito del processo di *Risk Management* nonché di altri *risk assessment*; obiettivo di tali interviste è l'identificazione (e/o l'aggiornamento) dei principali rischi che minacciano il raggiungimento degli obiettivi di processo e l'identificazione degli eventuali controlli posti a loro presidio (individuati dal Responsabile della struttura auditata).

Le interviste effettuate sono, di norma, formalizzate. L'attività di formalizzazione avviene attraverso appositi documenti/memo⁵⁵, condivisi, se necessario, con i partecipanti alle interviste, in cui sono descritti in particolare gli argomenti trattati⁵⁶, soprattutto tutte le informazioni (emerse dall'intervista) a supporto degli ambiti di miglioramento identificati;

- l'analisi di piani di *test* standard, ove disponibili, contenenti i principali rischi insistenti sui processi/fasi/attività oggetto di audit e i relativi controlli posti a loro presidio.

Il *Team Leader* con l'ausilio del *Team*, basandosi sulle informazioni e sulle analisi svolte sopra rappresentate, nonché sul proprio giudizio professionale, definisce un piano dei *test* articolato, per ciascun ambito dell'audit, in:

⁵⁴ Ad esempio, il *risk assessment* in ambito anticorruzione, le matrici rischi e controlli allegate alle Procedure Amministrativo Contabili (PAC).

⁵⁵ Sulla base dello standard operativo “*ST Memo intervista*” o anche attraverso altre modalità che garantiscano comunque la piena tracciabilità.

⁵⁶ Oltre, per esempio, al titolo dell'intervento di audit di riferimento, ai nominativi e ruolo dei partecipanti all'intervista, alla data/luogo dell'intervista.

- principali rischi di tipo *Operational* e/o *Financial* e/o *Compliance*;
- per ciascun rischio, gli obiettivi di controllo;
- la descrizione delle attività (*test*) che si intende svolgere per la valutazione dell'adeguatezza e dell'efficacia dei controlli, mantenendo distinte le attività di verifica relative alla valutazione del disegno da quelle sull'operatività; ivi incluse le verifiche sugli eventuali standard di controllo previsti da specifici modelli di controllo (es. Modello 231, *ABC system*).

Qualora, relativamente ai processi oggetto di audit, siano disponibili piani di *test* standard, predisposti internamente alla **funzione IA**, il *Team Leader*, con l'ausilio del *Team*, ne valuta la totale o parziale applicabilità agli ambiti dell'intervento, sulla base di quanto emerso dalla preliminare analisi dei rischi, apportando eventuali adeguamenti.

In questa fase, il *Team Leader*, ove ritenuto necessario dal Responsabile dell'audit, richiede il supporto specialistico agli altri colleghi della **funzione IA** e/o della famiglia professionale IA, depositari di specifico *know how* sui processi oggetto di audit.

Il piano dei *test* predisposto dal *Team Leader* è parte integrante del Programma di Lavoro dell'intervento, approvato dal Responsabile dell'audit⁵⁷, come descritto nel successivo paragrafo 7.2.5.

7.2.4 Budget delle risorse e tempistiche di realizzazione dell'intervento

Soprattutto sulla base del piano dei *test* predisposto, il Responsabile dell'audit, con l'ausilio del *Team Leader* quantifica le risorse necessarie per il completamento dell'intervento di audit in termini di *effort* (ore/giorni uomo) e di *elapsed* (giorni di calendario), con evidenza delle principali *milestone*, valutando con il supporto della struttura competente per la programmazione operativa (ove presente) l'opportunità di rivedere e/o integrare la composizione del *Team* in termini di numerosità e competenze necessarie per svolgere l'incarico (rispetto alla programmazione operativa iniziale).

Nel caso in cui emergesse l'esigenza di avviare approfondimenti specifici su particolari aree di rischio e/o *red flag* all'interno degli interventi, viene valutata, di volta in volta, l'opportunità di impiegare⁵⁸ per la conduzione degli approfondimenti risorse aziendali specializzate a supporto del *Team* di audit già costituito o stabilmente all'interno del *Team* stesso⁵⁹.

In particolare, l'utilizzo professionale temporaneo di personale specialistico presente in altre società/aree o settori aziendali per l'impiego in interventi di audit, è preventivamente condiviso con il Responsabile gerarchico della risorsa interessata nonché con la competente funzione risorse umane e organizzazione e previa valutazione delle

⁵⁷ E anche dal **RIA** ove previsto da quest'ultimo.

⁵⁸ Sulla base dello standard operativo "*Richiesta risorsa specialistica*".

⁵⁹ In tali casi il Responsabile dell'audit rivede il *budget* (ore/giorni uomo) dell'audit inizialmente definito per valutarne la rimodulazione sulla base delle specifiche esigenze emerse.

condizioni di indipendenza. Il personale specialistico sarà formalmente incaricato dal Responsabile di riferimento, tra profili di riconosciuta competenza specialistica rispetto all'oggetto delle analisi e dovrà garantire, nello svolgimento delle attività, massima integrità, obiettività, riservatezza e indipendenza di giudizio, nonché assenza di situazioni di conflitto di interessi. Tale personale integrerà a ogni effetto e per gli aspetti di competenza il *Team* di audit, cui riporterà in via esclusiva gli esiti delle analisi svolte con ogni garanzia di riservatezza e confidenzialità.

Nella seguente tabella sono riportate le principali *milestone* di un intervento di audit:

<i>Milestone</i>	Descrizione
1. Data pianificata di inizio attività del <i>Team</i>	Data di assegnazione del <i>Team</i> definita nella programmazione operativa iniziale condivisa.
2. Data approvazione Programma di Lavoro	Data in cui il Responsabile dell'audit prevede di approvare il Programma di Lavoro dell'intervento, propedeutico all'avvio delle attività di <i>testing</i> .
3. Data inizio attività di verifica (<i>testing</i>)	Primo giorno previsto per l'attività di verifica (<i>testing</i>).
4. Data fine attività di verifica (<i>testing</i>)	Ultimo giorno previsto per l'attività di verifica (<i>testing</i>).
5. Data inizio discussione e formalizzazione risultati	Primo giorno previsto per l'attività di discussione con il <i>Management</i> dei risultati e di formalizzazione del Rapporto di audit.
6. Data fine discussione e formalizzazione risultati	Ultimo giorno previsto per l'attività di discussione con il <i>Management</i> dei risultati e di formalizzazione del Rapporto di audit.
7. Data consegna <i>draft</i> al RIA	Data prevista di consegna al RIA del <i>draft</i> del Rapporto di audit.

Qualora nel corso dell'intervento dovesse emergere la necessità di rivedere significativamente l'*effort* (ore/giorni uomo) e le tempistiche di realizzazione, il Responsabile dell'audit si coordina con il responsabile della struttura della **funzione IA** competente per la programmazione operativa (ove presente) per l'individuazione delle migliori soluzioni da adottare.

7.2.5 Definizione del Programma di Lavoro dell'intervento

Il *Team Leader*, con l'ausilio del *Team*, a conclusione delle analisi preliminari, sulla base della documentazione e delle informazioni raccolte, predispone il Programma di Lavoro⁶⁰ dell'audit, in cui rappresenta, in particolare:

- le principali caratteristiche del contesto di riferimento delle attività oggetto di analisi;
- le valutazioni effettuate circa la significatività dei potenziali rischi e delle possibili aree critiche del processo/attività oggetto di audit;

⁶⁰ Sulla base dello standard operativo "ST Programma di lavoro".

- gli obiettivi dell'intervento e gli ambiti su cui sviluppare le attività di *testing*;
- i contenuti del piano dei *test* da sviluppare, articolato nelle seguenti principali informazioni: *i)* rischio, *ii)* obiettivo di controllo, *iii)* descrizione del *test*, *iv)* esito del test, *v)* descrizione dell'eventuale *gap* individuato e *cross reference* al relativo rilievo (che sarà descritto nel Rapporto di audit/*follow-up*);
- gli oggetti di riferimento da campionare e i criteri di campionamento;
- il *budget* delle risorse e le tempistiche necessari per lo svolgimento dell'intervento.

Con particolare riferimento agli *item* campionati, sono riportate le informazioni di dettaglio relative alla popolazione fornita dalla/e struttura/e auditata/e oppure acquisita autonomamente dal *Team* di audit, le verifiche di completezza e accuratezza della popolazione ove effettuabili⁶¹, il campione individuato e i relativi criteri di estrazione.

Il Programma di Lavoro, corredato della documentazione di supporto raccolta e analizzata nell'attività preliminare, deve essere successivamente sottoposto al Responsabile dell'audit⁶², che ne approva i contenuti entro le tempistiche previste per il completamento delle attività preliminari e a seguito delle verifiche e delle eventuali modifiche che ritiene necessarie. Nei casi in cui si rendessero necessarie modifiche⁶³ al Programma di Lavoro durante la fase esecutiva (per es. relative al campione individuato e/o all'*effort* e ai tempi necessari e/o al piano dei *test*), il documento dovrà essere aggiornato dal *Team Leader* e riapprovato dal Responsabile dell'audit. Tali approvazioni devono essere rilasciate su eventuale sistema informativo gestionale a supporto delle attività di audit (ove esistente).

NB⁶⁴: Le principali informazioni sull'intervento di audit e sul relativo programma di lavoro sono inserite nel sistema informativo gestionale.

7.3 Attività esecutiva

L'attività di verifica ha lo scopo di valutare l'adeguatezza e l'efficacia dei controlli che presidiano i rischi rientranti nell'oggetto di audit. A tal fine, il *Team* di audit, sulla base del Programma di Lavoro definito, raccoglie, analizza, valuta e documenta informazioni sufficienti al raggiungimento degli obiettivi dell'intervento di audit.

Le attività svolte sono supervisionate dal Responsabile dell'audit, che fornisce adeguati *feedback* e indirizzi al *Team* durante lo svolgimento dell'intervento

⁶¹ Nei casi in cui non sia possibile effettuare tali verifiche, saranno indicate le relative motivazioni.

⁶² E anche al *RIA* ove previsto da quest'ultimo.

⁶³ A titolo esemplificativo, modifica/aggiunta di ambiti di analisi, punti di controllo e item campionati.

⁶⁴ Per le *funzioni IA* che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

7.3.1 Focus su selezione del campione

L'attività di campionamento è costituita da quella serie di azioni attuate dal *Team* di audit per selezionare un set di transazioni, operazioni o dati su cui intende effettuare i *test*/le verifiche.

Il *Team* di audit valuta se svolgere le verifiche su un campione dei dati e delle informazioni disponibili rappresentativo dell'intera popolazione o sulla totalità degli stessi, sulla base del proprio giudizio professionale, che terrà conto anche dei rischi interessati e degli obiettivi dell'intervento di audit.

Il grado di incertezza definito "rischio di campionamento", così come la scelta del metodo di campionamento da utilizzare, è oggetto di una valutazione professionale da parte del *Team* di audit, in accordo con il Responsabile dell'audit. La decisione è legata alla capacità del campione di fornire una ragionevole rappresentatività per l'intera popolazione dei risultati ma anche alla specificità dell'oggetto di audit (es. audit spot, segnalazioni) e/o alla sua complessità (come nel caso di un intero processo).

In alcuni casi, il *Team* di audit può valutare in accordo con il Responsabile dell'audit di selezionare l'intera popolazione, come - ad esempio - nel caso in cui la popolazione sia costituita da un limitato numero di item di grande valore.

Prima di procedere all'estrazione di un campione, il *Team* di audit acquisisce le seguenti informazioni circa la popolazione da testare:

- numerosità degli elementi/transazioni;
- differenti modalità con cui si può definire la popolazione delle transazioni di un oggetto da sottoporre ad audit (ad esempio in un audit sul ciclo passivo, la popolazione delle transazioni potrebbe essere rappresentata dagli ordini/contratti di acquisto e/o dalle fatture passive e/o dai fornitori);
- periodo di riferimento per l'individuazione della popolazione (es. ultimi due anni di bilancio chiuso, ultimo semestre dell'anno in corso, etc.);
- classi di suddivisione degli elementi/transazioni della popolazione (es. per periodo, per valore, per tipologia, etc.);
- eventuali ulteriori informazioni ricevute (dagli *stakeholders* dell'audit) e/o emerse dai colloqui/interviste con i soggetti auditati.

Una volta definita la popolazione di riferimento e il periodo di osservazione, si seleziona un determinato numero di elementi attraverso due metodi di campionamento:

- campionamento discrezionale, che si basa sul giudizio professionale del *Team* di audit per determinare, in accordo con il Responsabile dell'audit, la dimensione del campione e gli elementi che ne faranno parte.

Pertanto, con tale criterio, il *Team* di audit seleziona il campione sulla base delle proprie esperienze e competenze e, a sua discrezione, definisce la numerosità e soprattutto individua quali elementi della popolazione dovranno essere esaminati, anche in considerazione delle informazioni disponibili sulla popolazione da esaminare;

- campionamento statistico, che si basa su algoritmi matematici (ad es. campionamento per attributi o per variabili), che permettono di individuare in maniera oggettiva la popolazione da testare con particolare riferimento alla determinazione della numerosità del campione e della modalità di selezione degli elementi che ne fanno parte.

Di seguito si riportano alcuni tra i principali metodi di selezione del campione applicabili al campionamento discrezionale e/o al campionamento statistico:

- metodo di selezione “*judgemental*”: il *Team* di audit, basandosi sul proprio giudizio professionale e/o su precedenti risultati di audit, può essere in grado di scegliere gli elementi da testare più significativi per tipologia, valore economico, livello di rischio, strategicità per il *business*, etc.;
- metodo di selezione “casuale”: la selezione non si basa su considerazioni predeterminate (ciascun elemento della popolazione ha la stessa possibilità di essere selezionato);
- metodo di selezione “sistematico”: l’auditor procede al campionamento per intervalli predefiniti ovvero scegliendo un punto di inizio casuale e prendendo ogni n -esima unità nella popolazione⁶⁵ (n è calcolato dividendo la numerosità della popolazione per la dimensione del campione prescelta).

La selezione degli item del campione può avvenire anche mediante la combinazione di due o più dei suddetti metodi. In particolare, in caso di applicazione del criterio “*judgmental*” per la selezione di alcuni item potrebbe essere opportuno applicare la tecnica di campionamento “casuale” per svolgere le verifiche sulla restante parte della popolazione.

Sarà, comunque, responsabilità del Responsabile dell’audit scegliere di volta in volta la metodologia di selezione del campione (discrezionale e/o statistica) che più ritiene adeguata alle attività di *testing* da effettuare, in considerazione, tra l’altro, degli obiettivi dell’intervento, della popolazione da esaminare, delle risorse a disposizione.

⁶⁵ Esempio: popolazione 100 *item*/dimensione campione 20 *item* = 5 intervallo di campionamento. L’auditor selezionerà un *item* ogni 5 e quello iniziale sarà individuato casualmente entro il primo intervallo di campionamento (tra i primi 5 *item*).

7.3.2 Esecuzione delle verifiche (*test*)

I *test* rappresentano l'insieme dei riscontri necessari per valutare l'adeguatezza e l'efficacia del controllo che presidia il rischio identificato e oggetto di verifica, come riportato nel Programma di Lavoro, e costituiscono i fondamenti per i rilievi, le raccomandazioni e la successiva valutazione del SCIGR.

La valutazione del controllo si compone della valutazione del disegno (adeguatezza) e dell'operatività (efficacia).

Per effettuare la valutazione del disegno il *Team* di audit può prendere in considerazione numerosi fattori, quali, in particolare:

- la capacità e tempestività del controllo nell'intercettare parzialmente o totalmente le eccezioni/anomalie e nel ridurle a un livello accettabile (attraverso specifiche azioni correttive);
- il livello di discrezionalità o soggettività del controllo;
- il grado di segregazione tra i soggetti che intervengono nelle varie attività interessate dal controllo;
- il grado di indipendenza del controllo in termini di accesso/gestione delle risorse necessarie per l'esecuzione del controllo stesso;
- il grado di interrelazione o rafforzamento degli altri controlli afferenti al medesimo obiettivo di controllo/rischio (ridondanze dei controlli, controlli compensativi);
- la tipologia del controllo (automatico, manuale, semi-automatico);
- la capacità del controllo di adattarsi alle variazioni che intervengono nelle attività sottostanti (ad es. volume di transazioni, quantità di dati, etc.);
- la tracciabilità e ripercorribilità del controllo;
- il livello di copertura di tutti i rischi significativi a cui il controllo è associato;
- il grado di formalizzazione dei controlli in apposita normativa aziendale;
- il grado di aderenza alle normative aziendali, ove esistenti e formalizzate;
- la competenza del personale incaricato all'esecuzione del controllo.

Per effettuare la valutazione dell'operatività il *Team* di audit può:

- laddove il disegno del controllo sia ritenuto adeguato in termini di obiettivo di controllo, verificare se il controllo opera in conformità a quest'ultimo;

- laddove il disegno del controllo non sia adeguato in termini di obiettivo di controllo e/o la verifica dello stesso non sia risultata completa/conforme, misurare il grado di mancato raggiungimento dell'obiettivo di controllo ritenuto adeguato.

Nel corso dello svolgimento dell'incarico, il *Team* completa il piano dei *test* con le risultanze delle attività di verifica, incluse quelle effettuate mediante il monitoraggio degli indicatori di *continuous auditing*, ove applicabili. Per ciascuna verifica/*test*:

- descrive brevemente l'attività svolta, ivi inclusa l'indicazione di chi l'ha svolta e la data (laddove necessaria per “ripercorrere” le verifiche svolte;
- riepiloga i documenti di supporto utilizzati nelle analisi effettuate (le carte di lavoro sono archiviate e conservate con le modalità definite nel successivo capitolo 14);
- descrive le evidenze delle analisi;
- sulla base delle risultanze emerse, esprime una valutazione di sintesi degli esiti del singolo *test*. In particolare, il *test* può avere il seguente esito:

Esito <i>test</i>	Descrizione
Conforme	L'esecuzione del <i>test</i> ha rilevato una situazione in essere adeguata in termini di disegno, operatività e monitoraggio periodico.
Sostanzialmente conforme	L'esecuzione del <i>test</i> ha rilevato una situazione in essere standardizzata in termini di disegno e operatività.
Parzialmente conforme	L'esecuzione del <i>test</i> ha rilevato una situazione in essere adeguatamente operativa ma non adeguatamente documentata.
Sostanzialmente non conforme	L'esecuzione del <i>test</i> ha rilevato una situazione in essere parzialmente operativa e non adeguatamente documentata.
Non conforme	L'esecuzione del <i>test</i> ha rilevato una situazione in essere non operativa.
<i>Not assessed</i>	Non è possibile performare il <i>test</i> in quanto l'attività/evento non si è verificato nel periodo di riferimento dell'audit.
Completata	L'esecuzione del <i>test</i> – in sede di follow-up sul campo – ha rilevato l'effettiva implementazione dell'azione correttiva definita in sede di audit.
Parzialmente completata	L'esecuzione del <i>test</i> – in sede di follow-up sul campo – ha rilevato una parziale implementazione dell'azione correttiva definita in sede di audit.
Non Completata	L'esecuzione del <i>test</i> – in sede di follow-up sul campo – ha rilevato la non effettiva implementazione dell'azione correttiva definita in sede di audit.

Ai *test* valutati “parzialmente conforme”, “sostanzialmente non conforme”, “non conforme”, “parzialmente completata”, “non completata” corrispondono i rilievi.

Il *Team*, sulla base di considerazioni che possono emergere nel corso della fase di *testing*, può integrare il piano dei *test* con nuovi rischi/controlli/*test*. Tale integrazione deve essere condivisa con il Responsabile dell’audit che ne approva⁶⁶ l’esecuzione.

7.3.3 Identificazione dei rilievi e delle raccomandazioni di rafforzamento del SCIGR

Sulla base delle differenze emerse tra la situazione attesa⁶⁷ e la situazione in essere (così come emersa dalle attività di verifica), il *Team* di audit identifica i possibili rilievi. Per ciascun rilievo, il *Team* identifica la natura (disegno e/o operatività), il *rating* e la rilevanza ai fini del Modello 231, dell’*ABC system* e del Modello 262⁶⁸ societari, nonché le sottostanti cause e i rischi o le conseguenze cui l’organizzazione va incontro a causa della divergenza rispetto ai criteri di riferimento/situazione attesa⁶⁹.

Il Responsabile dell’audit verifica: i) la coerenza del lavoro svolto con quanto previsto nel Programma di Lavoro; ii) la completezza e adeguatezza dell’attività di *test* svolta; iii) l’adeguatezza della documentazione di supporto ai rilievi emersi. Nel caso ritenesse necessari approfondimenti, integra il Programma di Lavoro⁷⁰ e/o effettua richieste specifiche al *Team*.

I rilievi emersi nel corso delle attività di verifica devono essere corredati dalle raccomandazioni, che rappresentano il suggerimento della *funzione IA* sulle modalità di superamento dei rilievi riscontrati al fine di supportare il *Management*, responsabile ultimo del SCIGR sul processo di competenza, nell’individuazione e implementazione delle azioni correttive.

È tuttavia possibile che il *Team*, durante le attività di verifica, individui anche dei rilievi minori, di affinamento del SCIGR analizzato, che non necessariamente richiedono la formulazione di una raccomandazione formale e che non saranno riflessi nel Rapporto di audit, ma troveranno spazio di discussione nel corso dell’esecuzione dell’intervento e/o in sede di *Exit Meeting* (vedi successivo paragrafo 7.4.3).

Nel corso dell’attività di verifica, il Responsabile dell’audit, con il supporto del *Team*, valuta l’opportunità di informare i responsabili della/e struttura/e auditata/e sullo stato di avanzamento delle attività previste nell’intervento di audit, nonché su eventuali punti di attenzione già rilevati.

⁶⁶ Come previsto dal par. 7.2.5 “Definizione del Programma di Lavoro dell’intervento”.

⁶⁷ La situazione attesa è individuata sulla base, in particolare, del sistema normativo e organizzativo aziendale, di interpretazioni autorevoli e/o *best practice* di riferimento.

⁶⁸ Ove applicabile, per esempio nel caso di *combined assurance* (cfr. § 9).

⁶⁹ Sulla base dell’apposita sezione “*Finding*” dello standard operativo “*ST Programma di Lavoro*”. Tale sezione non va compilata nei seguenti casi: i) rilievi cd “minori” emersi dalle attività di audit/*follow-up* ma che non sono riportati nei Rapporti finali; ii) rilievi chiusi da *follow-up* sul campo.

⁷⁰ In particolare, il piano dei *test* ivi contenuto.

NB⁷¹: Gli esiti delle verifiche e le informazioni relative ai rilievi emersi sono gestiti nel sistema informativo gestionale.

7.4 Formalizzazione e *reporting* dei risultati

7.4.1 Valutazione di sintesi (*rating*) del SCIGR e dei rilievi

A conclusione dell'intervento, il *Team* di audit esprime una valutazione di sintesi (*Rating*) sul complessivo stato del disegno e dell'operatività del SCIGR dell'oggetto di audit, sulla base delle conoscenze e delle evidenze acquisite durante lo svolgimento dell'intervento e del proprio giudizio professionale, che copre tutti gli aspetti (*Operational*, *Compliance* e *Financial*) presenti nello *scope* dell'intervento di audit.

L'attribuzione di un *Rating* all'intervento di audit risponde alle seguenti esigenze: *i)* fornire al Vertice aziendale e agli Organi di controllo una valutazione sintetica dell'adeguatezza e del funzionamento del SCIGR; *ii)* pianificare in modo efficace ed efficiente gli interventi di *follow-up* "sul campo"; *iii)* aderire a quanto previsto dagli Standard internazionali per la pratica professionale; *iv)* allinearsi alle *best practice*.

Il *Rating* dell'oggetto di audit si riferisce allo stato del SCIGR riscontrato nel corso dell'intervento; le azioni correttive risultate completate ed effettivamente operative alla data di chiusura dell'attività "sul campo", così come evidenziato dalle verifiche effettuate dal *Team*, concorrono alla valutazione del *Rating*.

Tale valutazione, che risente dei limiti propri dell'attività di *internal auditing* e per sua natura non è in grado di far emergere ogni possibile carenza del sistema di controllo interno, rappresenta un contributo qualitativo professionale che integra, ma non sostituisce, le valutazioni proprie del *Management*, che si basano su una più strutturata conoscenza del processo, su eventuali ulteriori aspetti non emersi nel corso dell'attività di verifica e/o sulla fisiologica evoluzione delle attività e della connessa gestione dei rischi e del sistema di controllo interno.

Al fine di garantire il più possibile coerenza e oggettività nella valutazione, il Responsabile dell'audit, con il supporto del *Team* di audit, effettua analisi e raffronti delle risultanze emerse dall'intervento di audit e delle relative valutazioni rispetto ad altri interventi svolti in precedenza⁷².

Eventuali casistiche⁷³ in cui non viene attribuito un *Rating* devono essere motivate e condivise con il *RIA*. Le motivazioni sono riportate espressamente nel Rapporto di audit/*follow-up*. Il *Rating* del SCIGR oggetto di audit è espresso sulla base di una scala di valori a quattro livelli rappresentata nella figura seguente:

⁷¹ Per le *funzioni IA* che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

⁷² A tale scopo, viene coinvolta, ove necessario e ove presente, la competente struttura della funzione IA responsabile della reportistica sulle attività di audit, al fine di ottenere informazioni consolidate sui precedenti interventi di audit svolti dalla funzione IA.

⁷³ Per esempio, nel caso di audit spot focalizzati su aspetti specifici, circoscritti e quindi non sufficienti ad esprimere un giudizio sul SCIGR.

Rating SCIGR	Descrizione
 Non soddisfacente (Unsatisfactory)	Il SCIGR non è risultato adeguato né operativo.
 Necessari miglioramenti significativi (Major Improvements Needed)	Dalle verifiche svolte sono emerse debolezze diffuse e/o significative che possono pregiudicare l'adeguatezza e l'operatività del SCIGR.
 Necessari alcuni miglioramenti (Some Improvements Needed)	Dalle verifiche svolte sono emerse debolezze specifiche e/o moderate; tuttavia il SCIGR risulta nel complesso adeguato e operativo.
 Soddisfacente (Satisfactory)	Il SCIGR risulta nel suo complesso adeguato e operativo.

Non soddisfacente	Necessari miglioramenti significativi	Necessari alcuni miglioramenti	Soddisfacente
----------------------	---	--------------------------------------	---------------

Alla formulazione del *Rating* concorrono le valutazioni del SCIGR degli ambiti di cui si compone l'oggetto di audit (*Rating* di ambito), secondo la medesima scala sopra riportata, e la valutazione degli effetti reali o potenziali sul SCIGR dei rilievi (*rating* rilievi), nonché la loro numerosità e tipologia (disegno, disegno/operatività, operatività).

Il *rating* dei singoli rilievi è espresso secondo una scala a quattro valori (r1 – r4) rappresentata nella figura seguente:

Rating rilievi	Descrizione
 r1	Rilievo (di disegno e/o operatività) ad alto impatto sul SCIGR che necessita di intervento/i urgente/i, attraverso azioni compensative nelle more dell'attuazione dell'azione principale
 r2	Rilievo di disegno e/o operatività con impatto significativo sul SCIGR che necessita di intervento/i a breve termine, eventualmente anche attraverso azioni compensative nelle more dell'attuazione dell'azione principale
 r3	Rilievo (di disegno e/o operatività) con impatto moderato sul SCIGR, che necessita di intervento/i a medio termine.
 r4	Rilievo (di disegno e/o operatività) con impatto marginale sul SCIGR, che necessita di intervento/i di <i>fine tuning</i> a medio/lungo termine.

Il *rating* dei rilievi è valutato, tra l'altro, con riferimento alla rilevanza: *i*) dei rischi associati al/ai controllo/i riscontrati carenti (rispetto al SCIGR posto in essere a mitigazione dei rischi stessi); *ii*) della ripercussione su più obiettivi di controllo (*Operational, Compliance e Financial*); *iii*) della ripercussione sugli obiettivi di processo/sottoprocesso ed entità del danno potenziale e/o certo che ne deriva (es. in termini economico-finanziari e/o di immagine), dandone evidenza nel Rapporto di audit.

NB⁷⁴: Le informazioni relative al Rating SCIGR e al rating dei rilievi sono inserite nel sistema informativo gestionale

⁷⁴ Per le funzioni IA che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

7.4.2 Predisposizione Piano di Azione dell'intervento

Qualora, dalle attività svolte⁷⁵ dalla **funzione IA**, emergano rilievi sullo stato del disegno e/o operatività del SCIGR oggetto di verifica, il *Management* interessato - con il supporto metodologico della **funzione IA** – individua, in coordinamento con le altre funzioni eventualmente coinvolte⁷⁶, le azioni correttive idonee a risolvere le carenze riscontrate, le relative tempistiche e gli *Owner* responsabili della loro attuazione.

In particolare, il Responsabile dell'audit:

- supporta il *Management* nell'individuazione di azioni correttive che sanino le carenze riscontrate, fermo restando il principio di equilibrio tra efficacia del controllo ed efficienza di processo;
- verifica che le azioni correttive con impatto sul quadro normativo e/o organizzativo siano state preventivamente condivise dall'*Owner* dell'azione con la competente **funzione organizzazione**, che supporterà l'*Owner* stesso nella loro attuazione. In questi casi, va valutato se la suddivisione dell'azione correttiva in due azioni distinte e con *Owner* differenti (proposta di review del quadro normativo esistente e recepimento proposta con pubblicazione del quadro normativo così rivisto) risulti maggiormente efficace ai fini dell'implementazione dell'azione correttiva nel suo complesso;
- suggerisce al *Management*, per gli aspetti a carattere trasversale, di privilegiare azioni idonee a sanare eventuali analoghe criticità su altri processi/strutture aziendali (diversi da quelli analizzati nello specifico intervento di audit);
- verifica che i tempi⁷⁷ previsti dall'*Owner*⁷⁸ per il completamento della/e azione/i correttiva/e siano definiti in funzione del *rating* assegnato al relativo rilievo e che, qualora a causa della complessità dell'azione stessa non sia possibile prevedere tempi ragionevolmente brevi, la struttura auditata abbia previsto azioni correttive compensative di più rapida attuazione che permettano un miglioramento accettabile del SCIGR relativo all'oggetto di audit.

Le azioni così individuate con i relativi *Owner* e le tempistiche di attuazione costituiscono il Piano di Azione dell'intervento, che è parte integrante del Rapporto di audit.

⁷⁵ Ivi comprese le attività di *continuous auditing*.

⁷⁶ Il Responsabile dell'audit verifica l'avvenuta condivisione tra l'*Owner* dell'azione correttiva e le altre funzioni aziendali o società eventualmente coinvolte (quali, ad esempio, funzioni in ambito: *i*) risorse umane e organizzazione, *ii*) information technology, *iii*) legale), sia in fase di individuazione che di realizzazione delle azioni correttive.

⁷⁷ Nella tempificazione dell'implementazione di azioni correttive che necessitano di interventi a medio e a lungo termine, queste ultime devono, di norma, essere scomposte in ulteriori azioni di dettaglio, l'una propedeutica all'implementazione della successiva, con l'attribuzione di tempi di adozione coerenti alla cronologia di attuazione.

⁷⁸ In caso di modifiche organizzative che determinino un trasferimento ad altro ruolo dell'*Owner*, questi trasferisce formalmente la/e azione/i correttive di sua competenza a colui che gli subentra nella posizione organizzativa, comunicando alla **funzione internal audit** il nominativo del nuovo *Owner*.

NB⁷⁹: Le informazioni relative al Piano di azione degli interventi della funzione internal audit di FA SpA sono inserite nel sistema informativo gestionale.

7.4.3 Discussione con il Management

Al termine dell'esecuzione delle attività di verifica, il Responsabile dell'audit, con il supporto del *Team* e coinvolgendo, ove necessario, anche il *RIA*, discute, almeno con il *Management* della/e struttura/e auditata/e, e, se differenti, con i responsabili delle azioni correttive, i rilievi emersi nel corso dell'audit e le raccomandazioni proposte per la loro rimozione al fine di confermare quanto riscontrato, i tempi e i contenuti delle relative azioni correttive da implementare a cura del *Management* interessato.

Il Responsabile dell'audit, valuta, in funzione delle specificità dell'intervento di audit, se discutere con il *Management* e i relativi Responsabili apicali i singoli rilievi/raccomandazioni/azioni correttive nel corso delle attività di verifica, quindi man mano che si consolidano i risultati e/o al termine delle attività di verifica, attraverso uno specifico incontro di *Exit Meeting*.

Gli eventuali suggerimenti minori che non saranno esplicitati all'interno del Rapporto di audit sono comunicati (per iscritto) dal Responsabile dell'audit al *Management* interessato in occasione degli incontri di discussione nel corso delle attività di verifica e/o in sede di *Exit Meeting*.

Nella descrizione del rilievo sono riportate anche eventuali considerazioni del *Management* in merito a quanto rilevato dalla *funzione IA*.

I contenuti dei documenti⁸⁰ utilizzati per la discussione con il *Management* della/e struttura/e auditata/e, condivisi nel corso degli incontri ed eventualmente aggiornati sulla base di quanto emerso in tali sedi, sono riflessi nel Rapporto di audit. Tali documenti dovranno riportare sempre la dicitura "bozza" o "bozza per discussione" e sono finalizzati ad agevolare lo svolgimento degli incontri di discussione con il *Management*.

7.4.4 Predisposizione Rapporto di audit

Dopo la discussione con il *Management* della/e struttura/e auditata/e, il *Team Leader* finalizza la bozza del Rapporto di audit⁸¹, in cui formalizza i risultati delle attività svolte. La bozza di Rapporto di audit è verificata dal Responsabile dell'audit.

Il Responsabile dell'audit, con l'eventuale supporto del *Team* di audit, discute la bozza di Rapporto di audit con il *RIA* di norma preliminarmente alla discussione con il *Management* della/e struttura/e auditata/e.

⁷⁹ Per le *funzioni IA* che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

⁸⁰ Per es. la presentazione di *Exit Meeting*, redatta sulla base dello standard operativo "*ST Exit meeting*", oppure il *draft* del Rapporto di audit.

⁸¹ La cui predisposizione è avviata quando ritenuto più opportuno dal *Team* di audit nelle fasi precedenti ed è redatto sulla base degli standard operativi "*ST Rapporto di audit*".

La bozza del rapporto è quindi discussa dal Responsabile dell'audit, con il supporto del *Team* e, ove necessario, coinvolgendo il *RIA*, con il *Management* della/e struttura/e auditata/e, ivi inclusi i relativi Responsabili apicali, al fine di confermare i rilievi emersi nel corso dell'intervento di audit, le raccomandazioni proposte per la rimozione degli stessi, i tempi e i contenuti delle azioni correttive da implementare a cura del *Management* della/e struttura/e auditata/e.

Il Responsabile dell'audit, con il supporto⁸² del *Team Leader*, aggiorna i dati e le informazioni contenuti nel Rapporto di audit in coerenza con gli esiti finali delle discussioni. Di tali esiti e delle modifiche eventualmente apportate al draft di Rapporto di audit deve essere mantenuta adeguata tracciabilità.

In caso di divergenze con la/e struttura/e auditata/e, queste devono essere evidenziate nel Rapporto di audit⁸³, insieme alle relative motivazioni formulate sia dal *Team* di audit⁸⁴ sia dalla struttura auditata.

Successivamente alla discussione con il/i Responsabile/i apicale/i della/e struttura/e auditata/e, il *RIA* avvia, con il supporto del Responsabile dell'audit⁸⁵, il successivo iter di trasmissione del Rapporto di audit (approvato dal *RIA* stesso).

Laddove necessario⁸⁶, nel corso di svolgimento dell'intervento di audit, devono essere predisposti “*interim report*”, contenenti le evidenze emerse al momento ed elaborati coerentemente a quanto sopra riportato per il Rapporto di audit.

Il Rapporto di audit è firmato⁸⁷ dal *RIA* e dal Responsabile dell'audit (ove non coincidenti).

Secondo quanto disciplinato dagli standard professionali, il Rapporto di audit deve comunicare i risultati delle attività svolte in modo completo, accurato, obiettivo, chiaro, conciso, costruttivo e tempestivo.

Se la comunicazione finale dei risultati contiene significativi errori od omissioni, il *RIA* deve inviare rettifiche e correzioni a tutti coloro che hanno ricevuto la comunicazione originale⁸⁸.

⁸² Il *Team* di audit sarà informato su eventuali aggiornamenti del Rapporto di audit definiti in autonomia dal Responsabile dell'audit.

⁸³ In maniera estesa nella sezione dedicata alla descrizione del rilievo e, ove necessario, in sintesi nell'*executive summary* del Rapporto di audit.

⁸⁴ Cfr. Standard 2600 “*Qualora il responsabile internal auditing concluda che il management abbia accettato un livello di rischio che potrebbe essere inaccettabile per l'organizzazione, ne deve discutere con il senior management. Se il responsabile internal auditing ritiene che la problematica non sia stata risolta, deve segnalarlo al board*”. Interpretazione: “*È possibile identificare il rischio accettato dal management attraverso un incarico di assurance o di consulenza, attraverso il monitoraggio dello stato di implementazione delle azioni intraprese dal management in risposta a incarichi precedenti, oppure in altri modi. Il responsabile internal auditing non è responsabile per la gestione del rischio*).

⁸⁵ E, ove presente, della struttura della funzione IA competente per la programmazione operativa.

⁸⁶ Per esempio, in caso di evidenze rilevanti / gravi da comunicare tempestivamente al Responsabile apicale della struttura auditata. La finalità è quella di pervenire, nel più breve tempo possibile, alla definizione e condivisione di misure idonee a mitigare i rischi correlati alla gravità dei fatti rilevati.

⁸⁷ Digitalmente o su carta. In caso di trasmissione cartacea del Rapporto di audit, quest'ultimo deve anche essere siglato su ogni pagina dal *RIA* e dal Responsabile dell'audit.

⁸⁸ Standard internazionale 2420.

7.4.5 Trasmissione del Rapporto di audit

Il RIA trasmette il Rapporto di audit, con apposita lettera di trasmissione⁸⁹, contestualmente al Presidente del CdA e all'AD della propria società. Successivamente, l'AD trasmette⁹⁰ il Rapporto di audit al Responsabile apicale delle strutture sottoposte ad audit nonché, contestualmente, alle altre strutture interessate, sulla base di quanto previsto nell'*Audit Charter* e negli standard operativi "Lettera di trasmissione"⁹¹.

Il Rapporto di audit è trasmesso⁹² dal RIA anche ai Presidenti del Comitato Controllo e Rischi (ove presente), del Collegio Sindacale e, limitatamente a quelli di competenza, dell'OdV societari.

Il Responsabile della funzione internal audit di Società informa le altre funzioni di controllo di secondo livello circa eventuali inefficienze, punti di debolezza o irregolarità riscontrate nel corso delle verifiche compiute e riguardanti specifiche aree o materia di competenza di tali funzioni, secondo flussi informativi adeguati in termini di contenuti e tempistiche.

Pertanto, nessun Rapporto di audit potrà essere inviato⁹³ a soggetti diversi da quelli sopra riportati e/o a soggetti esterni all'azienda. Al riguardo, si specifica che la società di revisione può consultare i Rapporti di audit cartacei presso la sede della funzione IA, alla presenza di rappresentanti di quest'ultima. Eventuali richieste di rilascio del Rapporto sono consentite solo previo benestare da parte della funzione legale. Tuttavia, potranno essere trasmesse alla società di revisione le relazioni periodiche sulle attività svolte dalla funzione IA.

Il Responsabile apicale della struttura auditata, entro la scadenza definita nella lettera di trasmissione del Rapporto di audit, può eventualmente integrare o modificare il Piano di Azione contenuto nel Rapporto stesso. In caso di modifica e/o eliminazione e/o sostituzione di azioni correttive, rispetto al Piano di azione riportato nel Rapporto, il *Management* della/e struttura/e auditata/e sottopone le proposte di variazioni al Responsabile dell'audit affinché questi valuti, con il supporto del *Team* di audit, l'efficacia nella soluzione dei relativi rilievi, coinvolgendo il RIA ove ritenuto necessario⁹⁴. Il Responsabile dell'audit deve inviare il Piano rettificato a tutti coloro che hanno ricevuto la comunicazione originale. In caso di dissenso sulle rettifiche al Piano ritenute non idonee a presidiare i

⁸⁹ La lettera di trasmissione è predisposta con il supporto del Responsabile dell'audit sulla base dello standard operativo "*ST Lettera di trasmissione a Pres e AD*" in cui sono riportati, tra l'altro, le tipologie di destinatari dei Rapporti di audit. Tra questi anche la Capogruppo di settore come previsto dallo standard. Prima della sua emissione, la lettera di trasmissione è condivisa con la struttura della funzione IA competente in ambito metodologie, ove esistente.

⁹⁰ La proposta per l'AD di lettera di trasmissione è redatta sulla base dello standard operativo "*ST Lettera di trasmissione da AD*" in cui sono riportati, tra l'altro, le tipologie di destinatari dei Rapporti di audit.

⁹¹ Si rinvia a tali standard operativi per il dettaglio dei possibili "mittenti" e "destinatari" del Rapporto di Audit.

⁹² La relativa lettera di trasmissione è redatta sulla base dello standard operativo "*ST Lettera di trasmissione a CCR_CS_ODV*".

⁹³ Dal RIA o dai dipendenti delle Funzioni IA o dall'*outsourcer* (in caso di audit realizzati in *outsourcing*).

⁹⁴ Al termine dell'analisi delle eventuali modifiche al Piano di Azione, il Responsabile dell'audit comunica la versione finale del Piano di Azione al Responsabile della struttura della funzione IA competente per il *reporting* sul monitoraggio azioni correttive, ove esistente.

rischi sottostanti, il Responsabile dell'audit evidenzia tale giudizio nella comunicazione e informa formalmente il Vertice aziendale⁹⁵.

Al fine di agevolare la risposta della struttura auditata, il Responsabile dell'audit, successivamente alla trasmissione del Rapporto di audit, può⁹⁶ inviare agli *Owner* delle azioni correttive un riepilogo (in formato editabile) del Piano di Azione contenuto nel Rapporto stesso.

NB⁹⁷: La trasmissione delle azioni correttive ai rispettivi owner avviene tramite il sistema informativo gestionale.

7.5 Monitoraggio delle azioni correttive

Il monitoraggio delle azioni correttive è una fase fondamentale del processo di *internal auditing* che riveste un ruolo cruciale nel rafforzamento del Sistema di Controllo Interno e Gestione dei Rischi.

Tale attività, infatti, assicura, secondo criteri uniformi, il puntuale presidio del processo di continuo miglioramento del SCIGR dell'Azienda, valorizzando al contempo le competenze e il ruolo del *Management* nel processo di individuazione, gestione e monitoraggio dei rischi dei processi di competenza e nella gestione strutturata delle azioni correttive.

La funzione IA monitora⁹⁸ l'implementazione dei Piani di Azione - definiti dal *Management* a conclusione degli interventi di audit⁹⁹ - mediante *Follow-up* "documentale" e/o *Follow-up* "sul campo".

Il *Follow-up* "documentale" è disciplinato da apposita CO/G – CO (emessa rispettivamente da FS SpA e società controllata), cui si rimanda per la descrizione delle attività e del perimetro di intervento. La funzione internal audit di FS SpA può delegare alla funzione internal audit di Società/Capogruppo di settore/Controllante, mantenendone la supervisione, l'attività di monitoraggio sulla corretta implementazione delle azioni correttive di qualsiasi tipologia di rilievo - indipendentemente dalla sua rilevanza purché attinente a materie comprese nell'ambito operativo della funzione internal audit di FS SpA definito nell'Audit Charter - derivanti dalle attività di audit da questa svolte su società controllate, direttamente od indirettamente.

⁹⁵ Cfr. Standard 2600 "Qualora il responsabile internal auditing concluda che il management abbia accettato un livello di rischio che potrebbe essere inaccettabile per l'organizzazione, ne deve discutere con il senior management. Se il responsabile internal auditing ritiene che la problematica non sia stata risolta, deve segnalarlo al board". Interpretazione: "È possibile identificare il rischio accettato dal management attraverso un incarico di assurance o di consulenza, attraverso il monitoraggio dello stato di implementazione delle azioni intraprese dal management in risposta a incarichi precedenti, oppure in altri modi. Il responsabile internal auditing non è responsabile per la gestione del rischio).

⁹⁶ In funzione dell'organizzazione, degli eventuali strumenti informativi a supporto e dei flussi operativi stabiliti con il *Management* di ciascuna funzione IA.

⁹⁷ Per le funzioni IA che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

⁹⁸ Così come definito dalle specifiche disposizioni aziendali.

⁹⁹ Inclusi eventuali incarichi di consulenza.

7.5.1 *Follow-up* “sul campo”

Il *Follow-up* “sul campo” consiste in una verifica operativa e non solo documentale dell’attuazione delle relative azioni correttive da parte della funzione IA e, di norma, è attivato successivamente al completamento di tutto o di gran parte del Piano di Azione così come emerso dalle attività di *Follow-up* “documentale”.

Quando è in corso il *Follow-up* “sul campo”, il Piano di Azione dell’audit non è più oggetto di *Follow-up* “documentale”; quest’ultimo sarà avviato con riferimento al nuovo Piano di Azione definito in esito al *Follow-up* “sul campo”.

Rispetto al normale flusso operativo per l’esecuzione degli interventi di audit (descritto nei precedenti paragrafi), il *Follow-up* “sul campo” presenta le seguenti specificità:

- la comunicazione dell’avvio dell’intervento è formalizzata attraverso lo specifico standard operativo;
- il piano dei *test* comprende i rilievi e raccomandazioni individuate nell’audit originario, le azioni correttive comunicate dalla/e struttura/e auditata/e per sanare le carenze riscontrate e le verifiche di implementazione delle azioni correttive;
- la predisposizione del Programma di Lavoro è semplificata in quanto l’ambito oggetto di verifica e gli obiettivi sono impliciti nella tipologia di intervento, mentre il Responsabile dell’audit, con l’ausilio del *Team Leader*, definisce il *budget* ore/giorni uomo dell’intervento e le relative *milestones/key dates* secondo quanto previsto nel paragrafo 7.2.4¹⁰⁰.
- di norma il *Rating* complessivo espresso non rappresenta una valutazione “ex novo” del SCIGR dei processi oggetto di verifica, ma l’evoluzione, alla data del *Follow-up*, del *Rating* espresso in sede di audit in funzione dell’effettivo completamento delle azioni pianificate e di eventuali nuovi rilievi;
- i risultati dell’intervento sono formalizzati attraverso lo specifico standard operativo di Rapporto di *follow-up*.

Il Rapporto di *follow-up*¹⁰¹ viene trasmesso sulla base delle stesse regole previste per il Rapporto di audit.

Il Rapporto di *follow-up* “sul campo” riporta le risultanze delle verifiche sullo stato di attuazione delle azioni correttive individuate a seguito del relativo audit. In particolare, il Responsabile dell’audit, con l’eventuale ausilio del *Team Leader*:

- aggiorna lo stato delle azioni correttive in base agli esiti delle verifiche svolte e il rating complessivo sul SCIGR;

¹⁰⁰ E ne dà informativa alla struttura della funzione IA competente per la programmazione operativa, ove esistente.

¹⁰¹ Redatto sulla base dello standard operativo “*ST Rapporto di follow-up*”.

- per le azioni che sono riscontrate come parzialmente/non completate (aperte) a seguito del *Follow-up*:
 - riporta le evidenze emerse in sede di *Follow-up*, quali in particolare il rilievo post *Follow-up*, definendone anche l'eventuale aggiornamento del *rating* rispetto a quello definito in sede di audit (anche relativamente al *rating* complessivo sul SCIGR), la relativa raccomandazione e l'eventuale azione correttiva migliorativa rispetto a quella originariamente prevista (azione correttiva post *Follow-up*);
 - inserisce la nuova data di scadenza dell'azione correttiva;
 - inserisce le informazioni su eventuali nuovi rilievi, relativo *rating* e relative azioni correttive.

L'ambito delle verifiche del *Follow-up* "sul campo" può essere esteso in funzione del tempo intercorso rispetto all'intervento di audit e delle evoluzioni (ad es. organizzative, normative, di business) intervenute. Al riguardo, il periodo di riferimento del *follow-up* sul campo per la determinazione del campione di norma è successivo alla data di chiusura dell'azione correttiva (in esito al *follow-up* documentale).

NB¹⁰²: Il monitoraggio delle azioni correttive tramite follow-up documentale¹⁰³ e follow-up sul campo è gestito nel sistema informativo gestionale.

¹⁰² Per le funzioni IA che utilizzano un sistema gestionale a supporto delle attività di audit, si rimanda al relativo manuale operativo per l'utilizzo dello stesso.

¹⁰³ Con riferimento al monitoraggio delle azioni correttive tramite follow-up documentale da parte della funzione internal audit di FS SpA confronta i seguenti paragrafi del Manuale Operativo MEGA: "Richiesta di Aggiornamento Azioni Correttive", "Aggiornamento status (avanzamento) delle Azioni Correttive", "Verifica dello status dell'azione correttiva".

7.6 Gestione degli interventi con metodologia “agile”

Al fine di implementare e adottare sistematicamente metodologie e strumenti innovativi, la funzione IA può identificare uno o più interventi di audit su cui adottare la metodologia “agile”¹⁰⁴, con l’obiettivo di estenderne l’ampiezza di applicazione nel medio termine.

Di seguito sono illustrate le principali caratteristiche di un intervento in linea con le peculiarità dell’approccio “agile”:

Natura e perimetro dell’intervento	Peculiarità dell’ambiente “agile”
Perimetro di audit complesso che si presta a utili scomposizioni delle attività	Apertura al cambiamento in ottica di miglioramento continuo; <i>Management</i> recettivo
In corso/evoluzione la definizione del processo oggetto dell’intervento	Scomposizione delle attività in task più piccoli per <i>feedback</i> rapidi
Adeguate grado di “maturità” della struttura all’approccio “agile”	Capacità di essere molto tempestivi nella condivisione dei rilievi e di implementare contemporaneamente le relative azioni correttive

Un approccio flessibile da parte del *Team* di Audit e partecipativo da parte della struttura auditata è fondamentale per un’efficace applicazione della metodologia “agile”.

L’approccio “agile” consente al *Team* di Audit di:

- rivisitare le modalità operative, garantendo attività e verifiche a valore anche in scenari in cambiamento;
- essere reattivi sulle priorità di rischi che cambiano in contesti in continua evoluzione;
- essere sempre più propositivi e proattivi nell’agire in coerenza con la strategia, gli obiettivi e i rischi dell’organizzazione e di tenere in considerazione gli impatti futuri;
- supportare le attività con una maggiore tempestività della condivisione dei rilievi e dell’avvio delle relative azioni correttive.

¹⁰⁴ Tale approccio fu adottato per la prima volta da un gruppo di professionisti che si riunì nel 2021 a *Snowbird (Utah – USA)* con l’intento di confrontarsi sui metodi e processi lavorativi in uso per lo sviluppo di software. Fu constatato che i progetti impiegavano molto tempo e - dopo anni di sviluppo e impiego di risorse - i prodotti consegnati non rispondevano più alle esigenze del cliente, che nel frattempo aveva maturato ulteriori necessità connesse alle continue evoluzioni tecnologiche e di business. La risposta fu quindi immaginare un approccio iterativo e adattivo che si adattasse maggiormente a scenari complessi e dinamici (approccio “agile”).

Dal punto di vista metodologico, l'approccio “*agile*” prevede la suddivisione dell'intervento di audit in più sprint:



Un intervento di audit può essere suddiviso in sprint per: *i)* sotto-processo, *ii)* rischio, *iii)* livello di urgenza dell'intervento, *iv)* classe di *stakeholder*, *v)* ogni altra modalità di aggregazione di procedure di verifica funzionale ad una più efficace e tempestiva: *a)* condivisione delle risultanze e *b)* attivazione /implementazione delle azioni risolutive.

All'interno di ciascuno sprint vengono eseguite le attività operative disciplinate nei paragrafi precedenti, con le seguenti ulteriori peculiarità:

- attività preliminare: con continua possibilità di rimodulare/ridefinire l'oggetto e l'obiettivo di analisi. In questa fase viene definito l'*Audit Backlog* inteso come elenco delle attività e degli obiettivi che si intendono raggiungere attraverso l'esecuzione dei vari *sprint*. Tale elenco aiuta a stimare, perfezionare e prioritizzare gli sprint;
- attività esecutiva: svolgimento delle verifiche e possibilità di monitorare il completamento dei Piani di Azione condivisi in sprint precedenti;
- formalizzazione e reporting dei risultati: condivisione immediata del “rapporto di *sprint*”, con il dettaglio delle risultanze emerse; delle relative raccomandazioni dell'IA e delle azioni correttive. In sede di chiusura dell'intervento di audit verrà emesso un Rapporto finale di audit (aggregazione dei singoli “rapporti di *sprint*”) con attribuzione del *rating* a: *i)* intervento di audit, *ii)* singoli sprint e *iii)* rilievi e definizione delle tempistiche e Owner responsabili dell'attuazione del PdA.

7.7 Gestione dei *Joint Audit*

In presenza di specifiche circostanze, concordate dai RIA interessati, è possibile effettuare i c.d. *Joint Audit*, cioè interventi di audit che vedono il coinvolgimento della funzione IA di FS SpA – con il ruolo di *Lead Auditor* - con una o più funzioni IA.

In questi casi l'intervento è svolto secondo il flusso operativo descritto nei precedenti paragrafi del capitolo 7, ma si caratterizza per i seguenti aspetti:

- la lettera di avvio dell'intervento e la lettera di trasmissione del Rapporto di audit sono adeguate¹⁰⁵ in funzione della specificità dell'intervento e firmate dai RIA coinvolti;
- il Rapporto di audit (nonché eventuali interim *report*) è approvato e firmato dai RIA coinvolti, previa verifica e firma da parte dei rispettivi Responsabili dell'audit (ove presenti);
- il *Follow-up* “documentale” viene curato di norma dalla funzione IA che ha svolto il ruolo di *lead auditor*.

L'intervento di *Joint Audit* è svolto da un *Team* costituito dagli *auditors* delle funzioni IA coinvolte che condurranno insieme le verifiche previste, sotto la supervisione dei rispettivi Responsabili di audit. Al Responsabile di audit appartenente alla funzione IA che fa da *lead auditor* spetta il coordinamento ultimo e la verifica finale delle attività svolte.

Non si configurano come *Joint Audit* gli interventi di audit/follow-up gestiti da una funzione IA attraverso un proprio *Team* di risorse integrato con *internal auditors* provenienti da altre funzioni IA, al fine di apportare competenze specifiche al *Team* stesso. In questi casi valgono le indicazioni descritte nel precedente capitolo 7 “Gestione degli interventi di audit”.

7.8 Aspetti specifici degli audit *spot*

La funzione IA svolge interventi di audit cd “spot”, cioè non previsti nel piano di audit e attivati sulla base delle modalità descritte nell'*Audit Charter*, il cui obiettivo è evidenziare eventuali carenze relative al SCIGR sia su aspetti specifici sia su un intero processo, anche con riguardo a presunti irregolarità o atti fraudolenti eventualmente compiuti da personale dipendente e/o da soggetti terzi.

La funzione internal audit assicurerà adeguati flussi informativi, in merito alla richiesta di avvio di audit “spot”, al Presidente e Amministratore Delegato della Società, nonché ai Presidenti del CCR (ove esistente), del Collegio Sindacale e, per quanto di competenza, dell'OdV della Società.

In virtù della propria natura, gli audit “spot” possono comportare l'adozione di specifiche modalità di esecuzione delle attività, nonché la non applicabilità di alcuni degli standard operativi definiti per gli interventi di audit/*follow-up*.

Di seguito si riportano le principali specificità operative di tali interventi, la cui applicazione deve essere, comunque, di volta in volta valutata e adattata alle specifiche esigenze e finalità delle verifiche:

- lo svolgimento degli interventi di audit spot è curato dalla competente struttura della funzione IA oppure da una delle strutture della funzione IA in base all'oggetto dell'audit¹⁰⁶;

¹⁰⁵ In termini di contenuti e destinatari, sulla base degli standard operativi “*ST Lettera di avvio*” e “*ST Lettera di trasmissione*”.

¹⁰⁶ In funzione dell'organizzazione di ciascuna funzione IA.

- il Responsabile dell'audit valuta, in coordinamento con il RIA e in funzione dello scope dell'audit, gli obiettivi specifici dell'intervento che potrà essere di tipo *operational* e/o *compliance* e/o *financial*;
- l'avvio operativo dell'audit avviene sempre tramite comunicazione del RIA (come descritto nel § 7.1), salvo diverse valutazioni, caso per caso, che potrebbero suggerire modalità differenti;
- le attività preliminari sono focalizzate sullo scope/obiettivi specifici dell'intervento, valutando di volta in volta l'opportunità di utilizzare, e nel caso adeguandoli, i relativi standard operativi;
- in caso di coinvolgimento di altre strutture aziendali, il Responsabile dell'audit spot valuta il grado di *disclosure* da adottare in funzione dello *scope* dell'audit, adeguando di conseguenza anche il contenuto delle richieste di documentazione, informazioni e dati alle strutture interessate, soprattutto nel caso di audit spot da segnalazione;
- il Responsabile dell'audit condivide con il RIA, di volta in volta, se attribuire o meno il *Rating* in ragione della sussistenza di elementi, quali, in particolare, l'ampiezza delle analisi svolte su sottoprocessi/fasi di processo o su aspetti più circoscritti, sufficienti a esprimere un giudizio sul SCIGR. Il Rapporto di audit è adeguato di conseguenza ed in esso è specificata la motivazione sottostante all'impossibilità di esprimere il *Rating*;
- con riferimento alle modalità di trasmissione del Rapporto si rimanda a quanto descritto nel § 7.4.5. In alcuni casi può essere prevista l'attivazione di specifici flussi informativi, per esempio verso la funzione in ambito acquisti nel caso in cui sia coinvolto un fornitore.

NB: Per la gestione degli audit spot sul sistema gestionale si rimanda ai riferimenti già inseriti nei precedenti paragrafi del capitolo 7.

7.9 Focus su specifiche tecniche di indagine e analisi

Oltre a quanto riportato nel precedente § 7.7, in determinate circostanze può essere necessario integrare le ordinarie procedure di audit con specifiche tecniche di indagine e analisi. Si fa riferimento, ad esempio, ai casi di indagini finalizzate a ricostruire o verificare eventi illeciti in cui le evidenze raccolte potrebbero essere utilizzate nell'ambito di procedimenti civili e penali e che richiedono pertanto ulteriori specifiche modalità operative di conduzione dell'incarico.

Nel seguito sono illustrate alcune procedure aggiuntive o alternative che il *Team* di audit può applicare in circostanze non ordinarie, di svolgimento delle attività di audit:

- promuovere la costituzione di un gruppo di lavoro inter-direzionale identificando le risorse in possesso delle competenze necessarie (ad es. funzione legale, risorse umane, protezione aziendale, IT, specialisti delle funzioni operative, etc.);

- valutare, con il supporto delle competenti strutture, le modalità da seguire per l'acquisizione di informazioni digitali archiviate in banche dati informatiche (ad es. posta elettronica aziendale, dati di traffico *internet* o telefonici, dati di accesso fisico e logico, etc.), adottando le misure necessarie a tutelare l'integrità forense delle informazioni raccolte e nel rispetto delle normative interne ed esterne applicabili;
- promuovere l'adozione di misure necessarie a salvaguardare la documentazione rilevante ai fini delle analisi, quali ad esempio: sospendere le regole vigenti in materia di periodica cancellazione dei dati (ad es. *back up*, videosorveglianza, registro accessi), congelare l'accesso alla casella di posta elettronica, all'ufficio e agli archivi cartacei e informatici, etc.;
- qualora si rendesse necessario acquisire documentazione presente in un ufficio, l'attività va eseguita da almeno due componenti del *Team* ed in presenza dei responsabili di quelle funzioni aziendali da coinvolgere in funzione delle necessità da valutare caso per caso, avendo cura di documentarne le modalità operative e quanto rinvenuto. In tali circostanze, il Responsabile dell'audit, in coordinamento con il RIA ove necessario, valuta l'opportunità di utilizzare strumenti audio/video per registrare le attività svolte;
- qualora sussistano dubbi sull'originalità, integrità o completezza della documentazione acquisita, il Responsabile dell'audit, in coordinamento con il RIA ove necessario, valuta l'opportunità di ottenere diretta conferma delle stesse da controparti esterne (banche, clienti, fornitori, depositari di merci, service providers, etc.);
- svolgimento di interviste a testimoni e altri dipendenti coinvolti nei fatti oggetto di indagine, da tenersi adottando predefinite modalità di esecuzione quali a titolo esemplificativo:
 - essere svolte solo dopo aver acquisito una buona conoscenza dei fatti e del processo/attività oggetto dell'audit e, possibilmente, sulla base di un elenco preventivamente predisposto di domande da porre al soggetto interessato;
 - essere svolte in modo non "accusatorio";
 - intervistare i dipendenti individualmente in un locale riservato che permetta la necessaria *privacy*;
 - prevedere la partecipazione di almeno due componenti del *Team* di audit, valutando l'opportunità di prevedere la presenza di un referente di altra funzione aziendale indipendente (es. Legale, Contenzioso lavoro, etc.);
 - verificare, prima della conclusione, che sia stata ottenuta una risposta esaustiva a tutte le domande previste e che non residuino, anche a seguito delle risposte ottenute, aspetti non definiti o poco chiari;
 - verificare se, al termine dell'intervista, il soggetto intervistato desideri riferire ulteriori elementi o aspetti;

valutare la definizione, con il supporto delle funzioni legale e/o protezione aziendale e/o risorse umane/contenzioso del lavoro, delle modalità di conduzione e formalizzazione delle interviste, prevedendo ad es. la registrazione della stessa o la redazione di un verbale sottoscritto dalle parti, dandone preventiva informativa al soggetto intervistato. In tale circostanza sarebbe auspicabile che il verbale venisse redatto contestualmente allo svolgimento dell'intervista e sottoscritto a conclusione della stessa.

8 CONTINUOUS AUDITING

Le attività di monitoraggio da *continuous auditing* hanno la finalità di integrare il tradizionale approccio di audit - ciclico, “a campione” e “retrospettivo” - con attività di verifica continuative, “diffuse” e per lo più automatizzate, nell’ottica di una *assurance* in “*real time*”, oggettiva, tempestiva e fondata su dati presenti negli applicativi gestionali aziendali. Tali attività si basano su un set strutturato di indicatori di rischio (*Key Risk Indicator* – KRI)¹⁰⁷ che, per singoli processi/attività/transazioni, individuano la “dimensione” di uno scenario di rischio attraverso l’individuazione di livelli di soglia predeterminati su base quantitativa (ad es.: valore economico, frequenza, incidenza, numerosità, utente): il superamento di questi livelli è monitorato periodicamente tramite un sistema di *reporting* che funziona come strumento di «allarme» per individuare punti critici del sistema di controllo interno. La periodicità è prefissata in ragione dello specifico indicatore, tenendo, in ogni caso, conto del fatto che maggiore è l’ampiezza fissata per la periodicità di esecuzione delle analisi, minore è l’efficacia delle attività di *continuous auditing*.

Il *continuous auditing*, pertanto, si sostanzia in verifiche a distanza effettuate mediante l’estrazione diretta dai sistemi informatici che supportano i processi/attività in oggetto, secondo una frequenza prestabilita, dell’intera popolazione dei dati contabili/gestionali afferenti agli specifici KRI individuati¹⁰⁸.

A seguito dell’analisi¹⁰⁹ dei KRI estratti, laddove emergessero *red flag* (possibili anomalie) la [funzione Internal Audit](#) procede ai relativi approfondimenti attraverso due modalità operative:

1. verifiche specifiche sui KRI con valori e/o trend “anomali”;
2. verifiche sulle anomalie emerse ricondotte nell’ambito di interventi di audit (pianificati e spot) sui processi/attività/transazioni oggetto di *continuous auditing*.

¹⁰⁷ Intesi come “indicatori di possibile anomalia”.

¹⁰⁸ I KRI costituiscono un set “dinamico” di indicatori, potendo essere arricchiti ed aggiornati in base ai cambiamenti della normativa e del contesto di riferimento ed all’emergere di eventuali nuove esigenze in un’ottica *risk based*.

¹⁰⁹ A tali analisi partecipa anche la competente struttura in ambito *anti-corruption* nel caso in cui il processo/attività oggetto di monitoraggio sia sensibile in tale ambito.

8.1 Verifiche specifiche sui KRI

A seguito dell'estrazione dei KRI monitorati, le competenti strutture della funzione IA individuano le casistiche che necessitano di ulteriori approfondimenti sulla base di eventuali *red flag*. Tali approfondimenti vengono condotti con il supporto delle strutture aziendali che gestiscono il processo/attività/transazioni oggetto di monitoraggio.

Le attività di *continuous auditing* si sviluppano attraverso i seguenti *step* operativi:

- elaborazione di un *report* periodico di *continuous auditing*, che evidenzia anche avvalendosi di grafici e/o tabelle: il periodo di riferimento dei KRI, la descrizione ed i valori alla data dei KRI, i trend (ove disponibili), i *red flag* (valori “anomali”), eventuali annotazioni/commenti di natura qualitativa. In caso di interventi di audit in corso sul processo/attività oggetto di monitoraggio, in sede di elaborazione del report periodico la competente struttura in ambito *continuous auditing* pianifica e svolge riunioni di allineamento interno¹¹⁰ con il Team audit;
- trasmissione del suddetto *report* ai Responsabili delle strutture aziendali¹¹¹ che gestiscono il processo/attività/transazioni oggetto di monitoraggio con richiesta della documentazione a supporto per tutti i *red flag* segnalati, laddove non fosse possibile per l'Internal Audit analizzare autonomamente, con le informazioni disponibili estratte dai sistemi informativi, le evidenze emerse;
- verifica degli eventi sottostanti i *red flag* emersi attraverso l'analisi della documentazione fornita, le interviste con il *Management*, eventuali altre informazioni disponibili sui sistemi informativi. A seguito delle verifiche svolte, i *red flag* vengono classificati in funzione della loro rilevanza e conseguente necessità di realizzare gli interventi volti ad eliminarli e/o monitorarli (azioni correttive), secondo la seguente scala di valutazione:

r1	Rilievo (di disegno e/o di operatività) ad alto impatto su SCIGR che necessita di intervento/i urgente/i, eventualmente anche attraverso azioni compensative. Anomalia da eliminare.
r2	Rilievo (di disegno e/o di operatività) con impatto significativo sul SCIGR, che necessita di intervento/i a breve termine. Anomalia da monitorare per verificare la riduzione del rischio correlato almeno al livello di un rilievo con impatto moderato sul SCIGR.
r3	Rilievo (di disegno e/o di operatività) con impatto moderato sul SCIGR, che necessita di intervento/i a medio termine. Anomalia da monitorare per verificare la riduzione del rischio correlato almeno al livello di un rilievo con impatto marginale sul SCIGR.
r4	Nessun Rilievo/Rilievo (di disegno e/o di operatività) con impatto marginale sul SCIGR, che necessita di intervento/i di <i>fine tuning</i> a medio/lungo termine. Nessuna anomalia o anomalia poco significativa.
-	Aspetto in corso di approfondimento.

¹¹⁰ Tali riunioni hanno lo scopo di: *i)* condividere e capitalizzare le informazioni ricevute dalla struttura auditata, *ii)* ottimizzare l'implementazione di eventuali ambiti di miglioramento del SCIGR.

¹¹¹ Di norma primi riporti del Responsabile apicale di struttura (per esempio, per FS, sono le prime linee dei *Chief*).

- Si precisa che, per le analisi su cui, alla data di emissione del *report* finale di *continuous auditing*, sono ancora in corso approfondimenti con le strutture aziendali interessate, non viene espressa una valutazione di rilevanza specifica. Quest'ultima, al contrario, verrà espressa in relazione allo stato dei predetti approfondimenti, in occasione della reportistica dei periodi di analisi successivi.
- Inoltre, nel caso di anomalie “da eliminare” o “da monitorare”, la struttura della **funzione IA** competente può incrementare la frequenza di calcolo dei KRI per verificare il miglioramento del trend dei valori;
- elaborazione di un *report* finale¹¹² periodico di *continuous auditing* integrato con gli esiti delle verifiche sopra descritte e sua trasmissione ai Responsabili apicali¹¹³ delle strutture aziendali che gestiscono il processo/attività/transazioni oggetto di monitoraggio;
- una sintesi della reportistica prodotta nel periodo di riferimento sarà oggetto di informativa¹¹⁴ al Vertice, al CdA e agli Organi di controllo e vigilanza¹¹⁵ e ad altre eventuali funzionali aziendali attori del SCIGR.

8.2 Verifiche ricondotte nell'ambito degli interventi di audit

Sulla base delle informazioni fornite dalla struttura della **funzione IA** competente per la pianificazione degli interventi di audit, la competente struttura della **funzione IA** trasmette al Responsabile dell'audit e ai *Team* di audit interessati l'estrazione dei KRI monitorati, laddove sia previsto (pianificato o *spot*) un intervento di audit sul processo/attività/transazioni oggetto di *continuous auditing*.

Il *Team* di audit utilizza le evidenze emerse dai KRI (inclusa relativa documentazione a supporto); i casi di *red flag* sono oggetto di approfondimento nell'ambito del programma di lavoro dell'intervento di audit. Nel Rapporto di audit sono evidenziati gli andamenti e/o i valori dei KRI di *continuous auditing* analizzati, con la relativa classificazione (descritta nel § precedente) e nella descrizione dei rilievi da essi originati va richiamata la descrizione dei KRI stessi. La struttura della **funzione IA** responsabile del *continuous auditing* analizza le evidenze di audit al fine della predisposizione del *report* finale periodico di *continuous auditing*.

Il *Team* di Audit e il *Team* di *Continuous Auditing* garantiscono uno scambio continuo delle informazioni.

¹¹² Redatto sulla base dello standard operativo “ST Rapporto di *Continuous Auditing*”.

¹¹³ Sulla base dello standard operativo “ST Lettera di trasmissione CA”.

¹¹⁴ Gli esiti di tali verifiche sono riportati nelle relazioni periodiche sulle attività dell'internal audit descritte nell'Audit Charter.

¹¹⁵ In occasione delle relazioni periodiche sulle attività dell'Internal Audit.

9 **COMBINED ASSURANCE: VERIFICHE INTEGRATE AUDIT E TESTING**

262

L'integrazione delle attività di testing 262 nell'ambito degli interventi di audit e di *follow-up* presenta sinergie e benefici in tutte le principali fasi che caratterizzano un intervento di audit/*follow-up*: *i*) pianificazione, *ii*) esecuzione, *iii*) *reporting*, *iv*) monitoraggio piani di azione e abilita i seguenti obiettivi:

- efficienza operativa (es. minor impatto sulle strutture aziendali oggetto di verifica, Programmi di lavoro comprensivi dei *test* 262);
- reportistica integrata;
- monitoraggio coordinato (con le strutture del Dirigente Preposto) dei piani di azione.

L'integrazione può avvenire attraverso due modalità differenti:

1. **Test 262 rientranti nel perimetro/scope dell'intervento di audit/*follow-up*** - In questo caso si ottiene la piena integrazione delle verifiche di audit e 262, cogliendo tutti gli obiettivi citati. Inoltre, i test 262 effettuati in logica integrata concorrono (essendoci piena coincidenza rispetto all'oggetto di audit) al giudizio (*Rating*) espresso dall'IA sul SCIGR del processo esaminato;
2. **Test 262 NON rientranti nel perimetro/scope dell'intervento di audit/*follow-up*** - Eventuali altri controlli 262 da testare durante l'intervento di audit/*follow-up*, sono svolti in ottica di efficienza con metodologia "*agreed upon procedures*" ma i relativi esiti non concorrono al giudizio (*rating*) espresso dall'IA sul SCIGR del processo esaminato.

Per quanto riguarda le attività di testing 262 non integrate e svolte sulla base della metodologia "*agreed upon procedures*" si rimanda al successivo § 10.1.

9.1 Pianificazione degli interventi

L'obiettivo di questa fase è l'individuazione degli interventi di audit integrati con il *testing* 262. A tale scopo, le attività da svolgere sono le seguenti:

- uno degli elementi considerati dall'IA per valutare l'indice di rischio¹¹⁶ complessivo di ciascun Oggetto di Audit (OA) nell'attività di predisposizione del Piano di Audit è la c.d. "rilevanza 262", determinata sulla base delle PAC associate a ciascun OA e delle evidenze contenute nella Relazione annuale trasmessa dal Dirigente Preposto (DP) all'IA (ultima disponibile);

¹¹⁶ Vedi § 5.2 per dettagli in merito all'indice di rischio.

- preventivamente all'approvazione del Piano di Audit, relativo all'anno "X"¹¹⁷, l'elenco degli interventi ivi previsti viene illustrato dal RIA o da un suo delegato al DP o ad un suo delegato che valuta l'impatto degli interventi presenti nel Piano di Audit in ottica del Piano di monitoraggio indipendente 262¹¹⁸. Al fine di comunicare - previa condivisione/informazione vs *staff* DP Capogruppo - alla funzione IA le PAC¹¹⁹ 262 i cui test potranno essere integrati negli interventi di Audit, il DP o suo delegato tiene in considerazione anche le ipotesi di tempistiche di: *i*) realizzazione degli interventi previsti nel Piano di Audit e *ii*) aggiornamento di eventuali PAC;
- la **funzione IA** comunicherà al DP eventuali modifiche del Piano di Audit intervenute in corso d'anno per le valutazioni dei potenziali impatti sul Piano di monitoraggio indipendente 262.

Al fine di cogliere i massimi vantaggi dall'integrazione delle verifiche, si riportano di seguito i criteri a supporto della pianificazione degli interventi integrati:

- valutare la sovrapponibilità e assimilabilità del perimetro dei test 262 e dell'intervento di audit/*follow-up*;
- priorità di applicazione delle verifiche integrate in seno agli interventi di audit (rispetto alle verifiche integrate nei *follow-up*);
- con riferimento alla pianificazione di *follow-up*, dare priorità a quelli il cui audit di riferimento è stato svolto in *combined*;
- associazione delle tempistiche di avvio dell'audit rispetto alle esigenze/tempistiche di *reporting* del DP.

9.2 Esecuzione degli interventi

L'obiettivo di questa fase è l'avvio dell'intervento di audit/*follow-up* integrato e la definizione del programma di lavoro comprensivo degli *script* dei test 262. A tale scopo, le attività da svolgere sono le seguenti:

- trasmissione della lettera di avvio dell'audit/*follow-up* e della comunicazione ai coordinatori societari 262¹²⁰. Quest'ultima entro le tempistiche di seguito riportate. Esplicitare direttamente nella lettera di avvio dell'audit lo svolgimento in *combined* dei test 262 prevedendo in indirizzo (in cc) il DP di FS (o quello societario nel caso di audit svolti dalle funzioni IA societarie);
- il *Team* di audit elabora il programma di lavoro dell'audit/*follow-up* prevedendo al suo interno anche i test sui controlli 262;

¹¹⁷ Di norma a febbraio dell'anno "X".

¹¹⁸ Di norma a giugno-luglio dell'anno "X".

¹¹⁹ Procedura Amministrativo Contabile.

¹²⁰ Nel caso di audit in *combined assurance* svolti dalla funzione internal audit di FS SpA presso società controllate, la comunicazione ai coordinatori societari 262 è effettuata dallo Staff del DP di Gruppo.

- per i *test 262* rientranti nel perimetro/scope dell'audit/*follow-up* e quindi pienamente integrati nelle verifiche, il *Team* di audit e il *Team* del DP devono condividere gli *script* dei test, ivi incluso il campione da selezionare. In questo caso, di norma, sono oggetto di *testing* tutti i controlli previsti dalla PAC di riferimento;
- i *test 262* non rientranti nel perimetro/scope dell'audit/*follow-up*, ma comunque svolti durante l'audit/*follow-up* in ottica di efficienza (anche verso le strutture auditate), sono realizzati con metodologia “*agreed upon procedures*”, cioè sulla base di *script*¹²¹ forniti dallo Staff del DP;
- nelle figure seguenti sono riportati due esempi di programma di lavoro integrato, il primo nel caso di perimetri audit/*follow-up* e 262 coincidenti e il secondo nel caso di perimetri non coincidenti;

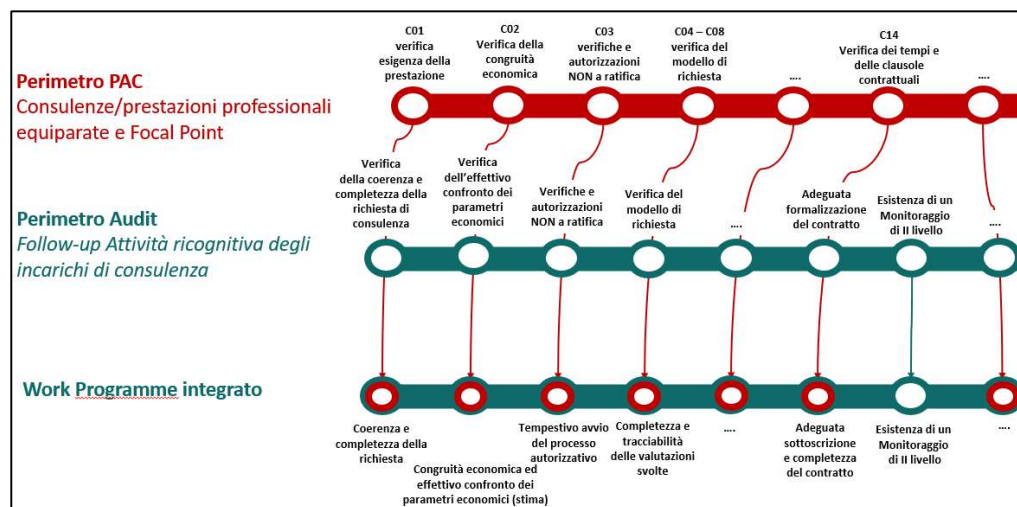


Figura 1: Esempio di Programma di lavoro integrato con perimetri coincidenti

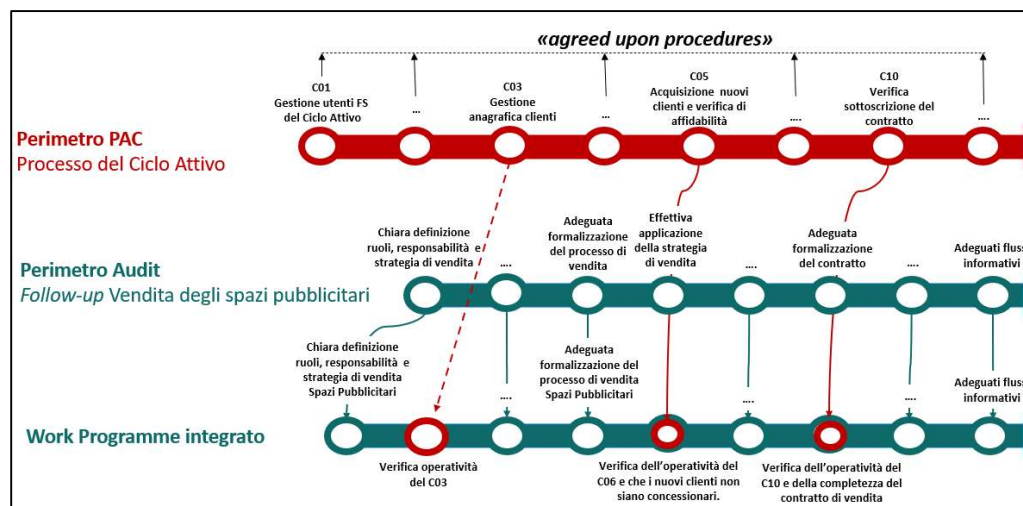


Figura 2: Esempio di Programma di lavoro integrato con perimetri non coincidenti

¹²¹ Con le necessarie informazioni per l'esecuzione del test, quali, ad es., elementi caratterizzanti il controllo, documentazione da ottenere e verifiche da effettuare, tipologia di test, periodo di riferimento e dimensione del campione.

- al *Kick-off meeting* il *Team* di audit e il *Team* del DP rappresentano, tra l'altro, alla struttura auditata l'approccio integrato delle verifiche di audit con i *test* 262. Eventuali esigenze specifiche legate all'attività di audit, per es. di carattere particolarmente riservato, saranno gestite separatamente;
- successivamente, il coordinatore di società dei *test* 262, in linea con le tempistiche previste per lo svolgimento delle verifiche, invia una e-mail di comunicazione avvio attività ai *process owner* e *control owner* con in copia il Responsabile dell'audit (oltre allo *staff* del DP);
- durante lo svolgimento dell'intervento di audit/*follow-up* prevedere incontri periodici tra il *Team* di audit e il *Team* del DP.

9.3 Reporting

L'obiettivo di questa fase è la redazione del Rapporto di audit/*follow-up* e della Relazione per il DP. Tale fase si caratterizza per i seguenti aspetti:

- il *Team* di audit, sulla base delle carenze emerse, valuta il disegno e l'operatività dei controlli della PAC a *test* 262 e fornisce gli esiti al *Team* del DP (inserendo i risultati nel sistema Mega Hopex 262), sia nel caso di verifiche integrate sia nel caso di *testing* 262 non integrati/fuori perimetro dell'intervento di audit/*follow-up* ma comunque svolti durante quest'ultimo;
- il *Team* di audit e il *Team* del DP si coordinano ai fini della valutazione del *rating* delle carenze con rilevanza audit e 262. In particolare:
 - nel caso di carenze da verifiche integrate (in perimetro di audit), il *Team* IA assegna il *rating* sulla base della propria metodologia e lo riporta nel Rapporto di audit; il *rating* è assegnato, secondo la propria metodologia 262, anche dallo *staff* del DP;
 - nel caso di carenze dal solo *testing* 262 (non integrate e quindi fuori perimetro dell'audit), il *rating* è attribuito dallo Staff del DP sulla base della propria metodologia (successivamente agli esiti dei test forniti dall'IA);
- al termine delle attività di *testing* 262, integrate o non, il *Team* di audit redige la Relazione 262 (in formato word);
- individuazione azioni correttive:
 - nel caso di carenze da verifiche integrate (in perimetro di audit), il *Team* di audit condivide i rilievi e le raccomandazioni di audit con le strutture competenti al fine di individuare le relative azioni correttive e le scadenze per il loro completamento (Piano di Azione). Il *Team* di audit e il *Team* del DP si coordinano

preventivamente¹²² in merito al supporto da fornire al *Management* nell'individuazione delle azioni correttive;

- nel caso di carenze dal solo *testing* 262 (non integrate e quindi fuori perimetro dell'audit), il *Team* del DP individuerà in accordo con gli altri attori coinvolti (es. *Process Owner*) le relative azioni correttive;
- il *Team* di audit procede quindi alla formalizzazione del Rapporto di audit/*follow-up* riportando che l'intervento è stato svolto in maniera integrata ed evidenziando i rilievi rilevanti ai fini 262¹²³;
- il *Team* del DP garantirà la chiusura dell'iter approvativo su Mega Hopex 262 prima dell'emissione del Rapporto di audit/*follow-up*.

9.4 Monitoraggio azioni correttive

L'obiettivo di questa fase è il monitoraggio dello stato di attuazione dei piani di azione definiti dall'intervento di audit/*follow-up* integrato. A tale scopo, le attività da svolgere sono le seguenti.

- nel caso di carenze da verifiche integrate/in perimetro di audit, il *Team* di audit, in coordinamento¹²⁴ con il *Team* del DP:
 - monitora lo stato di implementazione dei piani di azione;
 - analizza la documentazione ricevuta¹²⁵ e aggiorna lo status dei relativi Piani di azione;
- nel caso di carenze derivanti dal solo *testing* 262 (non integrate/fuori perimetro dell'audit), le relative azioni correttive sono monitorate autonomamente dal *Team* del DP;
- le azioni correttive individuate dal *Team* di audit su carenze che non integrano il *testing* 262 sono monitorate autonomamente dall'IA;
- qualora, ai fini dell'attestazione dell'anno successivo, il DP pianifichi un *follow-up* sulla PAC oggetto di *test*, il *Team* del DP trasmette gli esiti del *follow-up* 262 all'IA (qualora non svolto dall'IA, nell'ambito dei flussi informativi vigenti);
- qualora anche l'IA pianificasse un *follow-up*, valuterà se svolgere un *follow-up* «integrato» seguendo la metodologia descritta.

¹²² Nel caso di interventi presso società controllate, coinvolgono anche il DP/referente 262 societario.

¹²³ Valorizzando l'apposito "flag" previsto nel Rapporto di internal audit.

¹²⁴ A tal riguardo le due strutture si aggiornano a vicenda tramite e-mail o, se necessario, con riunioni ad hoc.

¹²⁵ A tale scopo, l'Owner dell'azione correttiva invierà la documentazione contemporaneamente al *Team* di audit e al *Team* del DP.

10 ALTRE ATTIVITÀ DI SUPPORTO SPECIALISTICO

La **funzione IA** può svolgere attività di supporto specialistico in materia di SCIGR, quali: *i)* attività di monitoraggio indipendente previste dal sistema di controllo sull'informativa finanziaria della società (cd. monitoraggio indipendente "262"), *ii)* istruttorie su segnalazioni e *iii)* attività di consulenza.

10.1 Monitoraggio indipendente

La **funzione IA** può svolgere attività di monitoraggio indipendente 262 sulla base di quanto previsto dal *Modello di Controllo Interno sull'Informativa Finanziaria del Gruppo FS* (c.d. "Modello 262"), cui si rimanda per dettagli e/o analoghi incarichi con riferimento ad altri modelli di controllo societari che li prevedano.

Il monitoraggio indipendente ha lo scopo di verificare l'adeguatezza e l'effettiva operatività del SCIGR e/o di specifici processi aziendali e rappresenta una forma di monitoraggio di "secondo livello", ulteriore rispetto a quello di linea (c.d. di "primo livello"), di norma attribuito alle funzioni operative responsabili dei processi/attività oggetto di esame.

Il piano delle attività di monitoraggio indipendente "262" è predisposto dal DP di Holdinge pre-condiviso da quest'ultimo con le **funzioni IA**. I *test* sono svolti con un approccio cosiddetto "*agreed-upon procedures*", che consiste nell'effettuare procedure di verifica concordate con la controparte, riportando le risultanze emerse senza fornire "*assurance*". Tali attività prendono avvio con la comunicazione via e-mail ai *process owner* e ai *control owner* da parte del coordinatore di società dei *test* 262 con in copia il Responsabile dell'audit e il *Team* di audit. La struttura di *staff* del DP/Responsabile Amministrativo societario fornisce al *Team* di audit gli *script* di *test* con le necessarie informazioni per l'esecuzione dei *test* (ad esempio: elementi caratterizzanti il controllo, documentazione da ottenere e verifiche da effettuare, tipologia di *test*, periodo di riferimento e dimensione del campione). I risultati delle attività svolte sono verificati dal Responsabile dell'audit, sintetizzati in appositi rapporti¹²⁶ (nonché caricati sul sistema informativo di supporto) e trasmessi dal Responsabile dell'audit¹²⁷ alle strutture di *staff* del DP/Responsabile Amministrativo societario e del DP della Holding.

10.2 Istruttorie su segnalazioni

La **funzione IA** può svolgere istruttorie sulle segnalazioni a seguito di richiesta del Comitato Etico/dell'Organismo di Vigilanza in base alla rispettiva competenza; quest'ultimi presidiano il processo di ricezione, analisi e trattamento delle segnalazioni inviate da Terzi o Personale del Gruppo ai sensi della Procedura per la Gestione delle Segnalazioni societarie.

¹²⁶ Il format della "Relazione di chiusura Test Indipendenti" è fornito dalla competente struttura del DP della Capogruppo.

¹²⁷ O dal *Team* di audit con in copia conoscenza il Responsabile dell'audit.

Nelle istruttorie, la **funzione IA** assicura che siano effettuate tutti gli opportuni accertamenti sui fatti segnalati verificabili, garantendo lo svolgimento delle attività in tempi congrui e nel rispetto dei principi di obiettività, competenza, riservatezza e diligenza professionale.

L'obiettivo delle attività di accertamento sulle segnalazioni è di procedere alle verifiche, analisi e valutazioni specifiche circa la ragionevole conferma, o meno, delle circostanze fattuali segnalate, nonché, ove applicabile, di formulare eventuali raccomandazioni in merito all'adozione delle necessarie azioni correttive sulle aree e sui processi aziendali interessati dalla segnalazione, a fronte delle quali il *Management* interessato redige uno specifico Piano di Azione.

Il Piano di Azione è oggetto di monitoraggio documentale da parte della **funzione IA** ed è ricompreso nella reportistica periodica verso il CdA, il Vertice, gli Organi di controllo e vigilanza e il *Management* in materia di monitoraggio dello stato di attuazione dei Piani di Azione.

Per le modalità operative di dettaglio del processo di ricezione, analisi e trattamento delle segnalazioni e di gestione delle istruttorie, si rimanda alla normativa aziendale in materia.

10.3 Attività di consulenza

La **funzione IA** può svolgere servizi di consulenza volti a fornire supporto specialistico al vertice aziendale e al *Management* nella creazione di valore aggiunto e nel miglioramento dei processi di *governance* e del SCI GR aziendale.

Tali servizi sono svolti, di norma, sulla base di specifica richiesta effettuata da parte del *Management*, anche mediante la partecipazione a *Team*/Gruppi di Lavoro/Comitati inter-funzionali e/o a Progetti di interesse aziendale.

La **funzione IA** definisce, in accordo con il *Management*, gli obiettivi, l'ambito di copertura e le correlate responsabilità, anche al fine di valutare il ruolo ricoperto, le situazioni di potenziale condizionamento e/o di conflitto di interessi, nonché il possesso delle competenze professionali necessarie per l'esecuzione dei servizi.

Nell'ambito di tale attività, la **funzione IA** fornisce il proprio contributo specialistico sui processi, al fine di migliorare l'efficacia e l'efficienza del SCI GR e supportare le funzioni aziendali competenti nell'aggiornamento e/o revisione dei modelli di *compliance* e di *governance* e sui correlati strumenti normativi, senza tuttavia contribuire in via sostanziale al disegno o al funzionamento del SCI GR stesso, senza assumere alcuna responsabilità manageriale nelle attività e/o processo decisionale correlato oggetto di consulenza e mantenendo l'obiettività e l'indipendenza richiesti dalle *practice* di *internal auditing*¹²⁸.

¹²⁸ Inoltre, qualora il RIA abbia, o si preveda abbia, ruoli e/o responsabilità che esulano dall'*internal auditing*, devono essere predisposte misure di salvaguardia atte a limitare le ripercussioni negative sull'indipendenza e l'obiettività (Cfr. Standard internazionale 1112).

Rientrano nei servizi di consulenza anche le attività di formazione sulle tematiche SCIGR erogate dalla **funzione IA**¹²⁹.

Gli interventi di consulenza¹³⁰ vanno previsti nel Piano di audit, al pari di quelli di assurance, e prevedono di norma le seguenti modalità realizzative:

- avvio dell'intervento tramite comunicazione, anche via e-mail, del RIA al responsabile apicale della struttura cui è rivolta la consulenza; nella comunicazione dovranno essere esplicitati, tra l'altro, gli obiettivi della consulenza;
- analisi della documentazione necessaria per lo svolgimento dell'incarico, quale, ad esempio: i) documentazione aziendale di riferimento (procedure, linee guida, modelli gestionali, disposizioni organizzative, etc.); ii) normativa e regolamentazione esterna; iii) elementi di *governance*; iv) standard internazionali;
- interviste ai responsabili delle strutture aziendali interessate dalla consulenza; al riguardo, per agevolare i rapporti e le comunicazioni con i "clienti interni" si può richiedere a quest'ultimi di individuare un referente;
- elaborazione di un *report* finale contenente i risultati dell'incarico e sua trasmissione ai responsabili apicali delle strutture "clienti";
- i risultati degli incarichi di consulenza sono oggetto di informativa al CdA, al Vertice e agli Organi di controllo e vigilanza nell'ambito dei flussi informativi / reportistica periodica della funzione IA verso tali *stakeholders*.

Le conclusioni formulate dalla **funzione IA** non sono vincolanti, fatto salvo il caso in cui emergano rilevanti debolezze di particolare impatto per la società. In tali casi, la **funzione IA** raccomanda la necessità di implementare un piano di iniziative di mitigazione o superamento delle criticità riscontrate. Nel caso di mancata implementazione degli specifici suggerimenti o della mancata adozione di misure alternative, la **funzione IA** informa gli *stakeholders* sopra riportati, secondo le modalità descritte nel paragrafo precedente.

11 FLUSSI INFORMATIVI (*REPORTING*) CON GLI *STAKEHOLDER*

La **funzione IA** redige relazioni periodiche aventi l'obiettivo di fornire informazioni sulla propria attività, nonché sugli esiti, correlate raccomandazioni e piani di azione che ne derivano.

Le relazioni sono riconducibili principalmente alle seguenti tipologie:

¹²⁹ Per esempio, ai Vertici, agli Organi di Governo/Controllo/Vigilanza, al *Management*, ai dipendenti.

¹³⁰ Con riferimento agli interventi non forniti nell'ambito di *Team*/Gruppi di Lavoro/Comitati inter-funzionali e/o a Progetti di interesse aziendale.

- relazione periodica sui principali risultati delle attività svolte dalla funzione IA;
- *report* sullo stato di attuazione delle azioni correttive;
- report specifici per il *Management/Process Owner*.

La **funzione IA**, inoltre, predispone relazioni ad hoc su eventuale richiesta degli Organi di controllo e vigilanza, per eventi di particolare rilevanza sul SCIGR.

11.1 Relazione periodica sulle attività della funzione IA

Secondo le scadenze definite dal calendario delle riunioni degli Organi societari, il **RIA** redige Relazioni trimestrali¹³¹ e una Relazione annuale, che contengono adeguate informazioni sulla propria attività.

Ai fini della predisposizione delle suddette Relazioni il **RIA**, attraverso la struttura interna competente (ove esistente)¹³², raccoglie e analizza tutti i dati, le informazioni e le valutazioni inerenti alle attività svolte dalla **funzione IA**. In particolare, tali Relazioni contengono informazioni in merito a:

- stato di avanzamento degli interventi previsti nel Piano di Audit, ivi compresi eventuali interventi non pianificati (audit spot) attivati nel periodo e quelli pianificati ma non attivati con le relative motivazioni;
- sintesi delle principali tematiche di controllo interno e gestione dei rischi e *governance* emerse dallo svolgimento delle attività di audit, incluse le rilevanze derivanti dall'attività di *continuous auditing* anche attraverso l'analisi su base aggregata dei rilievi emersi dagli interventi di audit con Rapporto emesso nel periodo di riferimento, finalizzate ad analizzarne le principali cause per valutare eventuali implicazioni di carattere strutturale e/o trasversale e formulare eventuali macro-suggerimenti su possibili interventi di miglioramento da attuare;
- sintesi degli esiti delle attività di monitoraggio delle azioni correttive e l'evoluzione delle correlate valutazioni di sintesi del SCIGR;
- organico e *Key Performance Indicator (KPI)* della **funzione IA** (per ulteriori dettagli sui *KPI* si rimanda all'Allegato 2);
- gestione dei rapporti con gli Organi di controllo e vigilanza societari, nonché con altri Comitati aziendali non consiliari (per es. il Comitato Etico);
- attività di indirizzo e coordinamento della famiglia professionale Internal Audit, incluse le attività in ambito metodologie e digitalizzazione del processo internal audit (per la sola FS SpA);

¹³¹ Il Responsabile della funzione internal audit di Società, di concerto con il Presidente della Società, può valutare l'adozione di differenti tempistiche di redazione delle relazioni periodiche, in considerazione della rilevanza degli aggiornamenti da comunicare.

¹³² O altro Responsabile/collaboratore individuato dal RIA.

- altre eventuali informazioni e attestazioni ritenute meritevoli di riporto al CdA.

Il **Responsabile della funzione internal audit di Società** mette a disposizione le Relazioni al Presidente del CdA di Società, all'AD di Società, al Collegio Sindacale di Società e al Comitato Controllo e Rischi di Società, ove presente; le Relazioni sono inoltre trasmesse all'OdV di Società, per le parti di interesse di tale Organismo.

Le Relazioni semestrale ed annuale sono oggetto di informativa al CdA.

11.2 Report sullo stato di attuazione delle azioni correttive

La reportistica periodica dedicata al monitoraggio delle azioni correttive è elaborata dalla funzione IA per dare evidenza dello stato di attuazione dei Piani di Azione individuati in esito agli interventi di audit.

Tale reportistica si focalizza su alcuni principali *KPI*, quali, in particolare:

- incidenza azioni correttive completate e aperte;
- incidenza del ricorso alla proroga (delle date di scadenza delle singole azioni);
- incidenza delle azioni “scadute” (cioè, nel caso in cui l'*Owner* non abbia comunicato, entro la scadenza pianificata, lo “status” dell'azione);
- durata media di realizzazione delle azioni;
- evoluzione del *Rating* SCIGR¹³³ dell'audit in funzione dello stato di attuazione delle azioni correttive.

Il **Responsabile della funzione internal audit di Società** mette a disposizione la reportistica¹³⁴ al Presidente del CdA di Società, all'AD di Società, al Collegio Sindacale di Società e al Comitato Controllo e Rischi di Società, ove presente; le Relazioni sono inoltre trasmesse all'OdV di Società, per le parti di interesse di tale Organismo.

La reportistica periodica è inoltre trasmessa al DP e, ove necessario, ai Responsabili apicali delle strutture di appartenenza degli *Owner* e ai Responsabili delle competenti strutture delle funzioni in ambito risorse umane e organizzazione che supportano gli *Owner* nella realizzazione delle azioni correttive con impatto sul quadro normativo e/o organizzativo.

All'interno della reportistica periodica sono riportate anche informazioni di sintesi sugli esiti del processo di monitoraggio.

11.3 Report specifici per il *Management/Process Owner*

La **funzione IA** collabora e mantiene flussi informativi:

¹³³ A cura del Responsabile dell'audit.

¹³⁴ Tale reportistica può essere contenuta nelle Relazioni periodiche sulle attività dell'IA, di cui al paragrafo 11.1.

- sui temi di SCIGR, con la funzione in ambito organizzazione e i *Process Owner*/Responsabili apicali delle strutture auditate a supporto del continuo miglioramento dell'assetto di *governance* e del modello organizzativo/normativo aziendale e delle iniziative di sensibilizzazione e rafforzamento della cultura del controllo;
- con la **funzione legale**, in merito alle eventuali iniziative da assumere nell'ambito di procedimenti giudiziari, di cui si abbia formale notizia, in cui siano richiamate direttamente o indirettamente attività della funzione IA e/o documentazione da questa prodotta/acquisita;
- con le altre strutture di controllo di "secondo livello" in coerenza con il quadro normativo interno.

In particolare, la **funzione IA** può elaborare specifici *report*/flussi informativi per i *Process Owner*/ Responsabili apicali delle strutture auditate in funzione di valutazioni interne o su richiesta di quest'ultimi.

Tali *report*/flussi informativi hanno una periodicità definita di volta in volta, a seconda delle necessità e possono riguardare, a titolo esemplificativo e non esaustivo:

- la descrizione delle principali tematiche di controllo interno risultate più ricorrenti e/o trasversali alle strutture facenti capo al *Process Owner*/Responsabile apicale di struttura;
- la sintesi delle segnalazioni afferenti ai processi/strutture facenti capo al *Process Owner*/Responsabile apicale di struttura, con indicazione degli esiti e dello stato di avanzamento delle istruttorie e delle azioni di miglioramento/correttive individuate;
- tematiche specifiche, di cui la funzione IA vuole dare evidenza al *Process Owner*/Responsabile apicale della struttura auditata;
- informazioni di dettaglio sullo stato di attuazione delle azioni correttive di competenza (soprattutto per i *Process Owner*/Responsabili apicali di struttura interessati da più attività di audit nel periodo di riferimento).

12 RAPPORTI CON GLI ORGANI DI CONTROLLO E VIGILANZA E IL COMITATO ETICO

La **funzione IA**, al fine di adempiere alle responsabilità attribuitele in materia di SCIGR, assicura¹³⁵ un costante rapporto con tutti gli Organi di controllo e di vigilanza societari e la gestione dei correlati flussi informativi secondo quanto previsto nell'*Audit Charter*.

¹³⁵ Per il tramite del **RIA** e/o, ove esistente, della struttura competente per la gestione dei rapporti con gli Organi di controllo e vigilanza.

Ad integrazione di quanto già riportato nell'*Audit Charter*, nel presente capitolo sono rappresentati i principali contenuti delle attività svolte nei confronti dell'OdV, del Comitato Etico, del Comitato Controllo e Rischi (ove istituito) e del CS societari.

I principi e gli obiettivi contenuti nel presente capitolo troveranno opportuna e adeguata declinazione operativa in ciascuna **funzione IA**, che li armonizzerà con le proprie specificità organizzative (soprattutto per le funzioni IA di minori dimensioni¹³⁶) e/o societarie, in accordo con la **funzione IA di FS SpA**

12.1 Rapporti con l'Organismo di Vigilanza e il Comitato Etico

Nell'ambito dei rapporti con l'OdV, la **funzione IA** assicura supporto e un sistematico e periodico flusso informativo nel rispetto di quanto previsto dallo Statuto dell'Organismo, dal Modello 231 e dall'*Audit Charter*. Il RIA, inoltre, può essere nominato come componente interno dell'Organismo di Vigilanza stesso.

Con riferimento a tali responsabilità, la **funzione IA**¹³⁷, nel caso in cui assicuri le attività di segreteria tecnica dell'OdV e la gestione dei relativi flussi informativi, svolge di norma le seguenti principali attività a supporto dell'OdV stesso:

- definizione del programma dei lavori dell'Organismo (calendario delle riunioni e ordine del giorno di ciascun incontro) e organizzazione dei lavori delle singole riunioni garantendo, tra l'altro: i) la messa a disposizione¹³⁸ della documentazione di supporto (ivi inclusa quella da parte delle varie funzioni aziendali; ii) la pianificazione dei vari interventi all'ordine del giorno affinché possa essere dedicato il tempo necessario all'illustrazione e al dibattito; iii) la relativa verbalizzazione degli incontri;
- gestione e monitoraggio delle tematiche emerse nell'ambito delle riunioni dell'OdV, attivando, ove necessario, opportuni flussi informativi con il *Management* per i temi di competenza, ai fini della relativa trattazione nelle riunioni dell'OdV programmate in calendario;
- predisposizione delle Relazioni per il CdA sulle attività svolte dall'OdV. Le relazioni, firmate dal Presidente dell'OdV, sono trasmesse dalla citata struttura alla Segreteria Societaria nei termini definiti e secondo le tempistiche definite dal calendario del CdA;
- raccolta e monitoraggio dei flussi informativi periodici trasmessi dalle strutture aziendali ai sensi del D.lgs. 231/2011.

¹³⁶ Di norma prive di un'articolazione organizzativa in diverse strutture.

¹³⁷ Tramite il RIA o persona da lui delegata o la struttura della funzione IA competente per i rapporti con gli Organi di controllo e vigilanza.

¹³⁸ Tramite il supporto di eventuali piattaforme informatiche di trasmissione dei documenti/informazioni e nel rispetto delle tempistiche previste dal Regolamento dell'OdV.

Nell'ambito dei rapporti con il Comitato Etico, la **funzione IA** assicura, ove previsto¹³⁹, le attività a supporto del Comitato Etico, quali ad esempio segreteria, gestione flussi informativi, analisi funzionali alla gestione e al monitoraggio delle segnalazioni. Il **RIA** di norma è inoltre componente interno del Comitato Etico.

12.2 Rapporti con il Comitato Controllo e Rischi¹⁴⁰ e il Collegio Sindacale

La **funzione IA**¹⁴¹ gestisce i flussi informativi nei confronti del Comitato Controllo e Rischi (ove istituito) e del CS al fine della tempestiva messa a disposizione delle informazioni rilevanti per l'espletamento dei rispettivi compiti e del coordinamento delle attività nelle aree di comune competenza e garantisce, ove previsto dall'assetto di *governance* societario, le attività di segreteria del Comitato Controllo e Rischi, ove istituito.

Con riguardo alla gestione dei flussi informativi, la funzione IA, in particolare:

- si relaziona con le segreterie tecniche dei citati Organi di controllo¹⁴² in merito alle attività di competenza della **funzione IA**¹⁴³;
- gestisce e monitora l'attuazione delle richieste del CCR e del CS, laddove rivolte alla **funzione IA**;
- assicura l'allineamento informativo tra CCR, CS e OdV sui temi di competenza della **funzione IA**.

13 QUALITY ASSURANCE E MIGLIORAMENTO CONTINUO

Il programma di *Quality Assurance* delle attività di *internal auditing* sviluppato dalla funzione IA, in conformità agli Standard internazionali per la pratica professionale¹⁴⁴, include valutazioni interne (*Internal Quality Review*) ed esterne (*External Quality Review*), finalizzate al miglioramento continuo della qualità delle attività svolte.

13.1 Valutazioni interne (*Internal Quality Review*)

Le valutazioni interne sono svolte sia in via continuativa, con l'obiettivo di verificare costantemente nel tempo l'adeguatezza delle attività della **funzione IA**, sia attraverso verifiche *ad hoc* di carattere non continuativo (*periodic review*) con l'obiettivo di verificare il rispetto delle indicazioni metodologiche fornite, formulare valutazioni conclusive sulla qualità delle attività di audit e di elaborare un piano di iniziative di miglioramento da implementare.

Il monitoraggio continuo delle attività di *internal auditing* è realizzato attraverso:

¹³⁹ Dal suo Regolamento.

¹⁴⁰ Ove istituito.

¹⁴¹ Tramite il **RIA** o persona da lui delegata o la struttura della **funzione IA** competente per i rapporti con gli Organi di controllo e vigilanza.

¹⁴² Nel caso in cui la **funzione IA** non curi la segreteria tecnica per i Comitato Controllo e Rischi.

¹⁴³ A titolo esemplificativo: *i)* la presentazione delle proposte di argomenti di comune interesse formulate dal **RIA** da inserire all'ordine del giorno della riunione; *ii)* la documentazione di diretta competenza della **funzione IA** a supporto della trattazione di specifici argomenti all'ordine del giorno; *iii)* le proposte di integrazione/modifica alla bozza del verbale della riunione precedente per le parti di competenza della **funzione IA**.

¹⁴⁴ Standard nr. 1300, 1310, 1311, 1312 (compreso il Codice Etico dell'Institute of Internal Auditors).

- lo svolgimento di una costante supervisione di tutte le attività operative, assicurata dal **RIA** direttamente oppure, ove possibile¹⁴⁵, tramite un processo di delega interna al personale che opera nella funzione IA dotato di adeguata competenza ed esperienza professionale¹⁴⁶. L'attività di supervisione si estende principalmente ai seguenti aspetti: *i)* conoscenze e competenze richieste per lo svolgimento delle attività; *ii)* adeguatezza della pianificazione delle attività; *iii)* completezza e accuratezza dei programmi di lavoro; *iv)* adeguatezza e tracciabilità delle carte di lavoro nel supportare osservazioni, conclusioni e raccomandazioni; *v)* conformità dei *deliverable* agli standard operativi definiti; *vi)* accuratezza, chiarezza e tempestività dei processi di comunicazione;
- lo svolgimento di interventi di *quality review* a campione sugli audit emessi (attività curate dalla competente struttura della **funzione IA**). A supporto di tali attività sono state elaborate specifiche check-list, cui si rimanda per dettagli;
- la definizione da parte della competente struttura della **funzione internal audit di FS SpA**, in coordinamento con le altre **funzioni IA**, di indirizzi metodologici, di procedure e di strumenti operativi di supporto per lo svolgimento delle attività. A tal fine, tale struttura, secondo un processo iterativo, individua le necessità emergenti in capo agli *stakeholders* interni¹⁴⁷ ed esterni¹⁴⁸ alla struttura e gli eventuali aggiornamenti riguardanti gli Standard internazionali della professione e/o le *best practice* di riferimento¹⁴⁹ sulla cui base elabora e promuove interventi finalizzati a migliorare l'efficacia e l'efficienza delle attività e dare seguito a richieste comuni e specifiche. Tale struttura promuove la partecipazione del personale delle funzioni IA coinvolto nelle attività operative sia in fase di individuazione delle necessità di miglioramento sia in fase di definizione e implementazione degli interventi integrativi/migliorativi al fine di attuare un processo di *feedback* sull'applicabilità degli stessi;
- la definizione e il monitoraggio di *Key performance Indicator* (per ulteriori dettagli sui *KPI* si rimanda all'Allegato 2) che consentono di valutare la qualità, l'efficienza e l'efficacia del processo, nonché la capacità dello stesso di creare valore per l'organizzazione/di rafforzare il SCIGR societario.

Le valutazioni interne periodiche, *Internal Quality Review (IQR)*, sono effettuate almeno ogni 3 anni con l'obiettivo di monitorare:

¹⁴⁵ In funzione dell'articolazione organizzativa della **funzione IA**.

¹⁴⁶ Responsabili dell'audit, Responsabili di altre strutture della funzione IA, *Team Leader*.

¹⁴⁷ **RIA**, Responsabile dell'audit, altri Responsabili di struttura.

¹⁴⁸ CdA, Vertice, Organi di controllo e vigilanza.

¹⁴⁹ In particolare, attraverso la partecipazione a corsi di formazione e iniziative (convention, tavole rotonde, convegni e seminari) promossi dall'Associazione Italiana Internal Auditors (AIIA) e da altre autorevoli associazioni di settore, la consultazione di siti web, pubblicazioni e riviste specializzate, e l'eventuale attivazione di servizi per il supporto metodologico, il *knowledge sharing* e *benchmarking* sulle tematiche di auditing e di SCIGR, nonché la partecipazione a progetti/gruppi di lavoro interni ed esterni a FS.

- l'efficacia, l'efficienza e la qualità del processo di *internal auditing*;
- la conformità, nello svolgimento delle attività operative, rispetto all'*Audit Charter* e agli altri strumenti normativi e/o operativi¹⁵⁰ di cui si è dotata la funzione IA e rispetto alle *best practice* e agli Standard internazionali per la pratica professionale;
- la realizzazione compiuta delle eventuali azioni correttive adottate a fronte di suggerimenti emersi in esito a precedenti interventi di *Quality Assurance* della **funzione IA**;

e di promuovere il miglioramento continuo delle *practice*.

Con riferimento agli interventi di *IQR*, questi sono svolti di norma mediante l'attivazione di un Gruppo di Lavoro composto da risorse interne a ciascuna **funzione IA** o composto da risorse di diverse **funzioni IA**, appositamente definito e coordinato dalla struttura responsabile delle metodologie della **funzione di internal audit di FS SpA**, attraverso un processo strutturato di revisione di tutte le attività della **funzione IA**.

Le *IQR* sono svolte dalla **funzione di internal audit di FS SpA** e/o in maniera "incrociata" tra le diverse funzioni IA.

In particolare, l'*IQR* si compone di norma delle seguenti attività:

- interviste ai RIA e/o altri responsabili all'interno delle **funzioni IA**, con l'eventuale supporto di un apposito questionario, per raccogliere valutazioni e commenti in relazione allo stato percepito delle attività della **funzione IA**;
- analisi su base campionaria o mediante *walkthrough* della documentazione a supporto delle attività svolte dalla Direzione;
- *benchmark*, svolto attraverso un confronto tra i principali *KPI* della **funzione IA** oggetto di *IQR* e i dati medi delle altre **funzioni IA di FS SpA** nonché (ove disponibili) di altre aziende "*peers*" di FS.

Il **RIA** comunica al proprio Vertice e agli Organi di controllo l'ambito e gli esiti delle *IQR* svolte¹⁵¹, comprensivi dell'eventuale piano delle iniziative di miglioramento e dell'aggiornamento periodico del relativo stato di attuazione. I risultati delle suddette valutazioni sono anche comunicati dal **RIA** anche all'OdV della società.

Infine, la **funzione IA**, al termine dell'intervento di audit, chiede al *Management* delle strutture auditate dei *feedback*/suggerimenti in merito all'attività svolta¹⁵².

¹⁵⁰ Tra cui, in particolare, il presente Manuale.

¹⁵¹ Sia monitoraggio continuo che valutazioni periodiche.

¹⁵² Avvalendosi dello standard operativo "*ST Questionario di feedback*", ovvero di altro strumento idoneo a misurare il grado di soddisfazione del cliente.

13.2 Valutazioni esterne (*External Quality Review*)

Le valutazioni esterne, *External Quality Review* (EQR), sono effettuate periodicamente, almeno una volta ogni cinque anni, da parte di un “valutatore” qualificato e indipendente, esterno all’organizzazione, con l’obiettivo di formulare un giudizio complessivo sull’insieme delle attività svolte dalla [funzione IA](#). Le EQR interessano in particolare:

- il ruolo, la struttura e il posizionamento della [funzione IA](#) al fine di valutarne l’indipendenza e l’obiettività;
- l’intero spettro delle attività di audit e consulenza svolte dalla [funzione IA](#) per valutarne la conformità agli Standard¹⁵³, all’*Audit Charter*, alle normative interne ed esterne applicabili;
- le esigenze espresse dal CdA e dal *Management* sulle attività di *internal auditing* e l’adeguatezza dell’*Audit Charter* nel soddisfare tali esigenze;
- la metodologia, gli strumenti e le tecniche impiegate nello svolgimento delle attività di audit;
- la valutazione sulle *best practice* internazionali e di settore adottate e su quelle potenzialmente applicabili all’attività di audit;
- l’integrazione delle attività di *internal auditing* nell’ambito dei processi di *governance* della società, comprese le relazioni all’interno e fra i vari soggetti coinvolti nei suddetti processi;
- l’esperienza, le conoscenze e competenze in possesso degli *auditor*;
- la creazione di valore aggiunto, il miglioramento delle operazioni della società e la contribuzione al raggiungimento delle strategie di business delle attività di *internal auditing*;
- il programma di *Quality Assurance*.

L’incarico al valutatore esterno è assegnato tramite gara, secondo quanto previsto dalla normativa interna ed esterna applicabile. Il valutatore esterno individuato deve garantire piena indipendenza della valutazione e l’assenza di conflitti di interessi (reali o potenziali).

Il [RIA](#) comunica al proprio Vertice e agli Organi di controllo l’ambito e gli esiti della EQR, comprensivi dell’eventuale piano delle iniziative di miglioramento e l’aggiornamento periodico del relativo stato di attuazione. I risultati delle suddette valutazioni sono anche comunicati dal [RIA](#) all’OdV della Società.

¹⁵³ Compreso il Codice Etico dell’*Institute of Internal Auditors*.

14 GESTIONE E ARCHIVIAZIONE DELLA DOCUMENTAZIONE

I seguenti paragrafi descrivono le regole operative di gestione, trattamento e conservazione della documentazione acquisita e prodotta dalle **funzioni IA** in occasione dell'esecuzione di interventi di audit e nel corso di tutte le altre attività svolte nell'ambito della funzione.

14.1 Regole generali di riferimento

Nell'ambito dello svolgimento delle proprie attività, il personale delle **funzioni IA**, anche in qualità di incaricati al trattamento dei dati personali¹⁵⁴, è tenuto a osservare le indicazioni ricevute dal *Data Manager*¹⁵⁵ e le vigenti normative aziendali, pubblicate sull'intranet di Gruppo/aziendale, in materia di *Data Protection* e *Data Classification*.

In particolare, durante lo svolgimento e a conclusione delle attività svolte dalle **funzioni IA**, il personale interessato deve acquisire, produrre e registrare solo dati personali necessari al perseguimento delle finalità delle attività assegnate, provvedendo con la dovuta diligenza affinché non siano conservati documenti cartacei e/o elettronici contenenti dati personali non pertinenti, non necessari o, comunque, divenuti superflui. Il trattamento deve avvenire in modo lecito e secondo correttezza, privilegiando – ove possibile – l'impiego di dati anonimi o opportune modalità che permettano di identificare l'interessato solo in caso ciò risulti necessario ai fini del completamento della/e attività per la/e quale/i il dato è stato acquisito.

Al fine di assicurare la protezione dei dati in proprio possesso, gli accessi ai sistemi informativi a supporto delle attività svolte, che consentono tra l'altro la gestione, condivisione e archiviazione delle carte di lavoro e di ogni altra documentazione attinente alle attività svolte, sono opportunamente protetti e profilati.

In generale, tutti i dati, le informazioni e la documentazione acquisita e prodotta dalla **funzione IA** costituisce “informazione” aziendale riservata, di cui va garantita e tutelata la confidenzialità anche a salvaguardia della funzione di auditing. Pertanto, l'archiviazione e la conservazione di tali dati avverranno con modalità tali da salvaguardarne il massimo riserbo e da impedirne l'accesso da parte di soggetti non autorizzati¹⁵⁶, nel rispetto delle normative esterne e interne applicabili nonché degli Standard internazionali per la pratica professionale¹⁵⁷.

La gestione e l'archiviazione deve essere tale da consentire che i dati, le informazioni e i documenti analizzati e prodotti supportino le conclusioni e i risultati del lavoro svolto e ne consentano la ricostruzione e la ripercorribilità.

¹⁵⁴ Ai sensi della normativa aziendale definita in attuazione del GDPR, l'Incaricato del trattamento di dati personali è la persona fisica designata dal Data Manager che svolge operazioni di trattamento sotto l'autorità diretta del Titolare o del Responsabile, autorizzato in relazione all'attività svolta, al quale il Data Manager fornisce specifiche istruzioni circa il trattamento dei dati personali (per dettagli si veda la DdG n. 295/AD del 9 aprile 2021” e s.m.i.).

¹⁵⁵ Il Data Manager è il responsabile di struttura macro, che in relazione alle attività assegnate, è designato dal Titolare/Responsabile al trattamento di dati personali (per dettagli si veda la DdG n. 295/AD del 9 aprile 2021” e s.m.i.).

¹⁵⁶ Anche con riferimento al ritiro della documentazione mandata in stampa presso le stampanti condivise nonché della eliminazione dei documenti non necessari o, comunque, divenuti superflui.

¹⁵⁷ E dei “Principi” e delle “Regole di Condotta” del Codice Etico dell'*Institute of Internal Auditors*. Standard 2300, 2310, 2320, 2330.

È opportuno privilegiare l'archiviazione della documentazione in formato elettronico¹⁵⁸, anche al fine di consentirne un'agevole consultazione.

Le risorse interessate, con l'eventuale coinvolgimento del Responsabile dell'attività, qualora ritenuto necessario, selezionano la documentazione di lavoro da archiviare secondo le seguenti regole:

- la versione finale (cartacea o elettronica) di tutti i *deliverable* e/o documenti rappresentativi di specifiche *milestone* dell'attività e dei documenti specifici a supporto delle attività stesse (es. e-mail ritenute rilevanti);
- la corrispondenza (cartacea o elettronica) intrattenuta con soggetti terzi (diversi dal personale della funzione IA) contenente elementi utili alla tracciabilità dell'attività svolta (es. elementi che supportano gli esiti dell'attività);
- i documenti forniti da soggetti terzi a supporto di pareri formulati e/o di conclusioni raggiunte.

Viceversa, deve essere eliminata al termine dell'attività tutta la documentazione in formato elettronico o cartaceo non contenente elementi utili e attinenti al lavoro svolto e le conclusioni raggiunte.

La documentazione archiviata (in formato cartaceo ed elettronico) deve essere conservata in coerenza con quanto previsto dalle normative interne ed esterne in materia.

L'archiviazione delle carte di lavoro, ove possibile, deve essere tempestiva in modo da garantire anche l'attività di supervisione del lavoro. A tal fine, la documentazione deve essere archiviata progressivamente durante lo svolgimento delle attività.

Trattandosi di dati inerenti all'attività di *internal auditing* e finalizzati alla valutazione del SCIGR, il complesso delle informazioni, dei dati e della documentazione acquisiti e/o prodotti dalla funzione IA hanno valenza esclusivamente interna ed endoprocedimentale.

Al di fuori del procedimento dell'*internal auditing*, ferme restando le disposizioni aziendali in materia, l'utilizzo da parte della società di tali informazioni, dati e documenti è sottoposto alla preventiva autorizzazione del Rappresentante Legale della società.

14.2 Documentazione di audit

Come anticipato nelle regole generali di comportamento e secondo quanto previsto dagli Standard internazionali per la pratica professionale, il *Team* di audit deve “registrare” nel corso dell'intervento di audit tutte le informazioni rilevanti al fine di supportare le conclusioni e i risultati del proprio incarico, nonché di consentire la ricostruzione a posteriori delle attività svolte e delle eventuali carenze riscontrate.

¹⁵⁸ Sui sistemi informativi disponibili (es. Sistemi gestionali a supporto dell'attività, aree dedicate e segregate nella Intranet aziendale).

Il Responsabile dell'audit assicura, con il supporto del *Team Leader*, l'organizzazione e l'archiviazione¹⁵⁹ tempestiva della documentazione acquisita e prodotta durante lo svolgimento dell'intervento di audit e la sua custodia fino alla chiusura dell'intervento (cioè fino alla trasmissione del Rapporto di audit al Responsabile apicale della struttura auditata). Successivamente alla trasmissione del Rapporto, il Responsabile dell'audit archivia anche gli eventuali raccoglitori.

La documentazione deve essere ragionevolmente completa, ordinata, comprensibile e organizzata in modo logico.

I documenti acquisiti e prodotti nel corso degli interventi di audit devono essere opportunamente denominati e referenziati (catalogati) con l'indicazione di un codice (*reference*) e del nome del documento.

Al termine del processo di archiviazione deve essere predisposto un indice delle carte di lavoro contenente le suddette informazioni nonché la natura del documento (cartaceo o elettronico) e la sezione di archiviazione. Tale indice deve essere firmato dal Responsabile dell'audit e dal *Team Leader* e deve essere allineato/coerente con la struttura di archiviazione elettronica e/o cartacea. L'indice, a sua volta, deve essere archiviato sia elettronicamente sia su un eventuale raccoglitore contenente ulteriore documentazione cartacea.

In particolare, nel caso di archiviazione cartacea, i raccoglitori devono essere segregati e protetti¹⁶⁰, evitando di lasciare la documentazione incustodita sulle postazioni di lavoro.

Per ulteriori dettagli operativi sulle regole di archiviazione si rimanda all'apposita istruzione operativa interna alla funzione IA.

14.3 Altra documentazione

La documentazione raccolta e/o prodotta nel corso delle attività deve essere opportunamente referenziata al fine di consentirne l'individuazione e la consultazione sia nel corso che alla fine del lavoro. È necessario, inoltre, predisporre un indice della documentazione archiviata, specificando se cartacea e/o elettronica e indicando i riferimenti di archiviazione.

La documentazione cartacea deve essere conservata in appositi raccoglitori opportunamente segregati a cura del Responsabile dell'attività, identificati da un numero progressivo e da un titolo che ne consenta di individuarne facilmente il contenuto.

La documentazione elettronica deve essere referenziata e archiviata nei sistemi dedicati. Ciascuna risorsa è responsabile di garantire, in relazione alle attività di propria competenza, l'allineamento dei documenti archiviati su supporto elettronico con quelli (eventuali) in formato cartaceo.

¹⁵⁹ Elettronica e, ove strettamente necessario, cartacea (su appositi raccoglitori). Tali raccoglitori devono essere segregati in armadi chiusi a chiave, evitando di lasciare la documentazione incustodita sulle postazioni di lavoro.

¹⁶⁰ Per esempio, in armadi chiusi a chiave.

La documentazione in formato elettronico o cartaceo che non risulti di diretta pertinenza con gli obiettivi dell'attività e/o non direttamente correlata alle attività svolte deve essere eliminata.

Per la gestione delle segnalazioni oltre a quanto previsto nel presente capitolo, si rimanda anche alle specifiche normative interne in materia.

14.4 Regole di accesso agli archivi

La documentazione, sia essa cartacea o elettronica, è liberamente consultabile dalle risorse coinvolte fino al completamento dell'archiviazione.

Successivamente alla chiusura dell'attività e al completamento dell'archiviazione dei relativi documenti:

- la documentazione elettronica è consultabile accedendo ai sistemi a supporto, in funzione delle profilazioni assegnate;
- la documentazione cartacea può essere consultata richiedendo autorizzazione specifica al Responsabile della documentazione.

Con particolare riferimento agli interventi di audit, il Responsabile dell'audit ha accesso permanente all'archivio elettronico e cartaceo, per tutti gli interventi di audit chiusi (di competenza e non) e per quelli di competenza in corso. Il *Team Leader* ha accesso all'archivio elettronico e cartaceo, per gli interventi di competenza, fino alla chiusura del Piano di Azione da *follow-up* "documentale"¹⁶¹.

La consultazione della documentazione cartacea archiviata presso gli archivi aziendali deve essere richiesta al [RIA](#) o alla sua Segreteria, ove presente. Le risorse interessate a recuperare la documentazione archiviata richiedono via e-mail, con in copia conoscenza il Responsabile della documentazione, l'accesso o la movimentazione dell'archivio aziendale per la consultazione della documentazione.

Il personale della segreteria traccia le consultazioni della documentazione presso gli archivi aziendali con le relative movimentazioni.

Non è consentito l'accesso alla documentazione a soggetti terzi, se non previa specifica autorizzazione del [RIA](#), il quale a sua volta consulta preventivamente il Responsabile della documentazione e/o la funzione legale a seconda delle circostanze. In caso di richiesta di consultazione e/o di consegna (es. da parte di organismi di controllo/autorità giudiziaria), è necessario redigere un elenco che riporti la documentazione consultata/consegnata, mantenendone una copia.

¹⁶¹ Salvo nel caso di Funzioni IA di minori dimensioni e/o prive di articolazione organizzativa, per le quali il RIA può mantenere l'abilitazione anche al *Team Leader*.

14.5 Regole operative di classificazione della documentazione gestita dall'Internal Audit

Tutta la documentazione gestita dalle **funzioni IA** deve essere classificata sulla base delle indicazioni della normativa interna in materia di *Data Classification*.

Con riferimento alla tipologia di documentazione di norma prodotta dalle **funzioni IA**, le regole operative di classificazione da utilizzare sono riportate nell'apposita istruzione operativa interna alla **funzione IA**.

15 TEMPI DI CONSERVAZIONE DELLA DOCUMENTAZIONE

Le informazioni ed ogni altro dato personale, acquisiti dalla **funzione IA** durante lo svolgimento delle proprie attività, sono trattati nel rispetto del GDPR. Pertanto, i tempi di conservazione e tracciabilità della documentazione trattata e prodotta dalla **funzione IA** sono conformi al *Data Protection framework* del Gruppo FS Italiane.

In termini generali, sono applicate le seguenti regole:

- nel caso di interventi di audit/*follow-up*, la documentazione, sia cartacea che elettronica, deve essere conservata per un periodo di dieci anni, a decorrere dal completamento del Piano delle azioni correttive;
- nel caso di gestione segnalazioni, la documentazione, sia cartacea che elettronica, deve essere conservata: *i)* per le segnalazioni fuori ambito, 60 giorni dall'archiviazione; *ii)* per le segnalazioni archiviate a seguito di verifica preliminare e segnalazioni non fondate (così dichiarate a seguito di istruttoria), 5 anni dalla chiusura della verifica preliminare/istruttoria; *iii)* per le segnalazioni parzialmente fondate o fondate (così dichiarate a seguito di istruttoria), 10 anni dalla chiusura del piano delle azioni correttive individuate a seguito dell'istruttoria;
- per tutti gli altri documenti prodotti dalla **funzione IA** il periodo di conservazione è pari a 10 anni;
- per i documenti (siano essi Rapporti di audit/*follow-up*/istruttorie su segnalazioni o documentazione/carte di lavoro ad essi correlati o altri tipi di documenti/relazioni) riferiti ad un tema oggetto di un procedimento giudiziario, valgono le tempistiche stabilite per i trattamenti gestiti dalla struttura Legale.

Per ulteriori dettagli si rimanda al registro dei trattamenti aziendale istituito ai sensi del richiamato GDPR.

16 SISTEMI INFORMATIVI A SUPPORTO

La gestione informatizzata delle attività operative: *i)* garantisce una maggiore protezione delle informazioni/documenti, *ii)* prevede la preventiva autorizzazione dell'utente (profilazione) all'accesso a tali informazioni/documenti, *iii)* consente di ottimizzare la gestione della documentazione pertinente, evitando di archiviare lo stesso documento / informazione su sistemi differenti.

A tal proposito, si raccomanda la progressiva digitalizzazione delle attività attraverso l'utilizzo dei sistemi informativi disponibili nell'ambito del Gruppo FS Italiane, come di seguito elencati.

Per lo svolgimento delle proprie attività, la **funzione IA** si può avvalere dei seguenti sistemi informativi/applicativi a supporto delle attività operative:

- sistema informativo gestionale¹⁶² per lo svolgimento degli interventi di audit/*follow-up*, in ottica di processo *end to end*: dalla pianificazione degli interventi, alla loro esecuzione e supervisione, al monitoraggio delle azioni correttive e all'archiviazione dei documenti acquisiti/prodotti;
- sistema di *reporting*¹⁶³ (*data warehouse*) che utilizza il patrimonio informativo del suddetto sistema gestionale, eventualmente integrato con ulteriori informazioni, consentendo la produzione della reportistica sui diversi ambiti di attività dell'Internal Audit;
- piattaforma *cloud* per la gestione delle segnalazioni/*whistleblowing*, che supporta le attività di ricezione, trattamento, analisi e archiviazione delle segnalazioni ed i relativi flussi informativi, garantendo la riservatezza dell'identità del segnalante e adeguate misure di sicurezza delle informazioni;
- sistema di *knowledge management* per la **funzione IA** e per la famiglia professionale IA (per esempio gestito attraverso canali *Teams* dedicati), contenente in particolare informazioni di fonte esterna (per es. normative, pubblicazioni, materiale relativo a corsi e seminari formativi) e interna (per es. normative interne in materia di IA, standard operativi di audit) di interesse per le attività della funzione;
- sistema di gestione documentale (es. *SharePoint site*) dedicato alla **funzione IA**, in cui risiede l'archivio (elettronico) della **funzione IA** ed eventuali altri archivi dedicati alle strutture costituenti la **funzione IA**. L'accesso a tali archivi è controllato attraverso profili e *permission* assegnati a ciascuna persona della **funzione IA** dall'Amministratore dell'archivio (ruolo ricoperto da una persona della **funzione IA**);
- *software* di *data analytics*¹⁶⁴, come strumenti di: i) supporto allo svolgimento di analisi di audit, verifiche che prevedano l'analisi dei KRI di *continuous auditing*, ii) gestione dei flussi informativi trasmessi dal management ai sensi del D.lgs. 231/2001.

17 INDICE DEGLI ALLEGATI

- Allegato 1: Linee guida per l'utilizzo degli standard operativi
- Allegato 2: *Key Performance Indicator* (KPI) della funzione IA

¹⁶² L'Audit di FS SpA ha adottato il sistema informativo MEGA HOPEX.

¹⁶³ Esempio il software Power BI.

¹⁶⁴ Esempio ACL, Power BI.



Firmato

Sergio ROMITI



VERSIONING DEL DOCUMENTO

Versione/Data			Nome documento	Struttura	Redatto	Verificato	Autorizzato
	v0.0	27/12/2018	Manuale di Internal Audit ¹⁶⁵	Direzione Centrale Audit	F.Sura	F.Sura	G. Cariola
	v.01	01/03/2021	Manuale di Internal Audit ¹⁶⁶	Direzione Centrale Audit	F.Sura	F.Sura	S. Romiti
n. 20	v02	29/05/2023	GR_IO_AUD_Procedura Metodologica Internal Audit (Manuale IA)_n20_v02	Audit	A. Patalano	V. Crescenzi	S. Romiti

¹⁶⁵ In linea con le disposizioni vigenti in materia di emissione dei documenti, tale versione era stata emessa e circolarizzata internamente alla Famiglia Professionale IA dalla funzione IA di FS SpA.

¹⁶⁶ Vedi nota precedente.

ALLEGATO TECNICO “RIFERIMENTI ORGANIZZATIVI” di FS SPA

RUOLO	DATA	STRUTTURA ORGANIZZATIVA	DOCUMENTO DI RIFERIMENTO
funzione internal audit di FS SpA	29/05/2023	Struttura AUDIT a diretto riporto dell’CdA di FS SpA, con il raccordo della Presidente	DOr n. 146/P del 5 agosto 2021
Responsabile internal audit di FS SpA	29/05/2023	Responsabile Struttura AUDIT FS – Chief Audit Officer	DOr n. 146/P del 5 agosto 2021
Responsabile della funzione metodologie IA	29/05/2023	Struttura PIANIFICAZIONE, METODOLOGIE E CONTINUOUS AUDITING in ambito AUDIT	DOr n.185/AUD-COA del 1° aprile 2022
Responsabile dell’intervento di audit o Responsabile dell’audit	29/05/2023	Strutture AUDIT FS, PROCESSI TRASVERSALI E PROGETTI STRATEGICI e RAPPORTI CON ORGANI DI CONTROLLO E VIGILANZA E GESTIONE DELLE SEGNALAZIONI in ambito AUDIT	DOr n. 185 /AUD-COA del 1° aprile 2022
funzione organizzazione	29/05/2023	Struttura GROUP ORGANIZATION in ambito CORPORATE AFFAIRS	DOr n. 9/COA del 1° marzo 2023
funzione formazione	29/05/2023	Struttura TRAINING & LEARNING in ambito CORPORATE AFFAIRS	DOr n. 150/COA dell’8 ottobre 2021
funzione legale	29/05/2023	Struttura LEGAL AFFAIRS di FS SpA	DOr n. 233/AD del 1° dicembre 2022

- Codice Etico del Gruppo Ferrovie dello Stato Italiane;
- Modello di Governance *Internal Audit (Audit Charter)*;
- Procedura monitoraggio delle azioni correttive derivanti dalle attività di Internal Audit;
- Modello Organizzativo e di Gestione di Ferrovie dello Stato Italiane SpA e delle società del Gruppo ex d.lgs. 231/2001;
- Modello di Governance del Gruppo FS Italiane;
- Modello di Compliance del Gruppo FS Italiane;
- Framework Risk Management del Gruppo FS Italiane;
- Policy Anticorruzione del Gruppo FS Italiane;
- Linee di Indirizzo sulla Politica Anticorruzione e Anti-Bribery&Corruption management system adottati dalle Società del Gruppo;
- Framework di Data protection;
- Framework di classificazione e protezione della riservatezza della informazione.